加雲聯網股份有限公司

SI/SM Project and System Security Management Guideline

整合/維護服務專案和系統安全管理指南

版 別：1.0

制訂日期：2024 年 5 月 XX 日

修訂日期：2024 年 5 月 XX 日

制修部門：XXX

頁 數：X

核准	審查	制定

文件發行/修訂記錄

版次	發行日期	生效日期	制修內容摘要
1.0			

Content

1.0 Object 目的 6
2.0 Scope 適用範圍 6
3.0 Responsibility 責任 7
4.0 Definitions 名詞定義 7
5.0 Reference 相關文件 9
6.0 Policy and Procedure 程序內容 10
6.1 Policy 10
6.1.1 The Security Policy 10
6.1.2 Additional Requirements 11
6.2 Organization, Roles, and Responsibilities 11
6.2.1 Organization, Roles, and Responsibilities 11
6.2.1.1 Project Security Management Organization 11
6.2.2 SI/SM Project Security Management Plan Security Assurance Organization 14
6.3 Personnel and Expertise 19
6.4 Configuration and Change Management 19
6.5 Development of Project and System Security 23
6.5.1 Project/System Development Process 25
6.5.1.1 Tendering/Acquisition 37
6.5.1.1.1 Tender Security Requirements 37
6.5.1.1.2 Tender Security Evaluation 37
6.5.1.1.3 Control gate review (R0:C0) 37
6.5.1.2 Project initiation 38
6.5.1.2.1 Security Planning 38
6.5.1.2.2 Systems Security Classification 39
6.5.1.2.3 Threat & Risk Assessment (Preliminary) 39
6.5.1.2.4 Control gate review (R1:C1) 39
6.5.1.3 Development/Design and Development 40
6.5.1.3.1 Detailed risk assessment 40
6.5.1.3.2 Critical Security Design Review 41
6.5.1.3.3 Control gate review (R2:C2) 41
6.5.1.4 Production/Implementation and Verification and Validation 42
6.5.1.4.1 Implementation of system security countermeasures 42
6.5.1.4.2 Application Security Testing 44
6.5.1.4.3 System Security Acceptance Testing 45
6.5.1.4.4 Penetration Testing 46
6.5.1.4.5 Control gate review (R3:C3) 47
6.5.2 Operation and Support/Maintenance – if applicable. 47

6.5.2.1 Perform security review 48
6.5.2.2 Perform type/setting/configuration management. 49
6.5.2.3 Perform Management of Change (MOC) 49
6.5.2.4 Regular security testing and/or evaluation 49
6.5.2.5 SuC's cybersecurity incident response and recovery 50
6.5.2.6 Perform continuous monitoring 50
6.5.2.7 Control gate review (R4:C4) 50
6.5.3 Decommissioning/Disposal – if applicable 51
6.5.3.1 Preserve Information 51
6.5.3.2 Sanitize Media 51
6.5.3.3 Dispose Hardware & Software 52
6.5.3.4 Control gate review (R5:C5) 52
6.6 Risk management and continuous improvement 52
6.6.1 KPI formulation 52
6.6.2 Regular evaluation 53
6.6.3 Audit and Security assessment 53
6.6.4 Prevention and Correction 54
6.6.5 Management review 54
7.0 OT Security Practices 56
7.1 Practices for Security Planning 56
7.1.1 Development of Security Plan 56
7.1.1.1 Security Management Plan 56
7.1.1.2 Security Vendor Management Plan 57
7.1.1.3 SI/SM Project Security Management Plan 58
7.1.1.4 Security Policy and Procedures Plan 59
7.1.2 Review and Management of Security Plan 61
7.1.3 Training activity for Security Plan 62
7.2 Practices for Threat and Preliminary Risk Assessment (TRA) 63
7.2.1 Perform Threat and Preliminary Risk Assessment and Documentation 63
7.2.2 Review and Management of Threat and Preliminary Risk Assessment 65
7.3 Practices for Detailed Risk Assessment 66
7.3.1 Perform Detailed Risk Assessment and Documentation 66
7.3.2 Critical Security Design Review 69
7.4 Practices for Implementation of system security countermeasures 70
7.4.1 Implementation of system security countermeasures and Documentation 70
7.4.1.1 Implement and document the assurance security. 71
7.4.1.2 Implement and document the network segmentation (architecture) security. 71
7.4.1.3 Implement and document the account management security 77
7.4.1.4 Implement and document the configuration management (CM) 81

7.4.1.5 Implement and document the SuC's Asset Hardening 83
7.4.1.6 Implement and document the wireless security if security control required. 83
7.4.1.7 Implement and document the Safety Instrumented System (SIS) security if security control required 85
7.4.1.8 Implement and document the remote access security if security control required. ... 87
7.4.1.9 Implement and document the event management security if security control required. 89
7.4.1.10 Implement and document the malware protection security if security control required 92
7.4.1.11 Implement and document the Patch management security if security control required. 95
7.4.1.12 Implement and document the Backup/Restore security if security control required. 100
7.4.2 Review and Management of Implementation of system security countermeasures 104
7.5 Perform Application Security Testing 104
7.6 Practices for System security acceptance testing process 116
7.6.1 Perform System security acceptance testing process and Documentation 116
7.6.2 Review and Management of System security acceptance testing process. 131
7.7 Practices for Operations and support/maintenance stages 131
7.7.1 Regular security testing and/or evaluation 131
7.7.2 Review and Management of Operation and Support/Maintenance 132
7.8 Process for maintenance service 132
7.8.1 Operation 133
7.8.1.1 Access control 134
7.8.1.2 Physical access security 134
7.8.1.3 Logical access security 134
7.8.1.4 Wireless access 135
7.8.1.5 Remote access 135
7.8.1.6 Electronic use criteria 137
7.8.1.7 Bypasses/overrides 137
7.8.2 Maintenance 138
7.8.2.1 Routine maintenance 138
7.8.2.2 Automation asset integrity program 139
7.8.2.3 Obsolescence planning 140
7.8.2.4 Tools 140
7.8.3 Audits and assessments 144
7.8.3.1 Audits 144
7.8.3.2 Job cybersecurity assessments 145
7.8.3.3 Service provider/product supplier qualifications 145

7.8.4 Security monitoring and performance measurement 146
7.8.4.1 Alarms and alerts..... 146
7.8.4.2 Automated security monitoring 147
7.8.4.3 Key performance indicators..... 147
7.8.5 Incident management 148
7.8.6 Regular assessments 149
7.8.6.1 Purpose 149
7.8.6.2 Input and guidance 149
7.8.6.3 Output 151
7.8.7 Change assessments: management of change..... 151
7.8.7.1 Management of change..... 152
7.8.7.2 Decommissioning..... 155
7.8.7.3 Assessing the change work process 158
8.0 Tables 表格 179
8.1 The SI,SM Project and System Security Management Guideline – Annexes (整合/維護服務專案和系統安全 - 附件) 179
8.2 The tasks of Secure Project/System development lifecycle and the reference sections for implementation with mapping to IEC 62443-2-4 SP requirements..... 180
8.3 The tasks, delivery outputs, and implement procedures in accordance with IEC 62443-2-4 SP requirements..... 204

1.0 Object 目的

This document describes a set of high-level guiding principles, practices and/or processes for the security management of Intelligent Cloud Plus's (ICP's) Industrial Automation and Control Systems (IACS) relevant secure Integration/Maintenance Services. This includes:

1. Providing the fundamental and high-level guiding principles, practices and/or processes on security management for IACS secure Integration/Maintenance Services;
2. Providing the necessary technology, processes/procedures, and personnel requirements for an IACS Integration/Maintenance Services Security life cycle management to satisfy the requirements specified in IEC 62443-2-4 standard, and if necessary, being applied to support the security management for the plan and implementation of an Integration/Maintenance Services project that was based on IEC 62443-2-4 standard or the development of an automation solution that was based on IEC 62443-3-3 standard; and
3. Providing the foundation for further procedure development.

2.0 Scope 適用範圍

2.1 Applicability

1. This document applies to ICP's Systems' or IACS Automation Solutions' (i.e., SuC's) Security for an Integration/Maintenance Service Project (SI/SM Project) (hereafter referred to as the Project) management program.
2. If there are additional applicable regulations, standards, codes and practices, or any security requirement specified by the Project Employer or Asset Owner (PE/O), ICP should moderately consider, apply them, and make necessary engineering justifications.
3. If the project has additional functional security considerations, it is recommended to refer to IEC TR 63069 and/or IEC TR 63074 technical reports for the necessary mapping of functional security requirements and to refer to IEC 61508 and specific sector applications functional security standards for implementing those kinds of System security and security assurance activities.

2.2 Validity and Reviews

1. This document is valid throughout the entire System or IACS Automation Solution (i.e. System under Consideration, SuC) as well as the SuC after the Verification and Validation Testing phase, such as the Operation and Support/Maintenance stage, support, and retirement (decommission) stage of the End-of-Life (EOL)/End-of-Sale (EOS) while performing the security management activities during the SuC life cycle.
2. While performing the security activities during the SuC life cycle (SLC), ICP shall have a management system to support a Project security activity based on this document. All documentation related to the Project security shall comply with the ICP's QP-11 產品

檢驗管理程序, QMS-01 品質手冊 session 8 and QP-03 客戶需求管理程序, secure project development quality assurance (QA) and/or security assurance processes to be delivered for review.

3. This document should be reviewed and revised if necessary, such as
   (1) Applicable regulations, standards, or code and practices changes or revisions;
   (2) After a major security incident;
   (3) ICP's security policies changes or revisions;
   (4) Any ICP's company-designated periodic review period; and
   (5) Other designated by task-based project review.

3.0 Responsibility 責任

The Project/System Security Office(P/SSO) will be responsible for the promotion of the security management framework of secure projects/systems and support the security operation of the secure SuC development process.

4.0 Definitions 名詞定義

ABAC	Attribute-Based Access Control
AD	Active Directory
BPCS	Basic Process Control System
CA	Certification Authority
CCM	Configuration and Change Management
CEF	Common Event Format
CISSP	Certified Information Systems Security Professional
CM	Configuration Management
COTS	Commercial Off-The-Shelf
CSA	Cybersecurity Assessor or Cybersecurity Assessment
CSMS	Cyber Security Management System
CSRS/CRS	Cybersecurity Requirements Specification
CSSLP	Certified Secure Software Lifecycle Professional
DFD	Data Flow Diagram
ESG	Environment, Social, Governance
EOL	End-of-Life
EOS	End-of-Service or End-of-Sale
EWS	Engineering Workstation Server
FAT	Factory Acceptance Test
HSE	Health, Safety, and Environmental
IACS	Industrial Automation and Control System
ID	Information Department
IDS	Intrusion Detection System

ITP	Inspection and Test Protocol
MIB	Management Information Base
MOC	Management of Change
LDAP	Lightweight Directory Access Protocol
NIST	National Institute of Standards and Technology
OS	Operating System
OSS	Open-Source Software
PBAC	Policy-Based Access Control
PD	Project Department
PE/O	Project Employer or Asset Owner
PJS	Project Security Leader
PKI	Public Key Infrastructure
PM	Project Manager
P/SSO	Project/System Security Office
PtW	Permit to Work
QA	Quality Assurance
QMS	Quality Management System
RBAC	Role-based Access Control
RCA	Root Cause Analysis
SAC	Security Analysis Center
SAT	Site Acceptance Test
SCA	Static Code Analysis
SDL	Security Development Lifecycle
SIAC	Safety, Integrity, Availability, and Confidentiality
SIEM	Security Information and Event Management
SIS	Safety Instrumented System
SL	Security Level
SL-T	Target Security Level
SNMP	Simple Network Management Protocol
SPR-T	Target Security Program Rating
SSDLC	Secure Software Development Life Cycle
SSID	Service Set IDentifier
STC	Security Test Center
SuC	System under Consideration
SVV	Security Verification and Validation
SW	Software
TCP	Transmission Control Protocol
TL	Technical Leader for SW
TRA	Threat and Risk Assessment

TPC	Third-party Component
TST	Tester
UDP	User Datagram Protocol
VAL	Validator
VER	Verifier
WBHS	Windows Based Host Servers

5.0 Reference 相關文件

[1] ID25- A17-M600-CM20-01 專案管理程序 ||QMS-01 品質手冊 第 8 章營運 和 QP-03 客戶需求管理程序

[2] ID26- A17-M732-CM20-01 設計管理程序 ||QP-14 設計管制程序

[3] ID24- A17-M720-CM20-01 工程規劃執行與驗收管理程序 ||QP-11 產品檢驗管理程序

[4] ID27- A17-P300-EHS20-11 事故、不符合與矯正措施管理程序 ||QP-05 不符合與矯正預防管理程序

[5] ID16- A17-C520-CP20-01 供應、承攬商管理程序||QP-07 採購與供應商管理程序

[6] ID28- A17-C520-CP20-02 採購管理程序||QP-07 採購與供應商管理程序

[7] ID29- A17-M630-QM20-01 倉庫作業管理程序||QP-12 倉儲及出貨管理程序

[8] ID30- A17-M500-QM20-01 材料檢驗與搬運儲存管理程序 || QP-12 倉儲及出貨管理程序

[9] TAICS TR-0023 v1.0 智慧製造工業自動化控制系統資安指引-第一部:資產擁有者

[10] TAICS TR-0027 v1.0 智慧製造工業自動化控制系統資安指引－第二部：整合和維護服務提供者

[11] TAICS TR-0031 v1.0 智慧製造工業自動化控制系統資安指引-第三部產品供應商之製造系統網宇安全

[12] IEC 31010 Risk management — Risk assessment techniques

[13] IEC 62443-2-1 Industrial communication networks - Network and system security - Part 2-1: Establishing an industrial automation and control system security program

[14] IEC 62443-2-4 Security for industrial automation and control systems - Part 2-4: Security program requirements for IACS service providers

[15] IEC 62443-3-2 Security for Industrial Automation and Control Systems – Part 3-2: Security Risk Assessment, System Partitioning and Security Levels

[16] IEC 62443-3-3 Industrial communication networks - Network and system security - Part 3-3: System security requirements and security levels

[17] IEC TR 62443-2-3 Security for industrial automation and control systems - Part 2-3: Patch management in the IACS environment

[18] IEC TS 62443-1-1 Industrial communication networks - Network and system security - Part 1-1: Terminology, concepts, and models

[19] ISA TR 84.00.09 Cybersecurity Related to the Functional Security Lifecycle

[20] ISO 31000 Risk management — Guidelines

[21] ISO/IEC 27000 Information Technology – Security Techniques – Information Security Management Systems – Overview and Vocabulary

[22] ISO/IEC 27001 Information Security Management System

[23] ISO/IEC 29147 Information technology – Security techniques – Vulnerability disclosure

[24] ISO/IEC 30111 Information technology – Security techniques – Vulnerability handling processes

[25] Lockheed Martin Kill Chain, https://www.lockheedmartin.com/content/dam/lockheed-martin/rms/documents/cyber/Seven_Ways_to_Apply_the_Cyber_Kill_Chain_with_a_Threat_Intelligence_Platform.pdf

[26] MITRE ATT&CK MITRE ATT&CK method for Industrial Control Systems, https://collaborate.mitre.org/attackics/index.php/Main_Page

[27] NIST FIPS 140-2 Security Requirements for Cryptographic Modules

[28] NIST SP 800-30 Information Security

[29] NIST SP800-37 Risk Management Framework for Information Systems and Organizations

[30] Operationally Critical Threat, Asset, and Vulnerability Evaluation Service Mark (SM) (OCTAVESM) Framework, Version 1.0, https://resources.sei.cmu.edu/asset_files/TechnicalReport/1999_005_001_16769.pdf

[31] TR-e-IoT-SCS-Part-2 Generic Protection Profile (GPP)

[32] STRIDE-LM Threat Model, https://csf.tools/reference/stride-lm/

6.0 Policy and Procedure 程序內容

6.1 Policy

6.1.1 The Security Policy

The Intelligent Cloud Plus (ICP) is committed to offering a Project/System that meets or exceed industry standards for security. ICP's Project Employer or Asset Owner (PE/O) must be able to use the System with confidence that those secure systems minimize the risk of vulnerability to malicious or unauthorized use or attack by any third party. ICP delivers on these commitments by doing the following:

1. Including security as a design feature in all of the ICP's IACS secure projects/systems;
2. Adopting robust security practices; and
3. Appropriately managing, implementing, and verifying and/or validating security practices and processes throughout the entire lifecycle of the projects/systems.

ICP requires its employees and stakeholders as well as its suppliers to support these commitments.

In furtherance of these security commitments, ICP should adopt the following vital security steps:

1. Established a comprehensive Project/System security program ("Project/System Security Program") managed by the Project/System Security Office (P/SSO),

which reports directly to the Chief Project/System Security Officer (CP/SSO). This program encompasses critical security processes and practices being implemented across the Project/System lines. ICP's employees and stakeholders are required to comply with the Project/System Security Program and its related requirements. Furthermore, the ICP should request its suppliers to make commitments to support the implementation of Product Security Programs and as a condition of doing business with ICP;

2. Identified the corporate CP/SSO and designated the P/SSO as the ICP official responsible for developing, implementing, and enforcing Project/System Security Programs and processes across the company. The P/SSO has the authority and resources to carry out these responsibilities; and

The security of ICP's Project/System is a key factor for the PE/O to choose ICP as their qualified supplier.

6.1.2 Additional Requirements

A policy for the Project/System security shall be defined, approved by management, published, and communicated to employees and relevant external parties. The policy:

1. Is appropriate to the purpose of the organization;
2. Includes security objectives or provides the framework for setting security objectives;
3. Includes a commitment to satisfy applicable requirements related to the Project/System security; and
4. Includes a commitment to continual improvement of the Project/System security management system.

The security policy should:

1. Be available as documented information;
2. Be communicated within the organization;
3. Be available to interested parties, as appropriate; and
4. Be reviewed at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy, and effectiveness.

6.2 Organization, Roles, and Responsibilities

6.2.1 Organization, Roles, and Responsibilities

6.2.1.1 Project Security Management Organization

1 A management framework should be established to initiate and control the implementation and operation of the Project security within the organization. The roles and expertise required in the SI/SM Project Security Management Plan are described in 6.2.2 and 6.3 of this guideline.
The key competencies for roles can be referred to Annexes Table B.1
The roles and responsibilities within the Project security management

framework shall be identified, which should contain at least the following items (See Figure 1 and Table.1.).

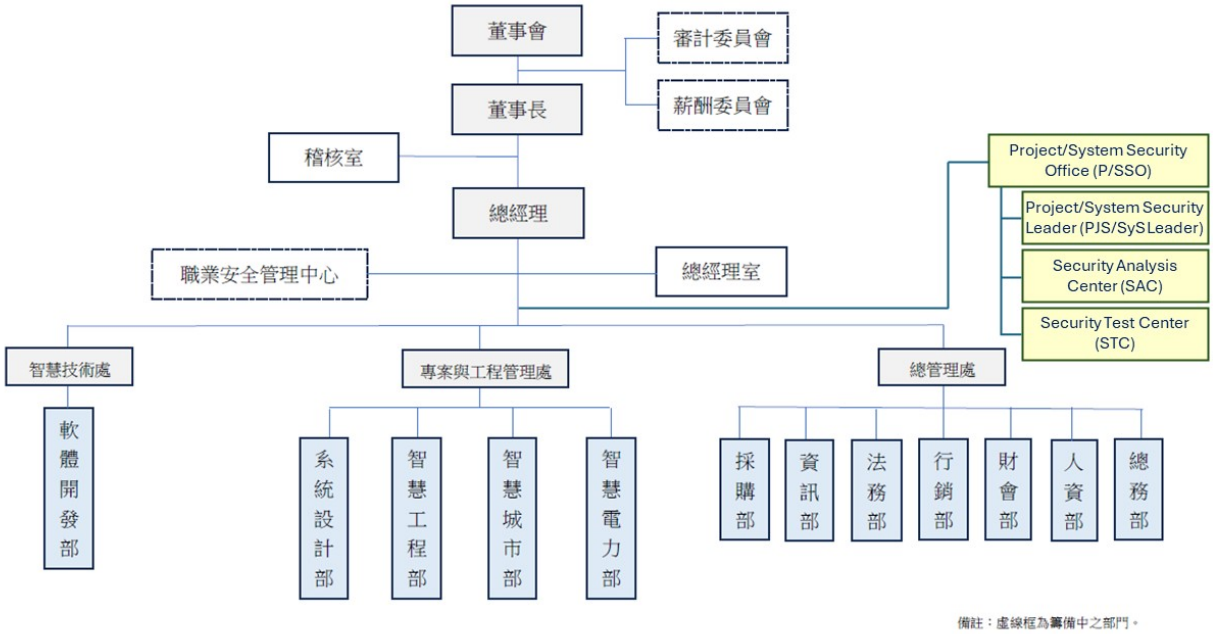

Figure 1 The Project Security Management Organization.

Table.1 Roles and Responsibilities of the Project Security Management Organization.

Roles	Responsibilities
Project/System Security Office(P/SSO)	(1) Building capabilities for Cybersecurity Assessor (CSA), Validator (VAL) & Verifier (VER). (2) Developing corporate governance/policies/procedures; (3) Participating in or assisting with the implementation of cyber threat identification, analysis, risk assessment, and evaluation activities as needed; (4) Planning and establishing the management processes, procedures, and technical practices for the Public Key Infrastructure (PKI), and providing technical support for the implementation, use, and maintenance of PKI, when needed; (5) Providing or assigning personnel to perform third-party independent assessments of a Project security and provide a Project Cybersecurity Assessment report, where applicable; (6) Training and communications; (7) Managing documents for IEC 62443 guidelines; (8) Providing announcements of the risk assessment management program and/or system, threat construction project, and consulting on the analysis and requirements of the required countermeasures; and (9) Maintaining the list of third-party components used by ICP's Projects.
Project Security (PJS) Leader	(1) Enforcement of Project security methodology on Project and system development activities; (2) Overseeing and directing the adoption of the ICP's Project Security Policy; (3) Acceptance of security risk; (4) Assigning personnel to a risk assessment review meeting or independent designee to review the security of a secure Project.
Security Analysis Center (SAC)	(1) Participating in or assisting with the implementation of cyber threat identification, analysis, risk assessment, and evaluation activities as needed; (2) Providing solutions for Project security issues and necessary technical advice; and

Roles	Responsibilities
	(3) Promoting the application, auditing, and tracking of the implementation, and replying to feedback from the teams.
Security Test Center (STC)	(1) Participating in or assisting with the implementation of security test, verify, and validate; (2) Providing solutions for secure Project security issues and necessary technical advice; and (3) Promoting the application, auditing, and tracking of the verification and validation, and replying to feedback from the teams.

6.2.2 SI/SM Project Security Management Plan Security Assurance Organization

1 The following roles and responsibilities of a typical project security assurance organization must be planned in a secure Project development plan (See Table 2.).

The key competencies for roles can be referred to Annexes Table B.2.

The organization independence requirements, and the repletion between the roles in Project-oriented organization and the project-oriented organization are described in Annexes B.2.

Table 2.Roles and Responsibilities of the SI/SM Project Security Management Plan Security Assurance Organization.

Roles	Responsibilities
Project Manager (PM)	(1) Take full responsibility for project management in relation to security assurance; (2) Ensure that the Quality Management System (QMS) and independence of roles, according to relevant parts of IEC 62443, are in place for the project and that progress is checked against the plans; (3) Allocate a sufficient number of competent resources in the project to carry out the essential tasks including security activities, bearing in mind the required independence of roles; (4) Ensure that a suitable VAL has been appointed for the project as defined in IEC 62443; (5) Be responsible for the delivery and deployment of the Project and ensure that security requirements from the PE/O is also fulfilled and delivered; (6) Allow sufficient time for the proper implementation and

Roles	Responsibilities
	fulfillment of security tasks; (7) Endorse partial and complete security deliverables from the development process; and (8) Ensure sufficient records and traceability is maintained in security-related decision-making. (9) Assign a security contact in its organization to the Automation Solution which is responsible and accountable related to the requirements of 7.1.1.3 3.
Project Security (PJS) Leader	(1) Enforcement of Project security methodology on Project and system development activities; (2) Overseeing and directing the adoption of the ICP's and Asser owner's Project Security Policy; (3) Acceptance of security risk; (4) Assigning personnel to a risk assessment review meeting or independent designee to review the security of a secure Project.
Technical Leader (TL)	(1) Leader of Project security activities in Project lines; (2) Responsible for implementing the proactive and reactive security processes; (3) Judge of security risk; and (4) Risk mitigation.
Tester (TST)	(1) Plans, prepares, and executes tests of systems to evaluate results against specifications and requirements as well as analyze/report test results; (2) Collect, verify, validate, and analyze test data; (3) Translate data and test results into evaluative conclusions; (4) Recommend the suitability of the outcome for intended use, and indicate any application constraints as appropriate; (5) Develop a validation report; (6) Conduct test events; (7) Design a data analysis structure (i.e., the types of data a test must generate and how to analyze that data); (8) Systems integration testing; and (9) Perform cybersecurity testing.
Verifier (VER)	(1) Develop a verification plan (which may include quality issues) stating what needs verification and what type of process (e.g., review, check, inspection, analysis, simulation, etc.) and the test is required as evidence;

Roles	Responsibilities
	(2) Management of the verification process (review, integration, and testing) and ensure independence of activities as required; (3) Check the adequacy (completeness, consistency, correctness, relevance, and traceability) of the documented evidence from review, integration, and testing with the specified verification objectives; (4) Develop and maintain records on the verification activities; (5) Develop a verification report stating the outcome of the verification activities and ensure that test activities are planned; (6) Identify anomalies, classify these in risk (impact) terms, record and communicate these to relevant change management body for evaluation and decision; (7) Manage testing for verification activities: • Develop the test specification (objectives and cases); • Execute tests according to the test specification and planning; • Ensure traceability of test objectives against the specified Project security requirements; • Ensure traceability of test cases against the specified test objectives; and • Ensure the planned tests are implemented and specified test cases are carried out. (8) Identify deviations from expected results and record them in test reports.
Validator (VAL)	(1) Establish an understanding of the Project within the intended environment of application; (2) Develop a validation plan and specify the essential tasks and activities for the validation and agree this plan with the CSA or Independent Security Assessor, if present; (3) Review the Project requirements against the intended environment/use; (4) Review the outcome against the Project requirements to ensure all of these are fulfilled; (5) Check the conformity of the process and the outcome against the requirements of this IEC 62443-3-2 standard including the assigned Security Level (SL);

Roles	Responsibilities
	(6) Review the correctness, consistency, and adequacy of the verification and testing; (7) Check the correctness, consistency, and adequacy of test cases and executed tests; (8) Ensure all activities planned in the Project validation plan are carried out; (9) Review and classify deviations in terms of risk (impact), record and submit them to the body responsible for Change Management and decision-making; (10) Give a recommendation on the suitability of the outcome for SuC, and indicate any application constraints as appropriate; (11) Capture deviation from the Project validation plan; (12) Carry out audits, inspections, or reviews on the overall project (as instantiations of the Project development process) as appropriate in various stages of development; (13) Review and analyze the validation reports of other generic applications, if being reused for the System under Consideration (SuC); (14) Check that developed solutions are traceable to the requirements; (15) Ensure that related cyber threats and vulnerability log and remaining non-conformities are reviewed and all cyber threats and vulnerability closed out appropriately through elimination or risks control/transfer measures/countermeasures; (16) Develop a validation report; and (17) Give agreement/disagreement for the release of the outcome.
Cybersecurity Assessor (CSA) or Independent Security Assessor	(1) When tasked with CSA or Independent Security Assessor, ensure to not become involved either directly or as authorized representative in the design, development, realization, implementation, manufacture/Projection, installation/integration/testing, marketing, operation or maintenance of the Project under Cybersecurity Assessment or Independent Security Assessment (This does not exclude the possibility of exchange of technical information); (2) Establish an understanding of the Project within the intended environment of application; (3) Develop an assessment plan and communicate this to the

Roles	Responsibilities
	PJS Leader and/or the Project Asset owner's or the ICP's organization (contracting body of the assessor); (4) Evaluate the conformity of the process and the outcomes against the requirements of this IEC 62443 standard, including the SL assignment, capability verification, and SL-T achievement evaluation; (5) Evaluate the competency of project staff and organization for the development; (6) Evaluate the verification and validation activities and the supporting evidence; (7) Evaluate the QMS adopted for the development; (8) Evaluate the configuration and change management (CCM) system and the evidence of its use and application; (9) Identify and evaluate in terms of risk (impact) any deviations from the requirements in the assessment report; (10) Evaluate the security audits have been carried out and documented in an appropriate way; (11) Carry out inspections on the overall development process as appropriate at various stages of development; (12) Give a professional view on the fitness of the developed outcome for its intended use, detailing any constraints, application conditions, and observations for risk control as appropriate; and (13) Develop and maintain records and reports in accordance with the assessment plan.

6.3 Personnel and Expertise

Personnel, departments, or organizations involved in secure development life-cycle activities shall be competent to carry out the activities for which they are accountable. P/SSO should prepare a training plan and irregularly hold security training to foster the persons within the organization involved in cybersecurity to have the competencies and awareness to fulfil their responsibilities. The training process shall refer to the education process of the QP-02 人事及教育訓練管理程序(Personnel and Training Management Procedure). The following items may be covered:

1 Engineering knowledge, training, and experience appropriate to the process application;
2 Engineering knowledge, training, and experience appropriate to the applicable technology used (e.g., electrical, electronic, or programmable electronic (PE));
3 Security engineering knowledge (e.g., risk analysis);
4 Knowledge of the legal and regulatory security requirements;
5 Security-related methods, tools, and guidelines; and
6 Adequate management and leadership skills appropriate to their role in the security lifecycle activities.

Besides, awareness and training may also be conducted within each department and the following principles need to be considered:

1 Empowering the employees in your organization to recognize common threats can be beneficial to the organization’s cybersecurity health;
2 Mentoring should occur from an experienced security engineer;
3 Sharing security best practices and organizational insights on what works;
4 Encouraging an open exchange of ideas and questions in a non-threatening environment; and
5 Continually emphasizing the critical nature of data and Project cybersecurity and that it’s the employee’s responsibility to be aware and build this into their designs.

The education and training should be designed with learning assessment mechanisms, such as quizzes or discussions, as a basis for evaluating the effectiveness of training. Relevant records such as learning assessment results and sign-in records should be kept for follow-up management.

For secure Project development projects, when the project management plan (including the project security management plan) is written, appropriate personnel shall be designated for different roles to perform security-related tasks.

Before a person is hired for a specific role, a job description should be filled by his/her line supervisor and approved by his/her higher-level supervisor. The training of hired employees should be verified by his/her supervisor and human resource department. The process of human resource can refer to QP-02 人事及教育訓練管理程序(Personnel and Training Management Procedure).

6.4 Configuration and Change Management

Configuration and Change Management (CCM) is a process (shown in Figure 2) to maintain the integrity of the hardware, software, firmware, Third-party Component (TPC), tools usage, documentation, workforce, or personnel assigned to the role-based security assurance

organization of the secure product development project, etc. which are related to the configuration and change management process. CCM is a continuous process of controlling and approving changes to security controls of the SuC. This process includes the creation or development of new secure products or changes occurred in an existing secure product while necessary. The CCM process shall be referred to the existing QP-01 文件管理程序、ISMS-P-20 組態管理程序書. Furthermore, if possible or appropriate, it is highly recommended that qualified Commercial Off-The-Shelf (COTS) CCM tools should be used to assist in achieving successful CCM results.

For the implementation of the CCM process on a SI/SM Project Security Management Plan, the procedures, the QP-14 設計管制程序 shall be applied to establish its relevant Configuration Control Stages which is defined in Section 6.5 and to perform its formal reviews or (so-called gate reviews) before the end of each configuration control stage, respectively.

Regarding any Configuration Change and/or design change that occurs on the SuC during its development or operation and maintenance period, the procedure, the QP-03 客戶需求管理程序 and ISMS-P-20 組態管理程序書, shall be adopted and followed. It should keep documentation up-to-date and to keep the asset owner informed about the latest document and publish the up-to-date documents to related stakeholder.

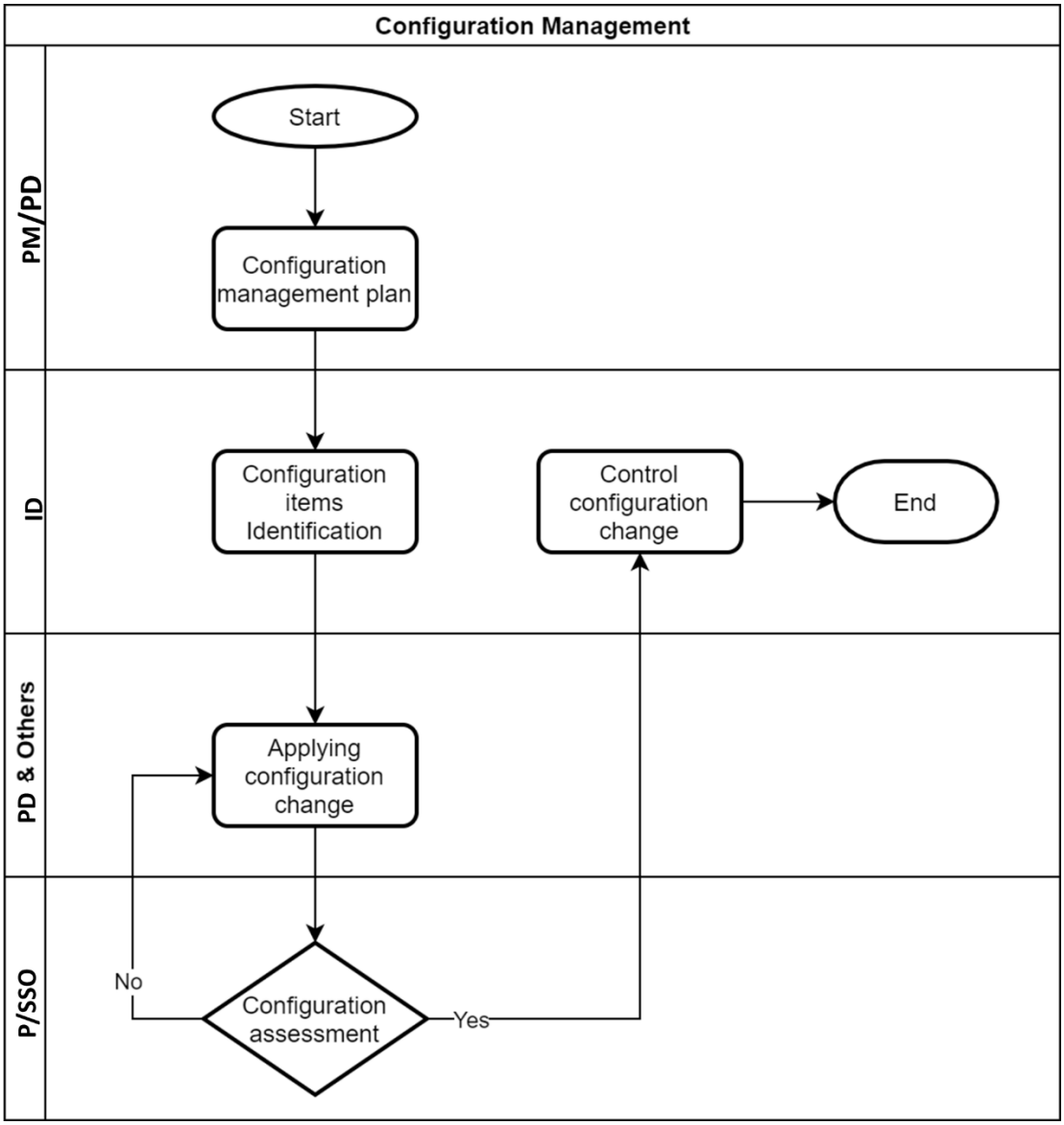

Figure 2 Process of Configuration Management.

1. Configuration Management Plan

   A configuration management plan shall be built for a secure product. The context in a configuration management plan should include, but not limited to, the following:

   (1) Automatic tools for the configuration management and how to use the tools;
   (2) Formal control stages and/or stages of a SI/SM Project Security Management Plan;
   (3) Acceptance plan;
   (4) Configuration items;
   (5) Descriptions of each configuration item; and
   (6) Configuration items identification and methodology used.

2. Configuration Items Identification

   (1) The configuration items identification management should be created to identify each configuration item of a secure product.
   (2) The configuration items of a secure product listed below should be controlled as a

minimum:

- Organization and personnel are dedicated to;
- The activities and tasks are planned;
- The documents and records for each stage and review of a SI/SM Project Security Management Plan;
- System, hardware, and software (including firmware and/or TPC if applicable) of a secure product. Hardware should be broken down into components and/or parts. Software and/or firmware including TPCs should be broken down to each functional library;
- The tools used in a SI/SM Project Security Management Plan;
- The security guidelines of a secure product; and
- The security defects and/or issues records of a secure product.

3. Applying Configuration Change

Any modification to a secure product shall be initiated only by the issue of an authorized request. The request should describe the following in detail:

(1) the affected risks; and
(2) the change proposed – the reasons for a change.
(3) The reason for a request for modifications could arise from, for example:
(4) Security capability lower than originally specified security target or level;
(5) Security defects and/or issues arising from using experiences;
(6) New or amended security legislations or standards applied;
(7) Modifications to the System under Consideration (SuC) or its use;
(8) Modification to any security requirement of a secure product;
(9) Analysis of operations and maintenance performance indicating that the performance is below the target specified; and
(10) Periodical security reviews and/or audits.

4. Configuration Assessment

(1) An impact analysis shall be carried out that should include an assessment of the impact of the proposed modification.
(2) The assessment should include a risk analysis enough to determine the breadth and depth to which subsequent overall security lifecycle stages will need to be undertaken. The assessment shall consider the impact of other concurrent modifications and shall also consider the security both during and after the modification has taken place.
(3) The impact analysis results described above should be documented.
(4) Authorization to carry out the required modification should be dependent on the results of the impact analysis.
(5) All modifications that have an impact on the security shall initiate a return to an appropriate stage of the overall SI/SM Project Security Management Plan. All subsequent stages should then be carried out in accordance with the procedures specified for the specific stages in accordance with the requirements in this guideline.

5. Control Configuration Change

Chronological documentation shall be established and maintained that shall document details of all modifications, and include the following information:

(1) The modification;
(2) The impacts analysis; and
(3) Reverification and revalidation of data and results – all documents affected by the modification.

Audit trails for change shall be documented including, but not limited to, the originator, date, and time.

6.5 Development of Project and System Security

Figure 3 demonstrates the ICP's Overall Secure Project/System development lifecycle and Configuration Control Stages. It shall be applied to any IACS secure Project/System and its development project and/or change project, if applicable. The complete secure Product/System SDL should be divided into the following phases and/or stages:

1 Concept/ Specification (R0/R1) – Market Feasibility Evaluation to ensure project/system is worthy to implement;
   (1) Tendering/Acquisition (R0 Stage, C0: R0 Review);
   (2) Project Initiation (R1 Stage, C1: R1 Review);
2 Development/Design and Development (R2 Stage, C2: R2 Review);
3 Production/Implementation and Verification and Validation (R3 Stage, C3: R3 Review);
4 Operation and Support/Maintenance – if applicable (R4 Stage, C4: R4 Review);
5 Decommissioning/Disposal – if applicable (R5 Stage, C5: R5 Review);

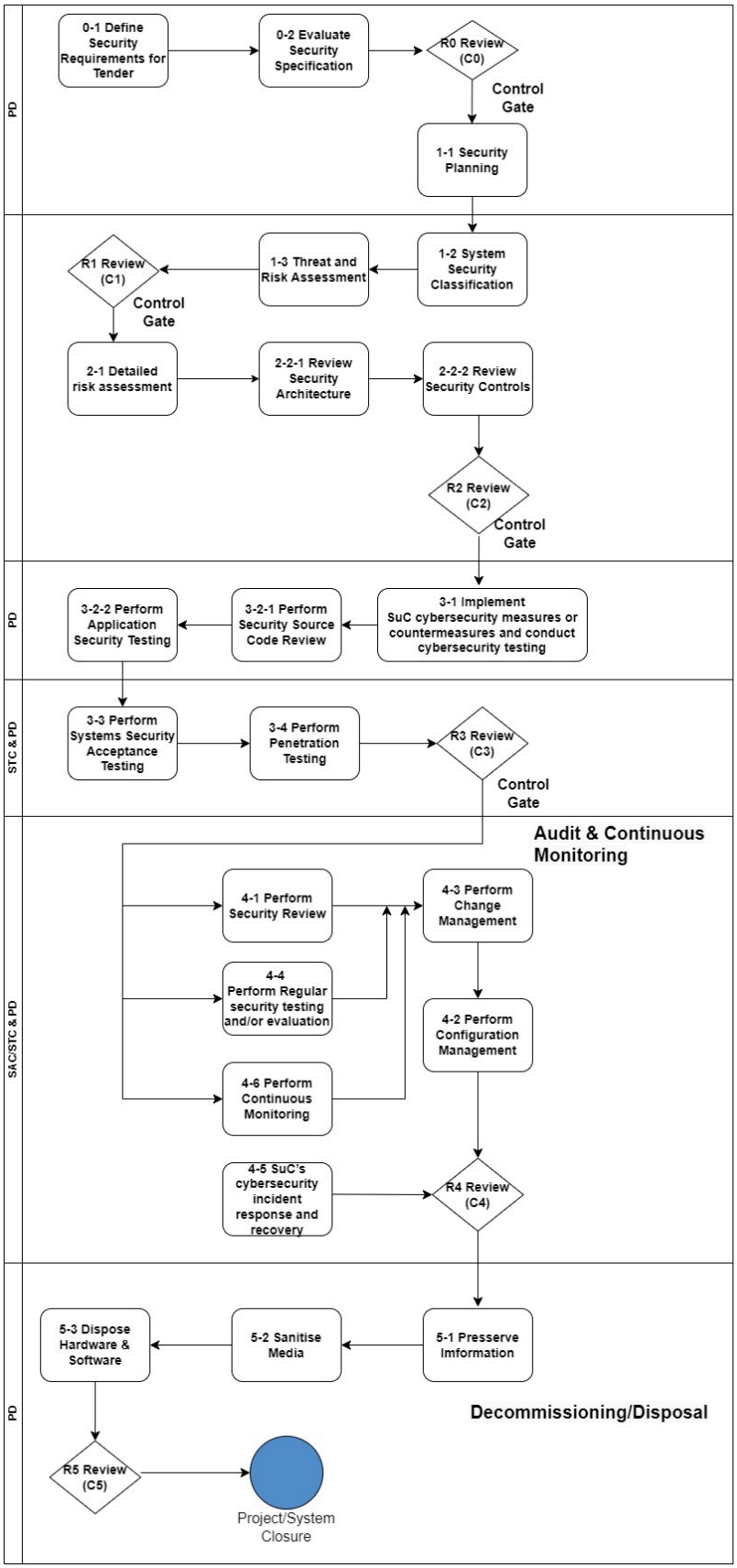

Figure 3 The Overall Secure Project/System development lifecycle and Configuration Control Stages.

6.5.1 Project/System Development Process

The Secure Project/System development lifecycle should be planned according to the overall Secure Project/System development process (see Figure 3) and the Secure Project/System Development Lifecycle Phase Management (see Table 3) and performed the relevant security assurance tasks and/or activities.

For all phases of the software-level security lifecycle, Table 3 indicates:

- The activities/objectives to be achieved;
- The references to the subclause containing the requirements;
- The required inputs to the phase; and
- The outputs required to comply with the requirements.

For a component that is applicable to the IEC 62443-4-2 standard, in most cases, the software-level security assurance management can be combined with and integrated into the hardware-level and system-level security assurance management. In this situation, the software-level security assurance tasks and/or activities and their work outputs and deliverables shall be carefully planned to a level sufficient to ensure Product security and integrated into a secure product SDL management plan.

In order to effectively and consistently implement the technology or procedures of various security requirements, Chap 7 describes the implementation of OT Security Practices.

The development and implement process of the Project/System should include, but not limited to, the following:

1. PM to create the SI/SM Project Security Management Plan (Refer to 7.1.1.3):
   - Plan the tasks of the Secure Project/System Development Lifecycle Phase (Refer to 8.2 table list of Task Name, Task ID, Output Delivery, and Output ID) (Expect output in section 5.5 in ID03 SI-SM Project Security Management Planning Guideline, including schedule planning)
   - Assign Roles and Responsibility for each security activity and/or task, and output delivery (Expect output in section 5.3.2 Table 1. And Table 2. in ID03 SI-SM Project Security Management Planning Guideline)
2. Develop and implement the Project/System
   - For each Task and/or Output Delivery, the responsible personnel (assign in section 5.3.2 Table 1. and Table 2. in the SI/SM Project Security Management Plan) should perform related procedures (Refer to 8.2 table list of Guideline Section)
   - For each activity of Task and/or Output Delivery, the start time of the task should follow the schedule plan in section 5.5.3 and the inputs were ready (Refer to 6.5.1 Table 3. list of Inputs), then develop the Outputs (Refer to 6.5.1 Table 3. list of Outputs)

Note:

1. The mapping for IEC 62443-2-4 Security Program requirements, 8.3 show the

information of the tasks, delivery outputs, and implement procedures in accordance with IEC 62443-2-4 SP requirements. For each Security Program requirement, it shows the Task_ID, Output_ID, and related procedures of Guideline Section with respect to the SP.

2. For assignment of responsible personnel for the Security Program (SP), the tasks related to SP were show in 8.3 for each SP, and the responsible personnel assignment was planned and specified in the SI/SM Project Security Management Plan (assign in ID_03 section 5.3.2 Table 1. and Table 2.)
3. Annexes B.4 gives the corresponding work instructions for each process of Security program requirements. The table gives the general process description, include “input”, “Measures”, “Verification steps”, and “outputs” for each Security Practice. This information is summary from tasks of each SP (In Note 1 it is mentioned). It may consist of multiple tasks for each SP, the responsible personnel and trigger/start time could refer to 2. Develop and implement the Project/System that is described above.

Table 3. Secure Project/System Development Lifecycle Phase Management

Figure 3 box number	**Title**	**Activities/ Objective**	**Require. subclause**	Inputs	Outputs
0-1	Tender Security Requirements	Define Security Requirements for Tender	6.5.1.1.1	Request from PE/O	Security Requirements for Tender
0-2	Tender Security Evaluation	Evaluating and assessing the adequacy of proposed security controls of submitted proposals in meeting requirements in the tender.	6.5.1.1.2	Security Requirements for Tender	• Security compliance report • Security Requirements deviation
1-1	Security Planning	Security planning to set a common understanding of security goals and objectives, identify key security roles, and develop high-	6.5.1.2.1	Security Requirements for Tender	• Security Management Plan - Key Security Roles - Common Security Expectations - High Level Security Schedule

Figure 3 box number	**Title**	**Activities/ Objective**	**Require. subclause**	Inputs	Outputs
		level security schedule.			• SI/SM Project Security Management Plan, including Configuration Management • Security Subcontractors/Suppliers Management Plan • Security Policies and Procedures Management Plan
1-2	Systems Security Classification	Classify the system to the appropriate security classification.	6.5.1.2.2	• Security Requirements for Tender • Common Security Expectations • High Level Security Schedule	• Security Classification • High-level Security Requirements
1-3	Threat & Risk Assessment (Preliminary)	Threat and Risk Assessment to ensure threats, risk, and security decisions are documented, assessed, and approved by key stakeholders.	6.5.1.2.3	• Security Requirements for Tender • Security Classification • High-level Security Requirements • SuC related documents	• TRA report detailing the potential threats and risks that could impact the organization business and the security controls needed to be put in place to reduce the risks to an acceptable level; • Preliminary Inventory Asset List

Figure 3 box number	**Title**	**Activities/ Objective**	**Require. subclause**	Inputs	Outputs
					• Simple Network Diagram • Updated Project Risk Register addressing cyber risks.
2-1	Detailed risk assessment	For each zone, design and document the technical and organizational cybersecurity policies, measures, or countermeasures	6.5.1.3.1	• High-level Security Requirements • SuC related documents • TRA Report • Risk Register	• Inventory Asset List • Security Architecture: Network and Data Flow Diagram (DFD) • OT Security Detailed Risk Assessment Report and/or Updated TRA • OT Security Risk Mitigation Plan and Requirement Specifications, include cybersecurity architecture and security controls (Functional Requirements, Security Countermeasures, Cybersecurity Policy, and Procedure requirements)
2-2-1	Review Security Architecture	Security review of system architecture.	6.5.1.3.2-1.	• Inventory Asset List • Security Architecture	• Approved Security Architecture: Network and Data Flow Diagram

Figure 3 box number	**Title**	**Activities/ Objective**	**Require. subclause**	Inputs	Outputs
				: Network and Data Flow Diagram (DFD) • Security Architecture • Updated TRA	and/or OT Security Risk Mitigation Plan and Requirement Specifications. • Updated TRA
2-2-2	2-2-2. Review Security Controls	The review of security controls put in place as part of the system's design.	6.5.1.3.2-2.	• Security Controls - Functional Requirements - Security Countermeasures - Cybersecurity Policy and Procedure requirements • Updated TRA	• Approved security controls of OT Security Risk Mitigation Plan and Requirement Specifications. • Updated TRA
3-1	Implementation of system security countermeasures	To ensure that Project features and security measures are implemented securely.	6.5.1.4.1	• Approved Security Architecture • Approved Security Controls • Updated TRA	• IACS Automation Solutions/Asset Hardening (Hardening) Recommended Practices • OT Security Policies and Procedures and/or Security Functional Description

Figure 3 box number	**Title**	**Activities/ Objective**	**Require. subclause**	Inputs	Outputs
					Specification: - Account Management, - Vulnerability Management, - Backup and Restore Procedure, - Change and Patch Management Procedure, - Logging, Monitoring, and Reporting Procedure, - System Malware Protection Procedure • OT Security Inspection and Test Protocol; • Security Solution Integration Plan for OT Security Policy and Procedure Design Practices • Incident response and recovery plan
3-2-1	Perform Source Code Review	To find security issues due to insecure coding practices or malicious intent or coding errors.	6.5.1.4.2-1.	• Approved Security Controls • Updated TRA	• Source code review report on weaknesses/vulnerabilities and recommendations; • Mitigation action plan; • Follow-up review report.
3-2-	Perform Application	To ensure that the	• 6.5.1.4	• Approved	• Approved

Figure 3 box number	**Title**	**Activities/ Objective**	**Require. subclause**	Inputs	Outputs
2	Security Testing	individual parts of modules are correct and fit for use.	.2-2.	Security Architecture • Approved Security Controls • IACS Automation Solutions/Asset Hardening (Hardening) Recommended Practices • OT Security Policies and Procedures • - OT Security Inspection and Test Protocol; • Security Solution Integration Plan for OT Security Policy and Procedure Design Practices	Application Testing Result • Mitigation action plan • Follow-up regression test report.
3-3	System Security Acceptance Testing	To verify that the complete system satisfies the specified requirements and is	6.5.1.4.3	• Security Requirements for Tender • Approved Security	• Approved Hardening Report • Approved Security Policies and Procedures and/or

Figure 3 box number	**Title**	**Activities/ Objective**	**Require. subclause**	Inputs	Outputs
		acceptable to end users. Systems Security Acceptance Testing focus on satisfying security requirements.		Architecture • Approved Security Controls • IACS Automation Solutions/Asset Hardening (Hardening) Recommended Practices • OT Security Policies and Procedures • - OT Security Inspection and Test Protocol; • Security Solution Integration Plan for OT Security Policy and Procedure Design Practices	Security Functional Description Specification • Approved Security Inspection and Test Protocol and report; • Approved Security Solution Integration Plan for Security Policy and Procedure Design Practices • Approved Incident response and recovery plan • Approved Testing Result - Application and vulnerability assessment test report - Security FAT test report; - Security SAT test report; • Action arising from the test
3-4	Penetration Testing	To find weaknesses/ vulnerabilities that an attacker could exploit under secure SuC environment.	6.5.1.4.4	• Approved Security Controls • Approved Security Architecture	• Penetration Testing results and recommendations • Mitigation action plan • Regression testing

Figure 3 box number	**Title**	**Activities/ Objective**	**Require. subclause**	Inputs	Outputs
					report (can be incorporated into SAT/ SIT test report) to validate the effectiveness of the mitigation actions.
4-1	Perform security review	To determine if the security controls in place continue to be effective over time, in light of system and environmental changes.	6.5.2.1	• IACS Automation Solutions/Asset Hardening (Hardening) Recommended Practices • Inventory Asset List • Security Policies and Procedures and/or Security Functional Description Specification • cybersecurity architecture • security controls	• Documented results of the security review • Security decisions arising from the security review findings. • Mitigation plan
4-2	Perform type/setting/configuration management.	Perform the type/setting/configuration change, if required, and to control and maintain	6.5.2.2	• Inventory Asset List • Security Policies and Procedures	• Change Control decisions • Updated security documentation • Updated Inventory

Figure 3 box number	**Title**	**Activities/ Objective**	**Require. subclause**	Inputs	Outputs
		an accurate inventory of any changes to the system		and/or Security Functional Description Specification	Asset List and/or TRA report.
4-3	Perform Management of Change (MOC)	Perform the type/setting/configuration change, if required.	6.5.2.3	• Inventory Asset List • Security Policies and Procedures and/or Security Functional Description Specification	• Change Control decisions • Updated security documentation • Updated Inventory Asset List and/or TRA report.
4-4	Regular security testing and/or evaluation	Scanning, conducting logs and continuously updating the security design for systems.	6.5.2.4	• IACS Automation Solutions/Asset Hardening (Hardening) Recommended Practices • Inventory Asset List • Security Policies and Procedures and/or Security Functional Description	• Security testing and/or evaluation reports.

Figure 3 box number	**Title**	**Activities/ Objective**	**Require. subclause**	Inputs	Outputs
				Specification • cybersecurity architecture • security controls	
4-5	SuC's cybersecurity incident response and recovery	To verify, exercise, and shorten the impact time of security incidents.	6.5.2.5	Security Policies and Procedures and/or Security Functional Description Specification	• Cybersecurity incident response and recovery analysis and report: – Documentation of cybersecurity incident response and recovery or recovery drill results; – Improvement decisions resulting from review results of cybersecurity incident response and recovery or recovery drills;
4-6	Perform continuous monitoring	To determine if the security controls in place continue to be effective over time, in light of system and environmental changes.	6.5.2.6	Security Policies and Procedures and/or Security Functional Description Specification	• Documented results of continuous monitoring such as weaknesses/vulnerability assessment reports • Security review / self-assessments reports • Security decisions arising from continuous

Figure 3 box number	**Title**	**Activities/ Objective**	**Require. subclause**	Inputs	Outputs
					monitoring
5-1	Preserve Information	To mark the archived information and handle in compliance with its security classification.	6.5.3.1	• Inventory Asset List • cybersecurity architecture • OT Security Risk Mitigation Plan and Requirement Specifications	• Decommissioning/Disposal Plan • Index of preserved information and its location.
5-2	Sanitize Media	To sanitize the system's digital media using approved equipment, techniques, and procedures according to relevant policies and regulations.	6.5.3.2	• Inventory Asset List • OT Security Risk Mitigation Plan and Requirement Specifications	• Media sanitized according to policy and regulatory requirements. • Media sanitization records.
5-3	Dispose Hardware & Software	Depending on relevant policies and regulation to dispose the Hardware and Software	6.5.3.3	• Inventory Asset List • OT Security Risk Mitigation Plan and	• Disposition records for hardware and software, including redeployment. Records should be retained according to relevant polices and

Figure 3 box number	**Title**	**Activities/ Objective**	**Require. subclause**	Inputs	Outputs
				Requirement Specifications	regulations. • Updated inventory of assets to reflect disposed hardware and software.

6.5.1.1 Tendering/Acquisition

The Acquisition phase of the development lifecycle is concerned primarily with the identification of security requirements, evaluation of proposed security controls, and reviewing and finalizing security design before acquiring or developing the system.

6.5.1.1.1 Tender Security Requirements

Security Requirements are defined and refined as part of the overall tender requirements submission. Security requirements should be clearly articulated, and its purpose and objective clearly stated, so that tenderers can provide adequate measures or controls to meet the requirements.
Security requirements should also include organization security standards or references from International Standards (e.g. ISO2700X standards), which are minimum security controls that must be put in place to protect systems in the area of Confidentiality, Integrity, and Availability.

6.5.1.1.2 Tender Security Evaluation

This activity focuses on the assessing of security control specifications proposed by the vendors.
The activity includes a series of documentation reviews, proposal evaluation, and clarifications, assessment of the security controls proposed. It may include software/hardware demonstrations and testing which the controls involve software and/or hardware solutions.
Recommendations are incorporated into the Tender Evaluation Report.

6.5.1.1.3 Control gate review (R0:C0)

The objective of this control gate is to match the security requirements expressed against the security functionality defined by the vendors. All security controls should be included in the vendor proposal. The approving authority of the control gate is the Project/System Security Office (P/SSO).
Recommended control validations for this phase include:

1. All the agreed-upon security controls have been included in the vendor proposal.
2. Vendor's planned activities and outcomes are compliant with organization security policy and procedures.
3. Formal key stakeholder acceptance of the risks based on the vendor proposal.

6.5.1.2 Project initiation

At the Initiation phase, early integration of security considerations is key to the success of implementing a secured system. Threats, security requirements, and potential constraints of functionality and integration are considered at this phase. Security is looked at from the perspective of business risks with inputs from the security team.

6.5.1.2.1 Security Planning

Security planning is to be conducted as part of the initiation phase, , for detailed practice, please refer to 7.1. It includes:

1. Identification and confirmation of key security roles in the Project: Proof of cyber security awareness of the project organization/personnel and personnel's ability to perform duties, including proof of ability of project organization personnel and cyber security awareness training planning and training records; (for detailed practice, please refer to 6.2)
2. Configuration management of the project: including the organizational structure of the project, assignment, and appointment of roles/positions/personnel, file configuration list, system hardware/software/firmware configuration list, system hardware/software/Firmware setting and parameter setting configuration list, change management, and the use of auxiliary tools or software systems such as project plan management, analysis, compilation, simulation, verification and verification, inspection and testing; (for detailed practices, refer to 7.1) And the Overview critical security milestones and activities for system development;
3. Identify the use of secure design, architecture, and coding standards.
4. Security management plans of subcontractors/suppliers and consultants; ensure that all key stakeholders understand the objectives, implications, considerations, and requirements for implementing security Have a common understanding;
5. Plan the security policies and procedures, including Account Management Plan, Vulnerability Management Procedure, Backup and Restore Procedure, System Malware Protection Procedure, Change and Patch

Management Procedure, Logging, Monitoring, and Reporting Procedure.

This planning activity is crucial as it highlights to key stakeholders that as the systems development progresses, decisions made will have security implications.

6.5.1.2.2 Systems Security Classification

To perform threat and risk assessment, it is important to first determine the security classification of the system.

The security classification will be used in conjunction with the threats and vulnerability information in assessing the risks.

Security classification mainly clarifies the ESG (Environment, Social, Governance) and HSE (health, safety, and environmental) requirements and impacts of the system. Industry standard requirements should be given priority, followed by customer requirements, and finally the information provided by the company.

6.5.1.2.3 Threat & Risk Assessment (Preliminary)

Threat and Risk Assessment (TRA) is the systematic process of identifying the various threats and weaknesses/vulnerabilities to systems, determining the level of risk these systems are exposed to, and recommending the appropriate level of protection. (For detailed practices, refer to 7.2)

The objective of TRA is to maximize the protection safety, integrity, availability, and confidentiality while minimizing risk.

A typical TRA includes:

1. Review of functional requirements specification.
2. Threats and vulnerabilities identification.
3. Initial establishment of SuC's Preliminary Inventory Asset List and Simple Network Diagram.
4. Risk identification, analysis, and evaluation.
5. Recommendations for appropriate security controls.

TRA must take into consideration all relevant regulatory practices and standards.

6.5.1.2.4 Control gate review (R1:C1)

The approving body for this stage is the Project/System Security Office (P/SSO) and /or the Project Employer or Asset Owner (PE/O).

The control verifications and validations for this phase include:

1. Project security management plan, Security Subcontractors/Suppliers Management Plan, SI/SM Project Security Management Plan, Security Policy, and Procedures Plan that is submitted, reviewed, and approved by the P/SSO and /or the PE/O.
2. Check and approve the use of security analysis tools in the SuC in the Security Policy and Procedures Plan.

3. Check and approve the Preliminary Inventory Asset List and Simple Network Diagram documents.
4. Threat and Risk Assessment Report that is submitted, reviewed, and approved by P/SSO and /or the PE/O. This is the main deliverable for this phase. It will be used extensively to develop the security requirements, controls, and design of the system.
5. Check and verify that security architecture reviews and/or security assessment and/or threat analysis of the control system used in the SuC has been conducted by an independent party.
6. Check the vulnerability management process of 1) the management of vulnerabilities newly discovered in the SuC or in its related policies and procedures for which the Project is responsible, and 2) the management of publicly disclosed vulnerabilities affecting the SuC. Check the description of the document to mitigate security weaknesses.
7. Checking if all high-level security requirements have been included or expressed as a set of security controls in the Threat and Risk Assessment Report.
8. Checking if the security team roles and responsibilities have been established.
9. Evaluate if the project is supported with the security resources currently available or projected to be available in the timeframe desired.
10. Check if all involve personnel (including subcontractor or consultant) to the Automation Solution have been informed by training and comply with project requirements. Annexes Table C.1 item VCSP.24 could be used to verify the personnel (including subcontractor or consultant) have been informed of and comply with the project requirements.

6.5.1.3 Development/Design and Development

The Development/Design and Development phase begins after the Security Planning and Risk Assessment is approved. As part of the design of the system, a detailed risk assessment should be conducted to define the cybersecurity architecture and security controls, and a critical security design review shall be conducted to check that the system architecture is secured, and appropriate security controls are put in place in the design of the system.

6.5.1.3.1 Detailed risk assessment

After the zones and conduits are identified in the initial risk assessment, a detailed risk assessment should be conducted for each zone and conduit (refer to 7.3 for detailed practices), including:

1. Identify threats and document them;

2. Identify and document vulnerabilities;
3. For each threat, select a risk acceptance principle to establish cybersecurity requirements:
   - Apply Codes of Practice
   - Countermeasures for citing and reference system similarity
   - Conduct detailed risk assessment

A set of threats can be addressed using the same principles.

4. Confirm the Target Security Level (SL-T) of the zone or conduit;
5. Output cybersecurity requirements specifications;

6.5.1.3.2 Critical Security Design Review

The Critical Security Design Review focuses on the review of security systems architecture and controls. This process ensures that security requirements and controls are met through the system's design and can be implemented to meet security requirements.

1. Review Security Architecture

   This activity focuses on the security review of system architecture. The systems architecture should be decomposed into finer components and its inner workings must be documented. This is to identify trust boundaries, information entry and exit points, and data flows.

   It includes architecture document reviews, design weakness/vulnerability assessments, and security recommendations.
2. Review Security Controls

   This activity focuses on the review of security controls put in place as part of the system's design. The activity includes a series of documentation reviews of security controls proposed in the system design, an assessment of its effectiveness, and recommendations.

Security Controls must be justified and documented based on the TRA and security requirements. Security Controls must be sufficiently documented to enable verification of the controls' adherence to security requirements. An analysis of the cost of implementing a potential security control should also be documented.

6.5.1.3.3 Control gate review (R2:C2)

Before the development of the system, the proposed security design and controls must be validated and accepted by key stakeholders. Updates and changes to the initial risk assessment must be updated to reflect changes to security requirements and design.

The control validations for this phase should include:

1 The system design is consistent with the enterprise architecture, including the security components of that architecture;

2 The system design addresses the agreed security requirements;

3 (Details) The TRA Report reflects the updated risks after consideration of the security architecture, and security controls that have been put in place;

4 The key stakeholders formally accepted the proposed system design taking into consideration the updated Threat and Risk Assessment Report.

An updated TRA, including updated risk, assessments, and recommendations should be approved by the P/SSO and/or the PE/O before the system can proceed with implementation.

6.5.1.4 Production/Implementation and Verification and Validation

The implementation verification and validation evaluation stages begin after the architecture design of the system has been approved. As the system is being implemented, security source code reviews and application testing should be conducted to ensure that security has been properly built from the bottom up. A final round of security source code review and application testing shall be part of acceptance testing, the system should be tested against a set of security test cases.

Before the deployment of the system, penetration testing shall be performed on the system to check for and address any vulnerabilities that were not identified or addressed adequately during the previous stages.

6.5.1.4.1 Implementation of system security countermeasures

Selecting and maintaining the organization's security countermeasures includes required security countermeasures and mitigating selected security countermeasures. (refer to 7.4 for detailed practices) Specific required countermeasures are considered the basis for formulating security policies and architecture, so these countermeasures should be considered in advance, including the following:

1. Implement and document the assurance security (for detailed practice, refer to 7.4.1.1);
2. Implement and document the network segmentation (architecture) (for detailed practice, refer to 7.4.1.2);
3. Implement and document the account management security (for detailed practice, refer to 7.4.1.3);
4. Implement and document the configuration management (CM) (for detailed practice, refer to 7.4.1.4);
5. Implement and document the SuC's Asset Hardening (for detailed practice, refer to 7.4.1.5);

The cybersecurity requirements specifications and mitigation countermeasures selected through detailed risk assessment should be implemented at this stage, which may include but are not limited to the following items:

1. Implement and document the wireless security, if required by security

control (for detailed practice, refer to 7.4.1.6);

2. Implement and document the Safety Instrumented System (SIS) security, if required by security control (for detailed practice, refer to 7.4.1.7);
3. Implement and document the remote access security, if required by security control (for detailed practice, refer to 7.4.1.8);
4. Implement and document the event management security, if required by security control (for detailed practice, refer to 7.4.1.9);
5. Implement and document the malware protection security, if required by security control (for detailed practice, refer to 7.4.1.10);
6. Implement and document the Patch management security, if required by security control (for detailed practice, refer to 7.4.1.11);
7. Implement and document the Backup/Restore security, if required by security control (for detailed practice, refer to 7.4.1.12);

In addition, the implementation discussion of countermeasures and issues related to the implementation of CSMS should also include:

1. Risk management and implementation: The selection, development, and implementation of security measures commensurate with the risk, which may take into account the design of inherently secure industrial operations, the use of Projects with strong inherent security capabilities, manual and procedural security countermeasures, and Technology-based (security solutions) countermeasures to prevent or reduce security incidents.
2. System development and maintenance: covering requirements documentation, design, procurement, testing, change management, patch management, and backup and recovery processes.
3. Information and Document Management: The process of providing classification, data protection, document management, and appropriate provision of information related to the SuC and security plans. Records management for the SuC may be included within the organization's general record retention and records management systems. Information and records management ensures that materials are available for the required length of time based on internal (e.g., organizational policies and equipment maintenance) or external (e.g., legal, regulatory, and political) requirements.
4. Incident planning and response: Incident planning and response addresses detecting cyber security incidents and remaining vigilant in identifying and responding to these incidents on time.
5. Implement and document the OT Security Inspection and Test Protocol: Annexes A.11 can be used to document the OT Security Inspection and Test Protocol. The ITP should include the test items related to application security testing items, detail information described in section 7.5.

6. Implement and document the Security Solution Integration Plan for OT Security Policy and Procedure Design Practices. The test cases and procedures should include all the items that are listed in 7.5.

6.5.1.4.2 Application Security Testing

The process of Application Security Testing is to ensure that, through a bottom-up approach, weaknesses/vulnerabilities are surfaced and addressed. The bottom-up approach allows problems to be detected early during the development of the system components, which would be costlier to fix during systems integration testing.

1. Perform Source Code Review

   A source code review is a systematic examination of the source code of an application with the intent of finding security issues due to insecure coding practices malicious intent or coding errors.

   This review should be related to the inspection and test project requirements of the OT Security Inspection and Test Protocol, and the Security Solution Integration Plan for OT Security Policy and Procedure Design Practices.

   A secure code review should examine the codes for the following:

   - Common application vulnerabilities (e.g. input validation, authentication, and access control)
   - Weak implementation of security functions (e.g. encryption, access control)
   - Backdoors, logic bombs, and malware
   - Undocumented/unnecessary functions
   - Known language-specific weaknesses/vulnerabilities.
   - Application logic weaknesses/vulnerabilities.

   For outsourced or turnkey projects, secure coding standards should be incorporated into the requirement specifications for vendors' compliance. Adherence to secure coding standards should also be one of the user acceptance criteria. Organizations should take utmost diligence to obtain the rights to review vendor's application source code for projects for which they do not own the source codes.

   After every source code review, a mitigation plan must be put in place to address all vulnerabilities found. Follow-up review must be conducted to validate the effectiveness of the mitigation actions and needs to be approved or risk accepted before performing application testing.

2. Perform Application Security Testing

   Application testing must be performed on systems to determine if modules are fit for use. The goal of unit testing is to isolate each part of the system and show that the individual parts are correct.

   This test activity project should be related to the test project requirements of OT Security Inspection and Test Protocol, and Security Solution Integration

Plan for OT Security Policy and Procedure Design Practices. (refer to 7.5 for detailed practices)

Proper application testing ensures:

- Problems can be detected early in the development lifecycle especially prior to an acceptance test.
- Simplifies integration by testing the parts of a system first and then testing the sum of its parts.

After every test, a mitigation plan must be put in place to address all vulnerabilities found. Follow-up regression test must be conducted to validate the effectiveness of the mitigation actions and needs to be approved or risk accepted prior to performing systems acceptance testing.

6.5.1.4.3System Security Acceptance Testing

This activity focuses on the acceptance testing of the security requirements and controls that have been approved as part of the systems design and are acceptable to be deployed.

Activities include:

1. Checking of system configuration against security specifications and baseline standards (if any)
2. Test Case Review (focusing on testing the security controls)
3. Validation of the Acceptance Test
4. Assessment and Recommendations.

The system is to be tested at various stages in its development and implementation.

Each system shall be subjected to three tests to demonstrate proper operation in accordance with project-specific requirements: factory acceptance test (FAT), site acceptance test (SAT) and site integration test (SIT). Loop tests shall be performed in accordance with IEC 62382, which typically occur after SIT. All these tests shall be completed, with any open items documented and agreed upon by all parties involved in the tests, prior to the system being placed in operation. An optional fourth test, factory integration test (FIT) can also be performed on all or part of the system while at the vendor's factory.

The typical order of execution of these tests is:

- The factory acceptance test (FAT) is performed on the SuC system, subsystem or component before it leaves the vendor's factory to demonstrate that it functions in accordance with the project-specific requirements.
- The factory integration test (FIT) is a fourth, optional testing point to demonstrate that the merging of some or all the various subsystems and components function as specified. This test is performed after or in conjunction with the FAT, before the SuC system, subsystem or component leaves the vendor's factory.

- The site acceptance test (SAT) is performed after installation on site to demonstrate the SuC system, subsystem, or component is in accordance with the applicable standards, codes, specifications, and installation instructions. This test is performed after each subsystem is installed.
- The site integration test (SIT) is performed after the SAT to demonstrate that the merging of the various subsystems and components into one overall SuC system is complete and that all subsystems and components work together as specified in the test plan. This test can be performed on two or more subsystems or components after each has been installed and successfully completed a SAT or after all subsystems and components have been installed and successfully completed a SAT.

For detail practices could refer to IEC 62381 : Automation systems in the process industry – Factory acceptance test (FAT), site acceptance test (SAT), and site integration test (SIT). The generic acceptance test procedure could refer to 7.9.

The minimum security acceptance testing should refer to 7.6 Practices for System security acceptance testing process. It should be conducted in accordance with the requirements of OT Security Inspection and Test Protocol and should be divided into three stages for testing, including:

1. OT Security FAT Test
2. Perform Security Inspection and Test Protocol (Inspection and check the Hardening, Security Policy and Procedure implementation, Security Solution Integration.) (refer to 7.6.1 2. for detailed practices)
3. OT Security SAT Test
4. Cooperate with the owner’s request to support the OT Security SIT Test

Systems Security Acceptance Testing should be performed by independent third-party assessors and thoroughly performed in a test environment that is identical to the production environment.

All test results must be accepted or mitigated by the Project/System Security Office (P/SSO) to the completion of the Systems Security Acceptance Testing.

6.5.1.4.4Penetration Testing

Penetration Testing, also called pen testing, is the practice of testing a computer system, network, or Web application under a secure SuC environment to find weaknesses/vulnerabilities that an attacker could exploit. These weaknesses/vulnerabilities may exist in operating systems, service and application flaws, improper configurations, or risky end-user behaviour.

Pen tests can either be performed manually or with the assistance of automated software tools. The pen test also includes gathering information about the target to identify entry points for penetration.

The pen test should include follow-up regression testing to validate that the mitigating actions are implemented effectively. All test results must be accepted or mitigated by the Project/System Security Office (P/SSO) before the

completion of this activity.

The main objective of performing penetration testing is to determine security weaknesses from an organization's policy posture to its systems, the employee's security awareness, and the organization's ability to identify and respond to security incidents.

Penetration testing should be performed by independent third-party assessors and should be conducted in SAT Test and SIT The Test stage is carried out.

6.5.1.4.5 Control gate review (R3:C3)

In the implementation phase, the system is built and tested. The key stakeholders rely on the outcome of security tests to assess whether the security controls put in place are effective. The approving authority for this control gate is the P/SSO and/or the PE/O.

Recommended control validations for this phase include:

1 Security controls defined by the agreed-upon requirements are implemented in the system correctly.

2 Mitigation actions arising from source code review reports, security test reports, and penetration test reports are addressed, risk accepted, and formally approved by the P/SSO and/or the PE/O.

3 Security Policies and Procedures and/or Security Functional Description Specification and Security Inspection and Test report approved by the P/SSO and/or the PE/O.

4 Users are adequately trained in the security components of the systems.

Both System Security Acceptance Testing and Penetration Testing must be performed. Results from both tests including mitigation actions should be reported to the P/SSO and/or the PE/O and approved before the commissioning of the system. All project documentation (outputs from current and previous security life cycle stages) must be handed over and accepted by the operations team (e.g., System Administrators) before entering the operations and support/maintenance phase.

Besides, Duruing hand over the systems to Employer, it should hold a training activities for Employer and/or maintenous service provider including following as minimum:

- All the operation & menu that are described in Security Functional Description Specification
- For event management, the configuring process related events to be logged and reported interface introduction
- Malware protection mechanism
- Configuration and Change Management

6.5.2 Operation and Support/Maintenance – if applicable.

Operations and support/maintenance is the phase where systems are in place and

operating. Enhancements and/or modifications to the system, from a software and hardware perspective, are developed and tested in this phase.
This process is to ensure that the operating system is regularly evaluated to check the effectiveness of security controls against current threats.
The generic maintenance service procedure could refer to 7.8.

The operations and support/maintenance service could be trigged by a Service Letter Agreement (SLA) from Asset owner. The operations and support/maintenance service should refer to 7.1 to start the service. The cyber security awareness training should be performed (for detailed practice, please refer to 7.1.3), and it should include the content of O&M documents (Security Functional Description Specifications) from Asset Owner.

The main activities at this stage could include following tasks as minimum:

1 Develop a Maintenance Service plan for Employer, it should follow all the Security Planning procedures (Refer to 6.5.1.2.1), if applicable.
2 Performing regular general and technical security controls reviews to determine if the security controls in place continue to be effective over time.
3 Performing proper change management (Management of Change, MOC) to prevent unintended consequences to the security baseline and to reduce the security risks posed by changes to the systems.
4 Performing proper configuration management to ensure that the security baseline of the system remains effective.
5 Regular security testing and/or evaluation.
6 SuC's cybersecurity incident response and recovery.
7 Performing continuous monitoring such as vulnerability assessment to determine the current state of the system security.

6.5.2.1 Perform security review

Security Review is an essential function to determine if the security controls in place continue to be effective over time, in light of system and environmental changes. In addition to assessing technology assets and technical security controls, security policies addressing issues such as acceptable use, and network rights should be reviewed to determine if administrative security controls are effective.
Security Review must be performed after all system and application changes to ensure that security controls continue to be effective.
Security Review should be performed by independent third-party assessors.
The activities of the security review could include, but not limited to :

1. The security hardening guidelines and procedures should be inspected Periodically. The check procedure should follow 7.6.1 3(2) and 2(5)[1] procedure.

2. Security analysis tools shall be Periodically used to discover undocumented and/or unauthorized systems or vulnerabilities in the SuC for Regular security testing and/or evaluation. It should follow 7.7.1 and 7.6.1 3(1) procedures.
3. Backup and procedure should be periodically checked and/or inspected, and disaster recovery test. It should follow 7.5 12 procedures.
4. It should periodically review/test/inspect the Automation Solution communication architecture, including its use of network security devices or equivalent mechanisms, is implemented according to the Automation Solution design as specified and approved by the asset owner. It could refer to 7.5 2(6) and 7.6.1 2(2)[13] to test or inspect the requirement for the implementation. Any changes of communication architecture should not negatively impact the approved network segmentation.
5. It should periodically review/inspect the logical and physical infrastructure drawings/documentation of the Automation Solution, including its network devices, internal interfaces, and external interfaces. It could refer to 7.5 4(1), 7.5 4(2) and 7.6.1 1(3).
6. It should periodically review/inspect the inventory register of the Automation Solution, including version numbers and serial numbers, of all devices and their software components. It could refer to 7.2.2 3.

6.5.2.2 Perform type/setting/configuration management.

Configuration Management is critical to establishing an initial baseline of the system and subsequently for controlling and maintaining an accurate inventory of any changes (including type/setting/configuration) to the system (refer to 7.4.1.4 for detailed practices).

Changes to the system configuration can have a significant security impact, therefore configuration management must include an assessment of the potential impact on the security of the system.

6.5.2.3 Perform Management of Change (MOC)

Change Management is critical to identifying significant changes and impacts that alter a system's security posture.

Inadequate control of changes to systems is a common cause of system or security failures. Changes to the operational environment, including changes from the development to production stages, can impact the security posture of the system.

Changes in the operational environment, including changes from the development phase to the Projection phase, may affect the security posture of the system. Change management practices should refer to 7.4.1.11 practices.

6.5.2.4 Regular security testing and/or evaluation

Scanning, conducting logs and continuously updating the security design is

essential for a safe system. This service will on a continuous occurrence review the system's status and scanning results and report back to the PE/O on system deviations that potentially could affect the Safety, Integrity, Availability, and Confidentiality (SIAC) of SuC. Security testing and/or assessment practices should refer to 7.7.1 practices.

6.5.2.5 SuC's cybersecurity incident response and recovery

The purpose and goal of this service are to verify, exercise, and shorten the impact time of security incidents in interrupting of

1. asset of the employer's Projection process.
2. the organization supporting the delivery of essential services to the employer's business, the owners, and authorities.

Securing the Security, Integrity, Availability, and Confidentiality of systems supporting the overall goal. Cybersecurity incident response and recovery or recovery practices should refer to 7.4.1.9 practices.

6.5.2.6 Perform continuous monitoring

The objective of continuous monitoring is to determine if the security controls in place continue to be effective over time, in light of system and environmental changes. It can include security reviews, self-assessments, vulnerability assessments, and patch and end-point management.

Continuous Monitoring may also be in the form of automated software that uses the baseline security controls as a comparison to generate results. Automation should be leveraged where possible to reduce the level of effort and ensure repeatability.

For example, weaknesses/vulnerability assessment is necessary due to the discovery of new weaknesses/vulnerabilities every day.

A weaknesses/vulnerability assessment report can be used to take appropriate risk mitigation actions and make risk-based decisions regarding the continued operations of the system and the explicit acceptance of risk that results from that decision.

6.5.2.7 Control gate review (R4:C4)

In this phase, while using the system, we are reassessing its status based on user feedback, technology changes, policy changes, new threats and weaknesses/vulnerabilities, and other business-related issues. The approving authority for this control gate is the Project Employer or Asset Owner (PE/O).

Recommended control validations for this phase include:

1. Validation of security reviews to ensure that built-in controls remain effective and reporting the results to the P/SSO and/or the PE/O;
2. Validation of security assessment and review reports to ensure that

systems and environmental changes are addressed.

3. Regular review of TRA reports and risk registers to ensure that risks remain valid and are continually addressed.

6.5.3 Decommissioning/Disposal – if applicable

The final stage is the disposal of a system and closes out current contracts. Information and system disposal will be addressed explicitly in this phase. The process and activities in this phase ensure the orderly termination of the system while preserving the vital information about the system so that the relevant information may be reactivated, migrated, or archived in accordance with regulations and policies.

The process addresses the proper disposal of the information, hardware, and software in a manner that prevents any possibility of unauthorized leakage of sensitive data. This also includes the proper preservation and archival of data processed by the system in accordance with the organization's security requirements.

6.5.3.1 Preserve Information

Organizations should select the archival method that would facilitate information retrieval in the future. This should take into consideration the following:

1. Obsolescence or unavailability of archival technology in the future
2. Legal and regulatory obligations for minimum records retention periods.

The archived information should also be marked and handled in compliance with its security classification.

6.5.3.2 Sanitize Media

Based on the security classification of the system and its information, the System Owners shall sanitize the system's digital media using approved equipment, techniques, and procedures according to relevant policies and regulations.

Systems owners should categorize the information, assess the nature of the medium on which it is recorded, assess the risk to confidentiality, and determine the appropriate sanitization process. NIST SP 800-88 r1, Guidelines for Media Sanitization provides details on media sanitization best practices.

It shall permanently destroy/delete all data in the component requiring safeguarding, as described in SP 03.10 BR, when it removes that component from the SuC, include deleting the data storage points and dataflows within the Automation Solution that require safeguarding, and the security implements for their safeguarding (e.g. confidentiality, integrity, availability).

The goal is to prevent sensitive data in a component/device that has been removed from the Automation Solution from being subsequently disclosed to anyone who can have access to the component after its removal.

Annexes Table C.6. No. VCSC.05-05 can be used to verify that the sensitive data in devices / components are removed from the automation solution and

permanently destroyed.

6.5.3.3 Dispose Hardware & Software

Depending on relevant policies and regulations, hardware can be sold, discarded, or given away. The disposal of software should comply with license agreements.

6.5.3.4 Control gate review (R5:C5)

In the disposal phase, the key concern is that the system is terminated in an orderly manner, and that vital information about the system is preserved according to applicable records management regulations and policies for future access. All media is accorded the correct sanitization method and finally the hardware and software are disposed of according to policy. The approving authority of this gate is the System Owners.

Recommended control validations for this stage include:

1 Validating information of the system has been correctly preserved and accorded with the right security classification.

2 Validating that media sanitization records have been properly recorded and filed. It should ensure that devices that are removed from active participation in the SuC are sanitized of their confidential or sensitive data. Typically, this can be done by destroying memory or overwriting (clearing) it several times to remove residual data. The number of times memory has to be overwritten is dependent on the type of memory.

3 Validating the disposition records against actual hardware/software inventory.

6.6 Risk management and continuous improvement

New security threats are constantly being identified and exploited by attackers, so the company help must compensate for this by continuously improving ICP’s SDL through this process.

This shall include the analysis of security-related issues in component/subsystem/system technologies that escape to the field from security issues management.

The auditing procedure may refer to the process of the QP-11 產品檢驗管理程序.

6.6.1 KPI formulation

The following metrics may also be established by the development team to monitor the effectiveness of the development process and help determine if measurable improvements are being made. The specific metrics to be collected (if any) are up to the SuC’s implementer:

1. Functional security – based on security functions defined;
2. Implementation security – based on the results of Static Code Analysis (SCA);
3. Deployment security – based on the results of an analysis of the attack surface of

the SuC;

4. Current backlog – based on the number of critical security defects in the SuC;
5. Training – based on the assessment scores of the engineers;
6. SDL process violations – based on the deviations to the SDL secure coding guidelines and;
7. Performance of the static analysis tool – based on vulnerability detection rate for code or flaws feedback in software or security by various related stakeholders.

Follow the process of the QMS-01 品質手冊 session 6 to identify key performance indicators by P/SSO annually.

6.6.2 Regular evaluation

1. The organization shall conduct internal audits at planned intervals at least once per year to provide information on whether the security management system conforms to the organization's requirements and the requirements of IEC 62443-2-4.
2. A group may be formed under General Management to conduct the internal audit. The auditors may come from internal or external. The competence required: Secure Software Development Life Cycle (SSDLC) training, Certified Secure Software Lifecycle Professional (CSSLP), Certified Information Systems Security Professional (CISSP), or other training that is recognized by P/SSO.
3. The organization shall plan, establish, implement, and maintain an audit program, including the frequency, methods, responsibilities, planning requirements, and reporting. The audit program shall take into consideration the importance of the processes concerned and the results of previous audits (internal and external);
4. Simulate a security event and writing security data to an audit log according to requirements of an asset owner. Annex A.9 13. could be used to exercise as training activity of this task.

6.6.3 Audit and Security assessment

The third-party audit should be considered for the following cases:

1. The risk level of risk assessment;
2. The policy of the company for the security product; and
3. The impact of events or incidents.

Other, the third-party assessment or/and validation of the product should have been done for the following cases:

1. Changes to the SuC's requirements;
2. Changes to other scheme requirements;
3. Changes by the vendors; and

4. A vulnerability impacting the SuC was disclosed.

6.6.4 Prevention and Correction

1. The General Manager shall review the organization's security management system at planned intervals to ensure its continuing suitability, adequacy, and effectiveness.
2. The management review shall include consideration of:
   (1) The status of actions from previous management reviews;
   (2) Changes in external and internal issues that are relevant to the security management system;
   (3) Feedback on the information security performance, including trends in nonconformities and corrective actions, monitoring and measurement results, audit results, and fulfilment of information security objectives.
   (4) Feedback from interested parties;
   (5) Opportunities for continual improvement.
3. The outputs of the management review shall include decisions related to continual improvement opportunities and any need for changes to the security management system.
4. The organization shall retain documented information as evidence of the results of management reviews.
5. The management review may be conducted with the management review process of the QP-13 內部稽核與審查管理程序.

The following activities, but not limited, that can help improve SDL are:

1. Improving the threat model by using a known security vulnerability database;
2. Attend external security or SDL conferences or participate in industry SDL groups;
3. Using multiple similar security testing tools, combining manual penetration testing with an automated tool, or using dedicated security testing experts for SVV-3 Vulnerability testing;
4. Conduct internal SDL conferences or sessions for sharing best practices within the organization; and
5. Create fuzzing tools for any protocols for which tools are not available.

6.6.5 Management review

1. The organization's response to a need for corrective action is documented in some corrective action procedures.
2. This procedure includes the root cause analysis (RCA) requirement to ensure that the non-conformance does not re-occur.
3. The timeframe for response and implementation of corrective action is the choice of the organization, except for non-conformances raised by certification bodies. There are defined timeframes for the implementation of corrective action for any

non-conformances raised during certification or surveillance audits.

4. One of the main drivers of improvement is to learn from security incidents, issues identified in audits, performance issues identified from monitoring, complaints from interested parties, and ideas generated at management reviews. For each learning opportunity identified you must maintain a record of the following:
   (1) What occurred;
   (2) If the event had undesirable consequences, what action was taken to contain and mitigate those;
   (3) The root cause of the event (if determined);
   (4) The action is taken to eliminate the root cause (if needed); and
   (5) An assessment of the effectiveness of any action taken.
5. The corrective action procedure may refer to the process of the QP-05 不符合與矯正預防管理程序.

7.0 OT Security Practices

In order to effectively and consistently implement the technology or procedures of various security requirements, Annexes B.4. The corresponding of Security program process and guidelines could be used to perform the process of following practices for security programs.

In general, for each requirement of security program,

1. It could use the various annex A as the “input” information or template to start to implement.
2. Use following related practices as the “Measures” specification to be the steps that must be followed.
3. Use the various annex C tables as the “Verification steps” checklist to perform the inspection or testing for the security programs.
4. Finally, the “outputs” document will be made, and should be delivered to the Project Employer or Asset Owner (PE/O) for reviewing and approval.
5. All the output would be performed by the validation check during each gate review.

7.1 Practices for Security Planning

The Practices Security Planning should adopted in both Integration and Maintenance services, include Development of Security Plan (7.1.1). Review and Management of Security Plan (7.1.2), and Training activity for Security Plan (7.1.3).

7.1.1 Development of Security Plan

7.1.1.1 Security Management Plan

A Security Management Plan document shall be developed. This document describes the required work scope and manages the Security requirements of the project. This document also describes the document delivery planning for assets and SuC, cybersecurity documentation, policies and Procedures, Cybersecurity Governance, Timeline, and Testing. Annexes A.1 can be used to document the Security Management Plan. The contents shall include, but not limited to, the following:

1. The PE/O’s security requirements, policies, and procedures
2. The PE/O’s Management of Change (MOC) and **Permit to Work (PtW) processes** for changes involving devices, workstations, and servers and connections between them.
3. The protection of the confidentiality of the PE/O’s data includes, but not limit to : documents of contract, technical, specification, meeting minute, sharing documents, etc. All the policies, procedures required to protect the confidentiality of the asset owner's data also shall be followed.

Besides, following topics also could be include if need:

1. Project Assets and SuC Description

2. Cybersecurity Documentation
3. Documentation Of Policies and Procedures for Protecting the Assets
4. Cybersecurity Governance
5. Project Role & Responsibility
6. Timeline of Implementation and Personnel Dedication
7. Organization Controls Planning for Gates
8. Testing Cases and Programs for Systems
9. Permit to Work (PtW) processes

7.1.1.2 Security Vendor Management Plan

Security Vendor Management Plan document shall be developed. This document describes the OT Security management of the vendors in the Project. This document also describes the management of document delivery for assets and SuC, cybersecurity documentation, policies and Procedures, Cybersecurity Governance, Timeline, and Testing with the vendors. Annexes A.2 can be used to document the Security Vendor Management Plan. The requiremments in the document shall be listed in contract of subcontractor or consultant to comply the requirements from asset owner. The contents shall include, but not limited to,

1. The PE/O’s security requirements, policies, and procedures
2. The PE/O’s Management of Change (MOC) and Permit to Work (PtW) processes for changes involving devices, workstations, and servers and connections between them.
3. The protection of the confidentiality of the PE/O’s data include but not limit to : documents of contract, technical, specification, meeting minute, sharing documents, etc. All the policies, procedures required to protect the confidentiality of the asset owner's data also shall be followed.

Besides, the following topics also could be include if need:

1. Project Assets and SuC Description
2. Governance/Strategy
3. Main Contractor responsibilities
4. Vendors responsibilities
5. PE/O’s responsibilities
6. Communicate Requirements to Vendor
7. Vendor selection process
8. Documents
9. Engineering plan
10. Vendor Management after Purchase Order

11. Progress Follow-up
12. Vendor Tests Management
13. Inspection and Test Protocol (ITP)
14. FAT
15. SAT

7.1.1.3 SI/SM Project Security Management Plan

The general overall context to which the secure development project shall be presented in an SI/SM Project Security Management Plan. SI/SM Project Security Management Planning Guideline shall be used to develop the SI/SM Project Security Management Plan. The corresponding project descriptions which include purposes, objectives, scope, contracture requirements if applicable, delivery strategy, master planning, and relevant stakeholders should be shown. Annexes A.3 can be used to document the SI/SM Project Security Management Plan. The contents shall include, but not limited to,

1. Direct subcontractors and consultants to comply with the PE/O's Management of Change (MOC) and Permit to Work (PtW) processes, and the protection of the confidentiality of the PE/O's data include but not limit to : documents of contract, technical, specification, meeting minute, sharing documents, etc. All the policies, procedures required to protect the confidentiality of the asset owner's data also shall be followed.

2. All assigned personnel (including subcontractors or consultant) have successfully passed security-related background checks, where feasible, and to the extent allowed by applicable law.
3. Assign a security contact in its organization to the Automation Solution which is responsible and accountable for the following activities.
   - Acting as liaison with the PE/O, as appropriate, about the service provider's and the Automation Solution's adherence to the Part 2-4 requirements that are required by the PE/O.
   - Communicating the Project's point-of-view on SuC's security to the PE/O's staff.
   - Ensuring that tenders to the PE/O are aligned and in compliance with the Part 2-4 requirements specified as required by the PE/O and the Project's internal SuC's security requirements.
   - Communicating to the PE/O deviations from, or other issues not conforming with, the Part 2-4 requirements that are required by the PE/O. This includes deviations between these requirements and the service provider's internal requirements.

4. Shall have documented minimum SuC's cyber-security qualifications for security lead positions and the capability to assign security leads to Automation Solutions who meet these qualifications and are qualified for this role.
5. Shall have a process that can be performed for the PE/O to inform the PE/O of changes to:
   - New personnel who need to get access to the solution
   - Personnel who no longer need access to the solution

7.1.1.4 Security Policy and Procedures Plan

The security policies and procedures plan shall be created and maintained. Annexes A.4 can be used to document the Security Policy and Procedures Plan. The contents should include, but not limited to:

1. Account Management Plan
2. Vulnerability Management Procedure:
   - It shall include the recommendation of security analysis tools to use, it shall obtain approval from the PE/O or Employer before using security analysis tools (e.g., network scans) at the PE/O's site. Annexes A.12 can be used to document the Vulnerability Scanning Report.
   - The security analysis tools used shall not affect SuC's normal operation. It shall ensure the control system components used in the Automation Solution can maintain the operation of essential control system functions in the presence of system and/or network scans during normal operation. It shall specify which criteria apply for the normal operation of its components in a solution or reference architecture, and the selecting and using control system components for solution or reference architecture that can withstand scanning by system or network scans shall be approved by the PE/O.
   - Vulnerability handling process
     Vulnerability management shall be performed. The vulnerability management process should follow Figure 4: Vulnerability handling process to manage (identifying, assessing, addressing, and disclosing) vulnerabilities that affect the SuC, including its related policies and procedures. These capabilities shall address: 1) the management of vulnerabilities newly discovered in the SuC or in its related policies and procedures for which the Project is responsible, and 2) the management of publicly disclosed vulnerabilities affecting the SuC (it should regularly refer the information like

https://cve.mitre.org/cve/) .

First, it should be evaluated whether a system under operation is affected. In this case, ad hoc immediate countermeasures should be applied which ensure a sufficient level of security while the vulnerability and the associated risk are assessed. Essential functions should continue to be supported, if applicable.

Then a TRA of the system including the new vulnerability should be performed and countermeasures are added to the system until an acceptable level of risk is achieved. In this process, the ad hoc countermeasures may also be changed or substituted. During this process, a patch schedule should be determined. The time duration until the patch is rolled out may be a factor in the risk assessment.

Depending on the risk of acceptance of the railway operator a risk can be accepted.

The implementation should be monitored. If changes in the schedule occur or if new threats arise from the vulnerability, then the TRA should be updated.

Typically, the process of identifying vulnerabilities includes event analysis and correlation, risk assessment, network scans, and other automated methods, and assurance. Software patches that result from the disposition of vulnerabilities are security patches.

In addition, monitoring product supplier websites, or subscribing to vulnerability feeds are other examples of how to identify vulnerabilities.

The output of Risk Assessment and Identify Mitigations shall include a list of countermeasures and shall describe how to mitigate security weaknesses inherent in the design and/or implementation of communication protocols used in the SuC that were known prior to Automation Solution integration or maintenance activities.

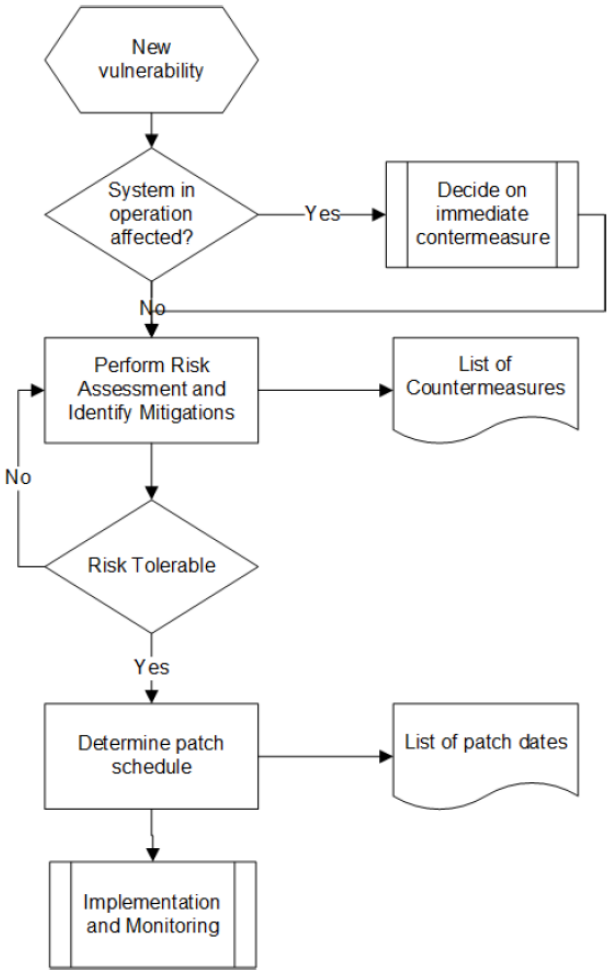

Figure 4 Vulnerability handling process

3. Backup and Restore Procedure
4. System Malware Protection Procedure
5. Change and Patch Management Procedure
6. Logging, Monitoring, and Reporting Procedure.

7.1.2 Review and Management of Security Plan

The Security Plan (including the Security Management Plan, Vendor Management Plan, and SI/SM Project Security Management Plan) shall be reviewed. Annexes Table C.1. can be used to verify the completeness.

1. For the SI/SM Project Security Management Plan, the review of the document should include, but not limited to,
   (1) The review should be verified by leader of PD or related department manager, and validated by P/SSO.
   (2) Annexes Table C.1 item VCSP.16 ~ VCSP.23 could be used to verify the SI/SM Project Security Management Plan document.

(3) The project personnel shall accept his/her responsibility to comply with the security aspects that he/she has been informed of,

2. For the Security Management Plan , the review of the document should include, but not limited to,
   (1) The project personnel shall accept his/her responsibility to comply with the security aspects that he/she has been informed of,
   (2) The confidentiality agreements with the PE/O
   (3) Have successfully passed security-related background checks, where feasible, and to the extent allowed by applicable law.
3. For the Security Vendor Management Plan, the review of documents should include, but not be limited to,
   (1) The project subcontractor or consultant personnel shall accept his/her responsibility to comply with the security aspects that he/she has been informed of.
   (2) The confidentiality agreements with the PE/O
   (3) Have successfully passed security-related background checks, where feasible, and to the extent allowed by applicable law.
4. Review the Security Policy and Procedures Plan
   Above plans should be reviewed by the following attender, but not limited to,
   (1) Security advisor; and
   (2) The content reviewer and the security reviewer.

If the project is the service for PE/O, then the Security Plans (include Security Management Plan, Security Vendor Management Plan and Security Policy and Procedures Plan) should be submitted to PE/O for approval, otherwise,
The approved Security Plan should be managed by a version control of the CCM process (referred to Section 7.4.1.4).

7.1.3 Training activity for Security Plan

An OT Security Awareness Training shall be performed. All assigned personnel (including subcontractor or consultant) to the Automation Solution shall have been informed of and comply with the requirements (e.g. responsibilities, policies, and procedures) defined in Security Management Plan, Vendor Management Plan, SI/SM Project Security Management Plan, and the requirements by the PE/O. The topics of the training should include, but not limited to, the following:

1. The security requirements, policies, and procedures from the PE/O, if applicable.
2. The process includes a verification/validation step that only informed personnel is assigned.

3. The PE/O's Management of Change (MOC) and Permit to Work (PtW) processes, and individual responsibilities required to support these processes.
4. Direct personnel to comply with protection of the confidentiality of PE/O's data.
5. IEC 62443 Overview
6. IEC 62443-2-4 Practice
7. IEC 62443-3-2/-3-3 Practice
8. IEC 62443-2-2/-3-3 V&V and Testing
9. Risk assessment principle and process.
10. Practice for policies and procedures integration, including Account Management, Vulnerability Management, Backup and Restore, System Malware Protection, Change and Patch Management, Logging, Monitoring, and Reporting.
11. Tasks & Personnel Assignment (IMP/VER/VAL)
12. Project Role & Responsibility (Subcontractor & Consultant)

7.2 Practices for Threat and Preliminary Risk Assessment (TRA)

If the asset owner has a specified risk assessment method, follow it, otherwise the following risk assessment methods should be implemented:

7.2.1 Perform Threat and Preliminary Risk Assessment and Documentation

A Threat and Preliminary Risk Assessment should be performed by following as a minimum:

1. It shall provide accurate logical and physical infrastructure drawings/documentation of the Automation Solution, including its network devices, internal interfaces, and external interfaces. Annexes A.5 gives an example to document the Data Flow Diagram (including logical and physical infrastructure drawings). The documentation and drawings shall be maintained as an accurate representation of the Automation Solution.
2. An Inventory Asset List shall be provided to create a hardware and software asset identification list, which can be utilized as a baseline for drawings and architecture diagrams. Risk assessments, zones (network segments), and conduits (connections between network segments), as described in IEC 62443-3-2, can be used in the development of the network architecture. Annexes A.6 can be used to document the Inventory Asset List.
   (1) The Inventory Asset List should include the version and serial numbers, of all devices and their software components in the SuC.
   (2) Besides, characteristics of The Inventory Asset List could include the following information, but not limited to,
   - Device Name-ID
   - Device Description-Purpose
   - Device Category

- Device SL-T
- Zone
- Plant Area Association
- Physical Location
- Connection
- Permanent /Temporary
- Manufacturer Name
- Manufacturer Model #
- Real Time Operating System (OS)
- Bios/Firmware
- Notes

(3) Documentation can include reports, automatically generated configuration data, screen captures, etc.

3. A network architecture documentation (Simple Network Diagram, Network and Data Flow Diagram) should be provided. Annexes A.5 gives an example to document the Data Flow Diagram, and Annexes A.7 gives an example to document the Simple Network Diagram. The network architecture should include each network segment, the network devices, including application gateways, used to interconnect the network segments, and identification of all network interfaces internal to the Automation Solution and those that connect the Automation Solution to external networks. Network interfaces can be identified through a variety of techniques, including Ethernet addresses (i.e. media access control addresses), IP addresses, and network interface card identifiers. The intent is to provide enough information about them to unambiguously identify them. A Simple Network Diagram for system-wise network connection should be generated for Preliminary Risk Assessment using.
4. It shall perform a Preliminary security risk assessment of the SuC or contribute to (participate in) a security risk assessment conducted by the Employer/PE/O or its agent. The security risk assessment could be triggered after the Preliminary Inventory Asset List and Simple Network Diagram are prepared. ICP's SI-SM Project Security Management Planning Guideline A.3 工作流程圖和安全風險評估要求 Workflow Diagram and Requirements of Security Risk Assessment, Table 4. The Proforma Form for Conducting the High-Level Cybersecurity Risk Assessment (HLCRA), and Table 5. The Proforma Form for Conducting the Detailed Risk Assessment Requirements (DRAR) should be used to perform the risk assessment process.
5. It shall have personnel (employees, consultants, contractors/subcontractors) capable of leading or actively participating in a risk assessment of the Solution.
6. The security risk assessment for the PE/O to obtain the risk parameters from the

PE/O Examples of such risk parameters are:

(1) Possible Financial damage on the unavailability of the SuC

(2) Compromises of integrity and confidentiality of automation solution data

(3) Breaches of regulatory requirements

7. The Preliminary Risk Assessment procedures should follow IEC 62443-3-2 requirements, to partition the SuC into zones and conduits, and to group assets or functions according to their risk.
8. It should be verified that security architecture reviews and/or security assessment and/or threat analysis of the control system used in the SuCs have been conducted by a third party.
9. A TRA report shall be generated, including the SuC system and asset that would be high-risk consideration and should be performed the detailed risk assessment for further measures. Annexes A.8 can be used to document the Threat and Risk Assessment Report. The TRA report shall inform and submit the Employer/PE/O of the results of security risk assessments that it performs on the SuC, including risk mitigation mechanisms/procedures and not mitigated residual risks.

7.2.2 Review and Management of Threat and Preliminary Risk Assessment

A review process should be executed by the following steps:

1. Assign a content reviewer to check the quality, clarity, format, and completeness of the content of documents.
2. Assign a security reviewer (for example, qualified personnel in SAD) to check the validity of security content, their ability to be verified, and whether it is consistent with the requirements of Section 7.2.1. Annexes Table C.2. can be used to verify the completeness of Threat and Preliminary Risk Assessment (TRA).
3. The network architecture documentation (Network and Data Flow Diagram) and Inventory Asset List shall be verified that wired and wireless devices used for control and instrumentation have been registered with the correct values to approve. Annexes Table C.3. can be used to verify the completeness of the network architecture documentation. Table C.4. can be used to verify the completeness of the Inventory Asset List. After the documents are verified and checked, they should be submitted to PE/O for validation review and approval, if applicable.
4. The approved documents should be managed by a version control of the CCM process (referred to Section [16]).
5. If there are any changes to the documents, the relevant information about the changes should be appropriately feedback, recorded, tracked, and managed (see Section 7.2.1). It should be reviewed and approved again, then checked into the

CCM process with new version control for any modification to the software security requirements specification after use.

7.3 Practices for Detailed Risk Assessment

7.3.1 Perform Detailed Risk Assessment and Documentation

A Detailed Risk Assessment should be performed by following as a minimum:

(1). Identify threats and document them;

(2). Identify and document vulnerabilities;

(3). Select a risk acceptance principle to establish cybersecurity requirements:

- Apply Codes of Practice
- Countermeasures for citing and reference system similarity
- Conduct detailed risk assessment

(4). Confirm the SL-T of the zone or conduit;

(5). Output cybersecurity requirements specifications;

Annexes A.8 can be used to document the threats, vulnerabilities, impact, Countermeasures & cybersecurity requirements specifications.

1. A detailed Inventory Asset List shall be created and maintained, the content of the Inventory Asset List should include, but not be limited to, the following:

   (1) Unique identifier
   (2) Name
   (3) Model/version
   (4) Supplier/Contractor/Fabricator
   (5) Services running
   (6) Software and applications
   (7) Patch status
   (8) Anti-virus status
   (9) IP & MAC addresses
   (10) Network segment
   (11) Hypervisors
   (12) OS/Firmware version
   (13) Security software installed (type and version)
   (14) Open Ports
   (15) Protocols

   Annexes A.6 can be used to document the extended detail Inventory Asset List.

   Note that this detailed Inventory Asset List should be kept up-to-date during the whole life cycle. If there are any changes to the documents, the relevant information about the changes should be appropriately feedback, recorded, tracked, and managed (see Section 7.2.1). It should be reviewed

and approved in next gate review, then checked into the CCM process with new version control for any modification to the software security requirements specification after use.

2. A network and data flow diagram for SuC shall be created and maintained, the information on each asset and data flow should include, but not be limited to, the following:
   (1) Function description of each host
   (2) Interfaces, ports of devices
   (3) Each data flow shows in one-direction
   (4) Protocols of each data flow direction
   (5) Short function description for each data flow direction

   Annexes A.5 gives an example to document the Data Flow Diagram.
3. It shall perform a Detailed security risk assessment of the SuC or contribute to (participate in) a security risk assessment conducted by the Employer/PE/O or its agent.
4. The Detailed Risk Assessment procedures should follow IEC 62443-3-2 requirements, the procedures shall include, but not be limited to, the following:
   (1) Identify and document the network segments of the SuC and their interfaces to other segments, including external networks, and for each interface designate whether it is trusted or untrusted.
   (2) Assess the interfaces of the SuC that have been identified as untrusted and are protected by network security devices or equivalent mechanisms, with documented and maintained security rules. At a minimum, the following shall be protected: 1) External interfaces 2) Level 2/Level 3 interfaces (may be include some “External” interfaces) 3) Interfaces between the BPCS and the SIS 4) Interfaces connecting wired and wireless BPCS networks 5) Interfaces connecting the BPCS to data warehouses (e.g. enterprise historians)
   (3) The protection mechanisms of the interfaces of the SuC shall be documented, and their effectiveness shall be ensured.
   (4) The process of protection for data storage points/document and dataflows shall be analyzed and documented the security requirements in the TRA reports, including Security Controls and dataflows, and should be implemented (refer to 7.4.1.2 10), planned and tested (refer to 7.5 2 5), and validated check (refer to 7.6.1 2(2)[9]. The process shall be performed, including but not limited, to:
      i. It shall identify and document data storage points and data flows within the SuC that require safeguarding, as defined, or approved by the PE/O or Security Policy and Procedures Plan. Examples

of the types of data to be protected include (this list is not exhaustive):

- It should be validated check (refer to 7.6.1 2. (2)[9].
- PE/O confidential data, including proprietary data (e.g. recipes) and data identified in NDAs or other contractual vehicles,
- configuration and operational data (e.g. commands and parameters),
- system data, such as cryptographic materials (e.g. keys and certificates), access control lists, passwords, network device data,
- audit and event logs,
- backup data,
- historical data,
- data warehouses.

ii. The security requirements for their safeguarding (e.g. confidentiality, integrity, availability). Access controls of the SuC shall be configured to protect data within the SuC requiring safeguarding, from unauthorized disclosure or modification, whether at rest or in transit. The security requirements should be documented in the TRA reports, including Security Controls and dataflows.

iii. It should be implemented (refer to 7.4.1.2 10.), includes configuring to protect data within the Automation Solution requiring safeguarding, as described above i and ii items, from unauthorized disclosure or modification, whether at rest or in transit.

iv. It should be planned and tested (refer to 7.5 2.(5), and

v. It should be validated check (refer to 7.6.1 2. (2)[9].

(5) Identify that interfaces of the Automation Solution that have been identified as untrusted are protected by network communication security devices or equivalent mechanisms, and to document how these interfaces are protected, including Automation Solution specific security policies and rules.

5. Assess wireless systems current in its description of the following: 1) data exchange to/from wireless instrumentation, 2) data exchange through a secure wireless link, 3) security mechanisms that prevent an intruder from gaining access to the Automation Solution using the wireless system, 4) security mechanisms that restrict access within the Automation Solution by workers with

handheld wireless devices, 5) where required, security mechanisms that protect remote management of wireless systems. All architecture descriptions should be updated to related documents including Inventory Asset List, Network and Data Flow Diagram, and TRA reports (including Security Controls).

6. If a wireless communication equipment is used in SuC,
   (1) it shall be registered in the Inventory Asset List, and the information should indicate whether wireless protocols used in the SuC are compliant with standards commonly used within the industrial security community and with applicable regulations. The information should include wireless protocols used in the SuC regarding their use of commonly accepted standard wireless technology.
   (2) An unique, Automation Solution-specific identifiers used for wireless networks are descriptive. Each wireless network should assign its identifier (e.g. SSID). If the identifier values are defined by the PE/O, the service provider's role is, if required, to guide their definition and/or review of the defined identifiers.
   (3) The SuC's wireless device addresses are configured.
7. A detailed TRA report shall be updated or generated, including the SuC system and asset that would be high-risk consideration, and should be performed the detailed risk assessment for further measures. The TRA report shall inform and submit the PE/O of the results of security risk assessments that it performs on the SuC, including risk mitigation mechanisms/procedures and not mitigated residual risks.
8. The security risk assessments of the communications of the SIS used in the SuC shall be conducted and addressed. The output includes Security Architecture (updated Network and Data Flow Diagram) and Security Controls (Security Risk Mitigation Plan and Requirement Specifications) that should be addressed.
9. It should be verified that security architecture reviews and/or security assessment and/or threat analysis of the control system used in the SuCs have been conducted by a third party.

7.3.2 Critical Security Design Review

1. Review of Security Architecture: Network and Data Flow Diagram
   (1) Include security architecture reviews of the communications of the SIS used in the Automation Solution
2. Review of Security Controls: Security Risk Mitigation Plan and Requirement Specifications
   (1) The security risk assessments of the communications of the SIS used in the Automation Solution. Typically, the review is done on integrated

SIS/control system products under the direction of the control system supplier in response to IEC 61511-1:2016, 8.2.4, and addressed by the supplier. In some cases, mitigation of risks is deferred to the Project as part of the installation/maintenance of the Automation Solution. In these cases, this requirement requires the Project to ensure the appropriate mitigations for the Automation Solution are determined.

3. Review of Security Detailed Risk Assessment Report and/or Updated TRA
   The review process should be executed by the following steps:
   (1) Assign a content reviewer to check the quality, clarity, format, and completeness of the content of documents.
   (2) Assign a security reviewer (for example, qualified personnel in SAD) to check the validity of security content, their ability to be verified, and whether it is consistent with the requirements of Section 7.3.1.
   (3) After the documents are verified and checked, they should be submitted to PE/O for validation review, if applicable.
   (4) The approved documents should be managed by a version control of the CCM process.
   (5) If there are any changes to the documents, the relevant information about the changes should be appropriately feedback, recorded, tracked, and managed (see Section 7.3.1). It should be reviewed and approved again, then checked into the CCM process with new version control for any modification to the software security requirements specification after use. Annexes Table C.5. can be used to verify the completeness of Security Design.

7.4 Practices for Implementation of system security countermeasures

7.4.1 Implementation of system security countermeasures and Documentation

All system security countermeasures that are the Requirement Specifications from the Detailed Risk Assessment report, including cybersecurity architecture and security controls (Functional Requirements, Security Countermeasures, Cybersecurity Policy, and Procedure requirements) should be implemented. The implementation of system security countermeasures should be documented in Security Policies and Procedures and/or Security Functional Description Specifications. Annexes A.9 can be used to document the system security countermeasures. The Implementation of Specific required countermeasures should be performed by following as minimum:

7.4.1.1 Implement and document the assurance security.

This practice should plan the assurance security activities in SI/SM Project Security Management Plan (7.1.1.3) during the planning stage and specifies relevant security solutions (including tools) in Security Policy and Procedures Plan (7.1.1.4) and approved by PE/O or Employer. Then, it will be implemented in each life cycle of the project, and the implementation of Specific required countermeasures should be performed by following as minimum:

1. In each control gate review of the project Life cycle stage, all Expected outputs that they have or that they can generate (e.g., as a result of a security assessment, threat analysis, and/or security testing) to confirm that components have adequate security for their intended use in the PE/O's Automation Solution) shall be verified and validated to have adequate security for their level of risk, and approved by PE/O.
2. A Vulnerability Management Procedures document (may be integrated into an IT/OT Security Functional Description Specification) shall be created and maintained. The procedures should be performed in high-risk consideration assets and should include but not limited to:
   (1) Security analysis tools (e.g., network scanning tools) shall be specified and validated for use in SuC
   (2) The instructions on how to use them should be described in the document.
   (3) Any known adverse effects they may have on the SuC's performance, and the recommendations for how to avoid adverse effects should be described in the document.

7.4.1.2 Implement and document the network segmentation (architecture) security.

This practice should be implemented in the preliminary risk assessment (7.2) and continuously updated and strengthened in the detailed risk assessment to define relevant network countermeasures and requirements (7.3). After the integration is implemented, the hardening process (7.4.1.5) and the relevant setting of requirements and inspection tests (7.5) should be performed to check the specific required countermeasures. The implementation of Specific required countermeasures should be performed by following as minimum:

1. A physical network segmentation architecture shall be implemented in SuC. The use of network security devices or equivalent mechanisms of the network is implemented according to the approved network and data flow diagram (7.3.12) by the PE/O.

2. A time distribution/synchronization for the SuC shall: 1) be performed from a secure and accurate source, and 2) use a protocol that is commonly accepted by both the security and industrial automation communities. The time synchronization setting of asses in SuC should be set to a same-time server IP address, if applicable.
3. It shall limit only software and hardware features required by the SuC or approved by the PE/O to be enabled in the SuC. At a minimum, the following requirements should be obeyed to reduce the attack surface of SuC:
   (1) unnecessary software applications and services (e.g. email, office applications, games) and their associated communication access points (e.g. TCP/UDP ports), USB devices (e.g. mass storage), Bluetooth and wireless communications are disabled and/or removed unless required and authorized for the SuC,
   (2) network addresses in use are authorized,
   (3) physical and logical access to diagnostic and configuration ports is protected from unauthorized access and use,
   (4) unused ports on network devices (e.g. switches and routers) are configured to prevent unauthorized access to the network infrastructure of the SuC, and
   (5) maintenance processes maintain the hardened state of the SuC during its lifetime.
4. It shall limit only necessary, authorized, and documented Certificate Authority (CA) digital certificates can be installed.
5. It shall enable a session locking function for SuC's workstations as required by the PE/O. This requirement applies only to the workstations for which the Project is responsible. The Session locking should:
   (1) prevent information on the logged-on user's display device from being viewed, and
   (2) block input from the user's input device (e.g. keyboard, mouse) until unlocked by the session user or an administrator.

   NOTE: Locking the user input device means that the user at the workstation is not able to use the keyboard except for unlocking the keyboard.
6. It shall implement that wired and wireless workstations, including handhelds, used for maintenance and engineering of wired and wireless control/instrumentation devices are installed and configured to avoid security risks associated with the circumvention of:
   (1) Automation Solution's access controls for these devices, should

implement the access controls (including authentication mechanisms) in accordance with PE/O policies or the Security Policies and Procedures Management Plan to minimize security risks. Windows AD could be used for Windows-based hosts in SuC, and Cisco RADIUS or Cisco TACACS+ could be used for IACS devices in SuC, if applicable.

(2) Communication security safeguards (e.g. network security devices) at the SuC boundary with Level 3. A Firewall or managed switch could be used to manage the connection authority limitation for the assets in the SuC's network.

(3) It should avoid direct access to these devices by handhelds that bypass access controls of the SuC.

(4) It should avoid direct access by a handheld to a wireless device in Level 3 that bypasses the Level 2/3 communication security device.

7. It shall implement the use of multi-factor authentication for SuC workstations as required by the PE/O or the Security Policies and Procedures Management Plan. This requirement applies only to the workstations for which the Project is responsible. The multi-factor authentication should include, at a minimum, two of the following:

(1) something the user knows, such as a password,

(2) something the user possesses (a physical token), such as a smart card,

(3) something inherent about the user, such as a retinal scan,

(4) someplace where the user is.

8. It shall configure the use of least privilege for the administration of network devices for which the Project is responsible. The least privilege for administrative operations means that access is granted only to resources (e.g. directories and files) that are needed, and operating system privileges are similarly restricted to only those that are needed.

(1) It shall configure network device access controls, including those for wireless network devices, as required by the PE/O or the Security Policies and Procedures Management Plan (The least privileged use rules for network devices from the Employer should be considered. If the Account Management Policy conflicts with the requirements of the PE/O, the requirements of the asset owner will prevail). Normally network devices are only accessed by users who are assigned the role of administrator. However, the PE/O's operating procedures can allow access to the network devices by other roles. Role-Based Access Control (RBAC), Attribute-Based

Access Control (ABAC), and/or Policy-Based Access Control (PBAC) could be used to support the access control scheme. Normally, network devices are accessed only by administrators so only one role needs to be defined and the access control list to be set accordingly. However, if the PE/O's operating procedures provide for different levels of network device administration, then multiple roles need to be defined. Users capable of administering network devices will then be granted these roles.

(2) It shall apply security measures to protect the confidentiality and integrity of data, in transit or at rest, that is used in the administration of communication devices (e.g. passwords, configuration data) and that is identified as sensitive data requiring safeguarding as specified in SP.03.10 BR and its REs (need to be protected by cryptography within the device and on communication links and informing the PE/O of the determination as requested).

- Encryption used on communications links can be performed at the network layer, on the transport layer connection, or at the message level to protect the data "on the wire".
- Encryption within network devices is used to prevent attacks on the configuration by malicious software in the device (e.g. as a result of hacking).
- The use of encryption mechanisms that provide integrity protection should be considered, such as AES_GCM.

(3) A mutual authentication shall be used for the administration of communication devices as required by the PE/O or the Security Policies and Procedures Management Plan (The least privileged use rules for network devices from the Employer should be considered. If the Account Management Policy conflicts with the requirements of the PE/O, the requirements of the asset owner will prevail). A technique of Challenge/response, user password/device certificate, and Kerberos (RFC 1510) could be used to provide mutual authentication.

9. The access to the SuC's control actions and data flows in the SuC (e.g. between workstations and controllers) shall be managed. Manual and/or automated controls should be in place to prevent Automation Solution devices, such as controllers, from executing invalid and/or unauthorized commands. The management, including configuration changes, are:

(1) valid, all commands (e.g. writes to setpoints, configuration commands) sent to SuC devices (e.g. from workstations) are valid

(within authorized limits), are authorized by a user with the appropriate permissions, and are transferred to the device executing the command (e.g. controller) over a connection that has been designated/authorized to be used for this purpose (e.g. a connection from an Operator Console to a controller).

(2) initiated or approved by an authorized user. The commands can only be requested by authorized users (e.g. operators), the entity receiving and executing the command knows which connections are authorized for receiving commands, and that the command is checked for validity. Validity is normally value and state dependent. For example, a setpoint normally is not allowed to be written by the operator without putting the loop into manual control.

(3) transferred over an approved communication path in the approved direction. data flows are conducted over an authorized connection and the data is transferred in the authorized direction. This portion of the requirement intends to make sure that the flow of data, including the direction, is authorized and conducted over authorized connections. For example, if a dynamic change (not a configuration change) to a set point is initiated by an entity not explicitly authorized to make the change, such as an advanced control application, then the system will notify the operator of the change and the operator is required to approve it before it can take effect. If the operator does not approve it, the set point does not change.

NOTE

(1) This requirement generally applies to commands issued by workstations and sent to controllers, and not to commands sent from controllers to Level 1 devices.

(2) Authorization of connections can be performed automatically by the control system and/or through appropriate configuration by the Project (setting up network addresses/ports authorized to send commands).

(3) Risk assessments (see IEC 62443-3-2) can be used to determine which connections are authorized to perform control actions. If warranted by the risk assessment, "dual approval" system capabilities (see IEC 62443-3-3) can be used to support this requirement. Dual approval refers to the system requiring two people to authorize actions that can result in a serious impact on the SuC.

(4) "Initiated or approved by" means, for example, that the Automation

Solution can prevent remote operators from changing setpoints without approval by the local operator through the authorized connection. How this is implemented is Automation solution dependent.

10. It shall implement the security requirements (e.g. confidentiality, integrity, availability) for data storage points and data flows within the SuC, either at rest or in transit. The control system data (e.g. passwords, certificates, keys) and other data deemed worthy of protection by the PE/O (e.g. recipes) should be protected. It should protect both types of data storage and data flows, at rest or in transit. Examples include data in memory (at rest) being used for calculations, and protocol header fields (in transit) being used to control packet/message transfer. A keepass tool could be used to protect the user password data files.
    (1) It shall implement the access controls of the SuC to protect data within the SuC requiring safeguarding, from unauthorized disclosure or modification, whether at rest or in transit. Access control mechanisms used to protect data typically could include:
        - mechanisms to protect against unauthorized memory dumps and network sniffing,
        - cryptographic mechanisms, including a) encryption keys, b) public key security infrastructure, c) digital signatures, d) data transport and message encryption, e) database encryption.
    (2) A description of the retention capabilities provided by the Automation Solution for storing/archiving sensitive data shall be implemented and documented. This documentation includes capacities, pruning and purging functions, retention timeouts, etc. This documentation should include the description of how the SuC stores/archives sensitive data, such as historical data and events. This can include internal capabilities of the SuC (e.g. data volumes/capacities) or can identify capabilities required to export historical data/events to a history archive. Historical data and events can be used during forensics and event analysis and correlation.
    (3) If cryptography is required (the requirement may request from Employer or countermeasure from risk assessment decision), the system/device shall use cryptographic algorithms , including algorithms and key management/distribution/protection, shall be commonly accepted by both the security and industrial automation communities (ex. use of standardized cryptographic protocol, use of recommended protocols (e.g. BSI TR-02102), see IEC 62443-4-2

CR4.3), or used according to proven practices or documentation, and the results (in TRA reports) of the configuration should be informed to and/or reviewed/approved by the PE/O.

7.4.1.3 Implement and document the account management security

The practice of the account management security should be implemented as a centralized account management mechanism, if possible. Windows AD could be used for Windows-based hosts in SuC, and Cisco RADIUS or Cisco TACACS+ could be used for IACS devices in SuC, if applicable. The user menus of these security solutions could be used as implementation guidelines to provide these functionalities, and should be integrated, set and inspected following requirements as minimum:

1. An account management system should be provided to support the following: 1) the administration of a single, integrated database, which may be distributed or redundant, for defining and managing user and service accounts, 2) the creation of accounts for authorized users only, 3) the configuration for decentralized access to this database for the management of accounts, 4) administration of decentralized enforcement of the account settings (e.g. passwords, operating system privileges, and access control lists) defined in this database. The account management system should: 1) have a single database that may be distributed or redundant, as determined by Automation Solution requirements, 2) allows accounts, including user, administrator/super user accounts, and service accounts (i.e. accounts that do not provide for interactive login), to be defined and managed for and by authorized users only, 3) allows administrators to manage accounts from a specified set of workstations/servers in the Automation Solution, not just from a single dedicated workstation, 4) distributes the enforcement of account access control lists and privileges to the location where the access or privilege is to be executed. Examples of this type of account management include Lightweight Directory Access Protocol (LDAP) based technologies. See IEC 62443-3-3 for related security requirements for systems used in Automation Solutions. Windows AD could be used for Windows-based hosts in SuC, and Cisco RADIUS or Cisco TACACS+ could be used for IACS devices in SuC, if applicable.
2. The account management shall provide to create and maintain unique accounts for each Automation Solution user. It should prevent users from having to share accounts, i.e. by having a separate account.
   (1) An account management document should be provided to the PE/O

that: 1) identifies all default user and service accounts that are installed in the Automation Solution, 2) describes the tools and procedures the PE/O can use to set/reset passwords for all default user and service accounts. It should ensure that there are no hidden accounts nor are there passwords that cannot be changed. A list of all user and service accounts and providing instructions to the PE/O that describe how to change their passwords should be generated. For accounts used by services and servers, changing a password may involve one or more of the following: 1) changing the password for the account, 2) changing the "logon" password in the services/services that run under the account, 3) changing the password used by other software processes that connect to other processes using the account. The list of all user and service accounts could be registered and/or recorded in an user account list. The instructions of account management could be provided in the Account Management of the Security Policies and Procedures and/or Security Functional Description Specification.

(2) If an account/password is automatically generated for a user, other than operators and service groups, both the generated account and password should be unique. The same password should not be generated for multiple user accounts, other than for operator and service groups.

(3) The service, auto-login, operator accounts, and other accounts required for essential functions and/or continuous operations, or as required by the PE/O should be configured so that they never expire nor become disabled automatically. These accounts should be configured as permanent accounts in the Automation Solution so that they do not expire or become automatically disabled or deleted. It should prevent services, operators, workstations configured for auto-login, and other accounts as required, from experiencing denial of service because their accounts have expired or become automatically disabled. Operator accounts are typically individual user accounts configured with operator privileges that provide visibility into the physical environment (e.g. the process) being controlled. This requirement does not prevent permanent accounts from being removed, or otherwise disabled, based on explicit actions taken by an administrator. A commonly recommended measure for Unix-based systems is to configure the root account to use the false or "no login" shell (and thus effectively deny all logins

using this account) and create a differently named alias for the root account for use by authorized administrative users.

(4) The built-in administrator account should be disabled, and if that is not possible, that it should be renamed or otherwise made difficult to exploit. It should disable or rename the built-in administrator account, or if neither of those is possible, should make it difficult to recognize and exploit it.

3. Unused system default accounts should be removed or disabled, including whether they are installed with the operating system or with the control system or related software, including unnecessary built-in accounts.
4. All user accounts should be removed once they are no longer needed, including 1) temporary accounts under the control of the Project, such as those used for integration or maintenance, 2) user accounts for the Project personnel who are no longer assigned to the Automation Solution (for notifying the PE/O of the removal of the Project personnel from the Automation Solution. It should provide functions or procedures for removing or disabling accounts that were created to support its personnel once their activities are complete or their assignment to the Automation Solution has ended. The intent is to ensure that the Automation Solution does not contain or retain these project accounts unless they are needed.
   (1) An audit log report after the completion of integration/maintenance activities that shows that accounts used to support these activities have been removed from the Automation Solution if they are no longer needed should be generated.
5. It should provide functions to configure password policies to achieve a minimum complexity commonly accepted by both the security and industrial automation communities. The password policies should provide minimal password complexity: 1) at least eight characters in length, and 2) a combination of at least three of the following four-character sets: lowercase, uppercase, numeric digit, and special characters (e.g.%, and #). Windows AD could be used for Windows-based hosts in SuC, and Cisco RADIUS or Cisco TACACS+ could be used for IACS devices in SuC, if applicable.
6. It should provide functions to configure passwords for local and system-wide (e.g. domain) user accounts to automatically expire after they have been in use for a period of time specified by the PE/O. It should ensure that passwords are configured to automatically expire after they have been in use by the PE/O for the specified number of days. When and

how often the Project configures and verifies the password settings for the password expiration period is Automation Solution specific, but verification is typically done as part of the handover process and after or during each maintenance cycle. The PE/O's security policy or Security Policies and Procedures Management Plan should set the expiration period based on a risk assessment and this value should periodically be reviewed. Windows AD could be used for Windows-based hosts in SuC, and Cisco RADIUS or Cisco TACACS+ could be used for IACS devices in SuC, if applicable.

(1) The password policies should provide functions to prompt users to change passwords N days before they expire, where N is specified by the PE/O. It should notify them that their passwords are expiring so they have time to change them.

7. Default passwords should be changed as required by the PE/O, including after the process of installation, re-installation, and reset/recovery.

8. It should provide functions for password policies to prevent users from reusing their last N passwords, where N is specified by the PE/O. Windows AD could be used for Windows-based hosts in SuC, and Cisco RADIUS or Cisco TACACS+ could be used for IACS devices in SuC, if applicable.

   (1) It should provide functions for password policies to prevent users from changing their passwords more frequently than once every N days, where N is specified by the PE/O. It should prevent users from changing passwords continuously to get back to a favorite password. The period of N days means that, once a password has been changed, the user cannot change it again for N days.

9. A secure document (could be a user account list) shall be created and keep this documentation current for accounts whose passwords have been approved by the PE/O to be shared with the Project. It should document the list of accounts for which passwords have been divulged to the Project by the PE/O and protect that list from unauthorized disclosure and modification. The user account list documents should be protected with a password to limit the ability to browse and/or edit. It should be accountable and responsible for maintaining a log of who has been given passwords for these accounts, including the subcontractors, consultants, and representatives. Account Management.xlsx file could be used as a template to report to the asset owner.

   (1) It shall report to the PE/O passwords that were 1) shared and no longer need to be shared, 2) knowingly divulged, or 3) knowingly

compromised, and support the PE/O in changing passwords as necessary. It should keep track of passwords (including passwords for auto-login accounts) that were shared with the Project or that the Project knows were compromised or otherwise divulged to others and report them to the PE/O so they can be changed. Once the passwords are no longer needed to be shared within the Project organization, and/or personnel share passwords with others no longer need to be shared, and/or sharing of passwords that occurs during testing, commissioning, troubleshooting, and maintenance, it should report these accounts/passwords to the PE/O. In addition, any time the Project suspects that a password has been compromised, it should notify the account owner and request the account owner to change its password.

7.4.1.4 Implement and document the configuration management (CM)

Configuration and Change Management (CCM) is a process to maintain the integrity of the hardware, software, firmware, Third-party Component (TPC), tools usage, documentation, workforce, or personnel assigned to the role-based security assurance organization of the secure product development project, etc. It should follow the process requirements that are described in 6.4 Configuration and Change Management.

1. File Integrity
   (1) An integrity verification mechanism shall be provided for PE/O or SuC's Users during their Operation and Support/Maintenance stage till the EOL/EOS phase to verify that scripts, executables, and other important files received from ICP have not been altered and verify software integrity in both the Mass Production stage and the Handling, Storage, and Transportation stage.
   (2) An integrity verification mechanism could be designed and embedded in a secure product to verify the file integrity of patch or update software. The table provided in Annexes B.3 can be used to review the method of file integrity before release. This shall be reviewed by the P/SSO and /or PE/O in Production/Implementation and Verification and Validation (R3), and then confirmed on R3 review (C3).
   (3) Common methods to satisfy this requirement include cryptographic hashes and digital signatures (which also provide proof of origin). The following measures may be considered as references:
      - Post cryptographic hashes for release files on a well-secured website;
      - Use an established certificate authority for code signing so product users can confirm the validity of signatures; and
      - Review the code signing processes if needed, including

certificate renewal and protection (according to the Certification Authority (CA)'s recommendation).

(4) If a digital signature (code signing) is used, the following process may be considered:

- There are multiple roles in the process: developer, signer, and verifier.
- The developer is the entity responsible for writing, building, and/or submitting the code that will be signed. This entity maintains a secure development environment, including the source code repository, and will submit code to the signer after it has completed the organization's software development and testing processes.
- The signer is the entity responsible for managing the keys used to sign software. This role may be performed by the same organization that developed or built the software, or by an independent party in a position to vouch for the source of the code. The signer generates the code signing private/public key pair on a device that is sufficiently protected, as the security of this process relies upon the protection of the private key. In many cases, the signer then provides the public key to a CA through a certificate signing request. The CA will confirm the signer's identity and provide a signed certificate that ties the signer to the provided public key. Anyone can use the public key associated with this certificate to validate the authenticity and integrity of the code signed with this key pair.
- When code is submitted by developers for signing, the signer verifies their identities and their authority to request a signature. The signer may also take additional steps to verify the code is trustworthy. Ultimately, two or more trusted agents of the code signing system may be needed to approve the request and generate a digital signature.
- The verifier is responsible for validating signatures on signed code. The verifier may be a software component provided by the same developer as the signed code (e.g., for a signed firmware update), or it may be a shared component provided by the platform (e.g., the operating system).

2. Configuration Items

(1) During the implementation of network architecture, a network architecture documentation (Network and Data Flow Diagram) includes each network segment, the network devices, including application gateways, used to interconnect the network segments, and identification of all network interfaces internal to the Automation Solution and those that connect the Automation Solution to external

networks, should be maintained and updated to the latest. During the maintenance stage, network architecture and a network architecture documentation also should be maintained and updated to the latest when each change for SuC.

(2) During the implementation of network architecture, an Inventory Asset List should be maintained and updated to the latest. During the maintenance stage, an Inventory Asset List also should be maintained and updated to the latest if any asset is changed for SuC.

(3) The network architecture documentation (Network and Data Flow Diagram) should keep the as-built and installed equipment connection and configuration documents current. It should keep its documentation up-to-date and describe the devices connected to each network segment in the Automation Solution. For an Ethernet device, the documentation would include the network address and switch to which the device is connected, and a copy of the download file used to configure the device.

(4) The wired and wireless devices used for control and instrumentation should be configured correctly with their approved values of the network architecture documentation (Network and Data Flow Diagram) and Inventory Asset List. The device configuration parameter values should be correctly downloaded/written to the device. The configuration parameter values could be confirmed by viewing them from a workstation.

7.4.1.5 Implement and document the SuC's Asset Hardening

A SuC's Asset Hardening shall be developed and should be performed and inspected during FAT and/or SAT stage. This document describes the required hardening concept for each device to reduce the security risk. Annexes A.10 can be used to document the IACS Automation Solutions/Asset Hardening Recommended Practices. The contents should include, but not limited to, the following:

1. A security hardening document (may be integrated into an IT/OT Security Functional Description Specification) shall be created and maintained. The procedures shall be performed for the included control system/ components.

7.4.1.6 Implement and document the wireless security if security control required.

If wireless devices are used in SuC, the practice of the wireless security should be implemented, if possible. The user menus/security guidelines of these wireless devices could be used as implementation guidelines to provide these security functionalities, and should be integrated, set and inspected

following requirements as minimum:

1. Implement the following functions of the wireless systems: 1) data exchange to/from wireless instrumentation, 2) data exchange through a secure wireless link, 3) security mechanisms that prevent an intruder from gaining access to the Automation Solution using the wireless system, 4) security mechanisms that restrict access within the Automation Solution by workers with handheld wireless devices, 5) where required, security mechanisms that protect for remote management of wireless systems. The goal is to ensure that wireless networks are protected from being used to gain unauthorized access to the Automation Solution. It should keep current its wireless communications architecture documentation that includes data flows, security mechanisms, and the use of wireless bridges. Any change of wireless network devices, the architecture documentation of the wireless networks shall be updated and checked to keep current.
2. The protection of wireless access shall be configured to use wireless authentication and access control mechanisms that are commonly accepted by both the security and industrial automation communities. (Example: WiFi password authentication, WirelessHART with configured join keys, Bluetooth with pairing). It should use commonly accepted authentication mechanisms and access control lists to prevent unauthorized access to wireless devices. The access control lists should be registered in an account list document.
3. The protection of wireless access shall be configured to protect wireless communications, and if cryptographic mechanisms are used for this purpose, they are commonly accepted by both the security and industrial automation communities. It should employ commonly accepted security mechanisms that protect access to data during transmission. This includes wireless communications between wireless devices and wireless access points and between wireless access points and other wireless access points.
4. The wireless protocols used in the SuC should use commonly accepted standard wireless technology.
5. The identifiers of the wireless network should not allow an external listener to identify the physical wireless network, its location, or the owner of the wireless network.
6. The wireless networks are configured to prevent: 1) the use of unauthorized device addresses, and 2) interference with the assignment of device addresses.

7.4.1.7 Implement and document the Safety Instrumented System (SIS) security if security control required

If SIS and/or essential/critical functionality of system are used in SuC, this practice should be implemented in the preliminary risk assessment (7.2) and continuously updated and strengthened in the detailed risk assessment to define relevant network countermeasures and requirements (7.3). The principles of Safety Instrumented System (SIS) security should be followed, and the results should be recorded in the Data Flow Diagram and TRA report and should be reviewed in Review and Management of Threat and Preliminary Risk Assessment (7.2.2) and Critical Security Design Review (7.3.2). After the integration is implemented, the relevant network implements and settings of requirements and inspection tests (7.5) should be performed to check the specific requirements of Safety Instrumented System (SIS) security. The implementation of Specific required countermeasures should be performed by following as minimum:

1. It shall configure the Automation Solution to protect safety communications and SIS safety functions from the BPCS or any other Automation Solution communications. The SIS communications critical to safety functions shall not be affected by other communications of the Automation Solution. It should have the physical separation of BPCS communications and the SIS. For example, firewalls and non-routable interfaces between the BPCS and SIS could be used to enforce this separation. NOTE: This requirement does not require that communications not critical to safety functions between the SIS and the BPCS (e.g. configuration downloads, status monitoring, logging) be shielded from other Automation Solution communications.
2. The external communications to the Automation Solution, including remote access communications, shall not be able to interfere with the operation of the SIS. The operation of the SIS should not be impacted by communications of devices/applications external to the Automation Solution.
3. The applications (e.g. control system applications) external to the SIS shall not be able to participate in disrupt or otherwise interfere with SIS communications that are critical to safety functions. It should not have communications critical to safety functions (e.g. data and/or commands) transferred between the SIS and applications residing external to the SIS. This requirement is intended to prevent the SIS functions critical to safety operations from being compromised by traffic originating from

sources outside the SIS.

4. The SIS EWSs that reside outside the SIS (external to the SIS interface with the control system) should be protected from compromise by communications from Level 3 or above. The safeguards should be employed, such as network security devices (e.g. firewall), and only authorized communications from Level 3 applications to SIS engineering workstations residing outside the SIS are permitted. Access from Level 3 applications to SIS engineering workstations that reside within the SIS is prohibited by SP.05.03 BR.
5. The SIS EWSs that reside within the SIS (internal to the SIS interface with the control system) should be protected from compromise by remote access (e.g. RDP). It should protect SIS engineering workstations that reside inside the SIS from being exploited via remote access connections. The SIS engineering workstations within the SIS (1a) either should not have remote access installed or (1b) should be disabled (not accessible), and/or (2) have security mechanisms that block remote access communications with these workstations.
6. All access to the Automation Solution’s SIS from outside the SIS shall be mediated and authorized at the interface to the SIS. Access controls to the SIS should be implemented at the interface to the SIS, for example by a gateway used only to provide access to the SIS from the BPCS.
7. The SIS functions performed by the Automation Solution’s SIS EWSs shall be protected from compromise by other SIS EWS software. It should reduce the possibility that the SIS EWS will contain T3 offline software (see IEC 61508-3) that could intentionally or inadvertently cause harm to the SIS. It should ensure that safety-related software running in SIS EWSs is protected from compromise from other software running in the SIS EWS.
8. Unauthorized wireless devices shall not be used as an integral part of SIS safety functions, to prevent attacks against the SIS by unauthorized wireless devices. Wireless device communications should not be used as an integral part of SIS safety functions when prohibited by the PE/O. "Integral part" refers to communications that are implemented and incorporated into SIS safety functions.
9. The function to enable and disable SIS configuration mode shall be provided. While disabled, this interface shall prohibit the SIS from being configured. The interface should prevent configuration messages from being delivered to the SIS. It should provide a process document (e.g. has written procedures) to lock the SIS to prevent configuration changes

from being made and unlock the SIS to allow configuration changes to be made. Locks could be physical key switches or software-controlled locks; however, when implemented, they allow the Project to follow its processes to lock the SIS to prevent inadvertent or malicious changes from being made.

(1) It shall provide a function process and/or procedure document to enable and disable a hardware implementation of the configuration mode interface required by SP.05.09 BR and to physically lock this hardware implementation while the configuration mode is disabled. It should be defined to require intentional human intervention to enable the configuration of the SIS, such as holding a physical key open (unlocked) while the configuration is being changed, to increase confidence that inadvertent changes to the SIS configuration cannot occur. The process (e.g. has written procedures) could use a hardware interface to enable or disable the ability to make SIS configuration changes. The hardware interface, such as a physical key switch, when physically locked (e.g. removing the key), causes the configuration mode to be disabled.

(2) It shall provide a function process and/or procedure document that can be performed for an independent third-party to verify that it is not possible to change the configuration of the SIS when the hardware interface described in SP.05.09 RE (1) is locked in the "disable" configuration mode. It should provide a report from a 3rd party that verifies that the SIS configuration locking mechanism works. The selection of independent third-party should be a certified ISA/IEC 62443 Cybersecurity Specialist or a ISO/IEC 17025 certified test Lab or individuals or organizations with equivalent technical experience and capabilities.

7.4.1.8 Implement and document the remote access security if security control required.

If the remote access functionalities are used in SuC, the practice of the remote access security should be implemented, if possible. A Remote PC Access (Citrix Virtual Apps and Desktops) or FortiGate IPSec VPN could be used to implement the remote access security. If asset owner specifies the tool or solution for the remote access connections, the specified tool or solution from asset owner should be considered priori to implement. The user menus/security guidelines of these tools could be used as implementation guidelines to provide these security functionalities, and should be integrated,

set and inspected following requirements as minimum:

1. All remote access applications used in the Automation Solution shall be commonly accepted by both the security and industrial automation communities. The remote access applications should provide acceptable levels of protection to the Automation Solution. The commonly accepted remote access mechanisms (e.g. RDP) could use multi-factor authentication mechanisms.
2. A document should be provided the detailed instructions for the installation, configuration, operation, and termination of the remote access applications to be used in the Automation Solution. Documentation for installing, configuring, and operating remote access applications that it recommends for use in the Automation Solution should be provided in the Security Policies and Procedures and/or Security Functional Description Specification. An instruction for the termination of these connections should be included in the document, and it should not permit to establishment of remote access connections that cannot be terminated by the PE/O.
3. The information about all proposed remote access connections to the PE/O that includes, for each connection: 1) its purpose, 2) the remote access application to be used, 3) how the connection will be established (e.g. via the Internet through a VPN), and 4) the location and identity of the remote client, shall be provided in the Security Policies and Procedures and/or Security Functional Description Specification. It should define and inform the PE/O of the details of all proposed remote access connections. The proposed location of the remote access client is required to be documented to allow the PE/O to review and approve/disapprove remote access from specific locations. In some cases, the proposed location can indicate "roaming" to allow for portable devices to be used as clients. It is not anticipated that the Automation Solution can automatically verify the physical location of the client at runtime.
4. All remote access connections to the Automation Solution shall be authorized by the PE/O. It should allow only those connections that have been approved by the PE/O. These remote access connections may be user-to-system or system-to-system, may traverse the Internet and/or include the use of modems, and/or may be provided and maintained by the PE/O. the PE/O could request the Project to provide or maintain the connections and can provide the appropriate requirements at that time. For example, the PE/O can prohibit TCP/IP protocols from being used

over external connections that use modems. The requirements for remote access connections should be generated by a risk assessment, as described in IEC 62443-3-2, including whether or not the connection should be encrypted, whether or not a modem can be used to provide the connection, and if so, whether the modem should be disconnected when not in use, and whether the modem should be capable of being used as a router.

5. All remote access connections conducted over the Internet or over other publicly accessible media that are used to support remote access to the Automation Solution by the Project (e.g. from the Project facility) shall be protected, such as authentication and encryption, as required by the PE/O. Protected links, such as VPNs, should be used when it remotely accesses the Automation Solution over the Internet (e.g. from its facilities or other remote locations). Authentication could be used to ensure that only authorized remote clients have access to the Automation Solution. It should offer remote support and troubleshooting/diagnostic services to the Automation Solution.

7.4.1.9 Implement and document the event management security if security control required.

The practice of the event management security should be implemented a centralized event management mechanism, if possible. A SPLUNK solution could be installed in Windows based host servers (WBHS) in SuC, or An Elasticsearch, Kibana, Beats, and Logstash (also known as the ELK Stack), or SINEC INS tools, to deliver the security logs to event log server or a Security Information and Event Management (SIEM) package, if applicable. The user menus of these security solutions could be used as implementation guidelines to provide these functionalities, and should be integrated, set and inspected following requirements as minimum:

1. The security incidents relevant to the Automation Solution shall be managed from detection through disposition to allow the security risk position of the Automation Solution to be maintained. It should configure to select and handle cyber-security incidents that affect the Automation Solution that including 1) which cyber-security compromises and incidents to detect, 2) which cyber-security incidents to report to the PE/O, 3) which cyber-security compromises and incidents need a response, can include supporting an incident response team. An identifiable process for detecting, handling, and reporting cyber-security incidents should be provided for: 1) determining which cyber-security

incidents associated with Automation Solution components for which the Project is responsible are deemed significant, and 2) configuring the Automation Solution and its supporting processes to detect, handle, report and respond to these incidents. The procedure for managing the security incidents should be documented in the Logging, Monitoring, and Reporting Procedure of Security Policies and Procedures and/or Security Functional Description Specification.

What constitutes an incident, which incidents are significant, and under what conditions they are reported to the PE/O are all part of the service provider's incident handling procedures. Incident handling implementation could be controlled by specific agreements between the PE/O and the Project, such as non-disclosure agreements and/or other contractual vehicles between the PE/O and the Project. These contractual vehicles often identify proprietary data to be protected and the types of compromise to be reported. Typically, the process of identifying incidents could include (1) event analysis and correlation, and (2) examination and triage of resulting compromises and potential incidents to yield incidents. SP.03.03 BR addresses the handling of vulnerabilities that were possibly exposed by this process or by other processes. For requirements related to product development incident reporting and handling that could refer to or complement the Project's incident handling capabilities and security guidelines, see IEC 62443-4-1 and ISO/IEC 30111..

2. A communications interface to report security compromises that have been automatically detected shall be provided and should be accessible to the PE/O and should be commonly accepted by both the security and industrial automation communities. Security compromises should be reported whether or not they result in a loss or are classified as an incident. Security compromises can be automatically detected at the time of compromise or through subsequent event analysis and correlation activities (e.g. through the use of a Security Information and Event Management (SIEM) package). To report security compromises that it detects automatically through an interface that the PE/O can use to receive the reports, the interface reports the detected events, for example, a SPLUNK agent could be installed in Windows based host servers (WBHS) in SuC, or Elasticsearch, Kibana, Beats, and Logstash (also known as the ELK Stack), or SINEC INS tools, to deliver the security logs to event log server or a Security Information and Event Management (SIEM) package.
3. An audit log shall be configured to write and collect all security-related

events, including user activities and account management activities, and shall be kept for the number of days specified by the PE/O (the requirements from asset owner) or specified in the Security Policies and Procedures Management Plan. It should provide an audit logging process for security-related events that include successful and invalid logins and logouts, and the creation, modification, or deletion of user accounts, among others. Audit logs can be used in forensics (e.g. who changed a user account and when) and in event correlation activities that can lead to security incident identification. Audit logs require a higher level of integrity protection than provided by typical event logs. They are used to protect against claims that repudiate responsibility for an action.

(1) The security-related data and events should be accessed through one or more interfaces that is/are commonly accepted by both the security and industrial automation communities. It should configure the Automation Solution to make it possible for the PE/O to collect security data and events over the network. Commonly accepted interfaces could include interfaces that support polling (SNMP reads), asynchronous reporting (e.g. SNMP traps), and logging (e.g. Syslog, Syslog-ng, and Common Event Format (CEF)). The use of commonly accepted interfaces makes it easier to integrate off-the-shelf software packages that collect and analyze data and events. For example, network devices typically maintain an SNMP Management Information Base (MIB) that contains security-related data that can be accessed using SNMP.

(2) It shall verify that security-related events can be written to an audit log. It should verify the mechanisms used to log and report security-related events operate as required by SP 08.02 BR and SP 08.02 RE (1). Simulation of security-related events could be used to demonstrate the writing of events to audit logs. Audit logs require a higher level of integrity protection than provided by typical event logs. They are used to protect against claims that repudiate responsibility for an action.

4. To log and notify the operator of process-related events as required by the PE/O shall be configured. The process-related event logs should be supported. The types of events should include state changes/operating condition changes/configuration changes that can be due to manual or automated (those without human intervention) operations. Notifications should include both simple event notifications and alarm/alert notifications. Alarms and events to be logged and reported should include

both operating system events and control system alarms and events. Event logs could be used in forensics (e.g. who changed a setpoint and when) and in event correlation activities that can lead to security incident identification. Events reported through this interface can potentially be determined to require safeguarding as required by risk assessment. See also SP.03.10 BR and its REs for requirements for the protection of sensitive data.

(1) The report alarms/alerts/events through an interface shall be secure that is commonly accepted by both the security and industrial automation communities. To report alarms and events to external applications, such as a centralized log, through a commonly accepted interface that protects the transmitted events against tampering and disclosure. This interface may support event notifications or event polling.

5. A document should be provided to the PE/O that describes the Automation Solution's ability to withstand the near-simultaneous occurrence of large numbers of events, typically referred to as event storms. To document the limits of the ability of the Automation Solution to protect against denial of service during event storms could be provided in the Logging, Monitoring, and Reporting Procedure of Security Policies and Procedures and/or Security Functional Description Specification. The characteristics of event storms (e.g. large number of events/second in relationship to the numbers that occur normally) are typically dependent on the number of control and instrumentation devices in the Automation Solution and the nature of the physical process.

7.4.1.10 Implement and document the malware protection security if security control required

If the malware protection countermeasures are required in SuC, the practice of the malware protection security should be implemented a distributed malware protection mechanism, if possible. A Palo Alto Antivirus system/tools could be used for malware protection mechanisms, if applicable. An OPSWAT MetaDefender Drive product could be used to scan malware for workstations, and OPSWAT MetaDefender Kiosk™ could be used to scan malware for portable media during implement and integration stages, and maintenance work stage as well. The user menus of these security solutions could be used as implementation guidelines to provide these functionalities, and should be integrated, set and inspected following requirements as minimum:

1. Documented instructions for the proper installation, configuration, and update of malware protection mechanisms shall be provided for the PE/O. The malware protection mechanisms should be commonly accepted malware protection software (e.g. anti-virus, whitelisting, NIDS) that operates as intended on Automation Solution hardware platforms (e.g. workstations) for which the Project is responsible. If the control system supplier does not test and recommend an anti-malware product, then it needs to be able to have these capabilities.
2. It should be implemented and ensured that: 1) malware protection mechanisms have been correctly installed/updated and properly configured in accordance with the service provider's approved procedures, as agreed with the PE/O, 2) malware definition files are installed within the time period agreed to with the PE/O, 3) malware configurations are maintained and kept current. Anti-malware software for Automation Solution platforms should be applied and managed, including installing and updating anti-malware software, keeping its malware definition files current, and maintaining its operational configuration settings. If anti-virus software is used, installation of anti-virus definition files should be performed within the agreed-to time period. If whitelisting software is used, whitelisting configurations should be kept current. Keeping a log of the installation and configuration activities, including updates to software and malware definition files, could be a way of demonstrating this process. The Palo Alto Antivirus system/tools could be used for malware protection mechanisms.
   (1) A document shall be created and maintained that describes the use of malware protection mechanisms in the Automation Solution. The document could be in the System Malware Protection Procedure of Security Policies and Procedures and/or Security Functional Description Specification. This documentation shall include for each component used in the Automation Solution: 1) the installation state of malware protection mechanisms or a statement that it is not technically possible to install malware protection mechanisms on the component, 2) the current configuration settings of the installed malware protection mechanism, 3) the current status of malware definition files approved for installation on the component, 4) the use of other mitigating features and functions used to reduce the risk of infection and/or mitigate the effect of infections (e.g. isolating infections, reporting infections).

3. Malware, other than zero-day malware, should be detected and properly handled by the installed malware protection mechanisms. Infected files could be detected and subsequently quarantined/deleted by the anti-malware product.
4. A document should be provided that describes: 1) how malware definition files for the Automation Solution are evaluated and approved, 2) reporting the status of malware definition files to the PE/O within N days after release of the files by the manufacturer, where N has been agreed to by the Project and PE/O. This status includes the applicability (e.g. component and version) and approval state (e.g .approved, installed, disapproved, etc.) for each malware definition file. This document is used to ensure that the Project has a process for verifying that new malware definition files are compatible with the Automation Solution and that they are available to the Automation Solution in a timely manner. The malware definition files should be approved and informed of the PE/O of the results within a mutually agreed time period after their release by the anti-malware software manufacturer. This does not require installation within this time period; it requires only that files are approved for installation within the time period. Approval means that the Project has evaluated the files for conflicts with their system. Those that conflict with the operation of the system is not approved.
5. All components, including workstations, supplied to the Automation Solution by the Project should be free of known malware prior to use in the Automation Solution. It should ensure that devices with detectable infections are not installed in the Automation Solution. The term "known malware" is used to indicate malware that has been previously discovered and for which malware definition files have been developed and are available. The OPSWAT MetaDefender Drive product could be used to scan malware for workstations, and OPSWAT MetaDefender Kiosk™ could be used to scan malware for portable media (e.g. USB memory device).
   (1) For portable media that is used for system testing, commissioning, and/or maintenance, it should be used this portable media for this purpose only. If a USB memory device has diagnostics tools or data on it, then this device should not be connected to any workstation or server that is not part of the Automation Solution.
   (2) All portable media used in or connected to the Automation Solution by the Project should be free of known malware before use in the Automation Solution. If a portable media (e.g. USB memory

device) has diagnostics tools or data on it, it should be scanned for free of known malware before use in the Automation Solution, then this device should not be connected to any workstation or server that is not part of the Automation Solution.

7.4.1.11 Implement and document the Patch management security if security control required.

This practice should plan the Patch management security and activities in the Security Policy and Procedures Plan (7.1.1.4) during the planning stage and approved by PE/O or Employer. Then, it will be implemented in each life cycle of the project, and the implementation of Specific required countermeasures should be performed by following as minimum:

1. A Generalized Patch Management Work Process (Figure 5) should be followed for software patches to the Automation Solution. Patching may be part of normal maintenance, or it may be required due to the identification of a critical vulnerability. In both cases, patching is part of change management. In the case of patching, it generally makes sense to have specific procedures rather than use the more generalized MOC work process. In general, patching should be performed as applicable. It should ensure that all authorized firmware upgrades should be implemented securely and that no unauthorized firmware changes should be made. Additional guidance is available in ANSIIISA -TR62443-2-3 2015. Figure 5 illustrates a generalized patch management work process. As patches inherently involve a relationship with the PE/O, it should have the capability to review, because of changes in security risks, how they evaluate and approve security patches for Automation Solution software for which they are responsible. Please note that while the project is responsible for providing patches, the PE/O is accountable for the actual decision to accept, defer, or reject a particular patch.

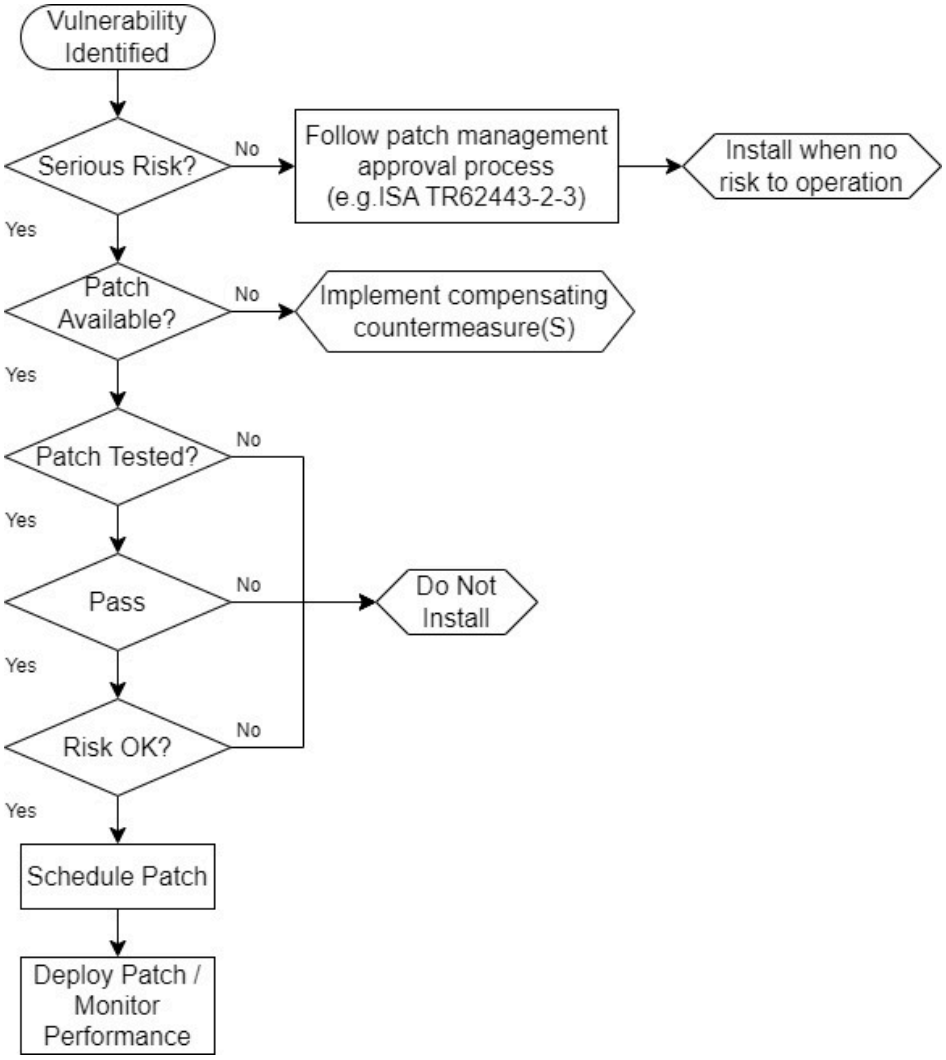

Figure 5 Generalized Patch Management Work Process.

2. A document should be provided to the PE/O that describes how security patches for Automation Solution software for which it is responsible are evaluated and approved. The content of the document could be in the Change and Patch Management Procedure of Security Policies and Procedures and/or Security Functional Description Specification. In this document, firmware upgrades are regarded as software patches and patch installation refers to installation of patches to the Automation Solution. The documentation should be reviewed by the PE/O to verify that new software security patches are compatible with the Automation Solution. In many cases, the Project will use documentation from the control system product supplier and modify it for the Automation Solution if necessary. The document should describe its policies for determining which security patches apply to the Automation Solution, and how they

are tested and approved. This includes security patches for the control system and component software, operating system software, and 3rd party software applications integrated into or with the Automation Solution, the control system, and components. IEC TR 62443-2-3 describes patch management and outlines a set of associated responsibilities for the control system supplier and the PE/O.

(1) The patch management process document shall include a process for the PE/O to review, as a result of changes in security risks, how it evaluates and approves security patches for Automation Solution software for which it is responsible. The patch process should include the patch evaluation process in response to changes in the cyber-security threat landscape (e.g. new threats can require a more rapid response). Typically, this is demonstrated as part of its incident handling processes or as a separate process for periodically reviewing its patch evaluation process. It should include the process for evaluating and approving the security patches. These reviews are required to be performed to be able to update this process to address changes in the risk environment. This review should be performed periodically or explicitly in response to significant changes in the risk environment. Significant changes are those that are recognized to have a potential impact on the process. Changes to the risk environment generally include new threats and vulnerabilities as well as the development of new security technologies.

3. The patch management process document shall include the process to inform PE/O about the description of security patches/updates. The process shall include making the description of each patch available to the PE/O within a time frame after the release of a patch by its manufacturer that is acceptable to the PE/O. The informing documentation shall include 1) security patches that apply to components of the Automation Solution for which the Project is responsible, 2) the approval status/lifecycle state (see IEC TR 62443-2-3) of each, i.e., approved, not approved, not applicable, in test, 3) a warning if the application of an approved patch requires or causes a re-start of the system, 4) the reason for those that are not approved or not applicable, 5) a plan for the remediation for those that are applicable but not approved. The descriptions of security patches that are relevant to the Automation Solution from the Project and to have these projects recommend how to mitigate vulnerabilities for patches the PE/O chooses not to install. An

identifiable process should be included in the patch management process for evaluating and approving security patches as documented by the process defined in SP.11.01 BR, and for informing the PE/O of the results within an agreed time frame "N number of days after the release of the patch by its manufacturer", where N is agreed to by the Project and the PE/O. The Project may use software libraries that are enhanced or otherwise different than those provided by their manufacturer(s). In this case, it will possibly need to alter a software patch package. This type of issue should be addressed as part of the implementation of this requirement.

(1) A patch list should be made available to the PE/O, through an interface commonly accepted by the industrial and security communities, including that identifies: 1) approved security patches applicable to Automation Solution software for which the Project is responsible (e.g. control system and component software, operating system software, and 3rd party software applications), 2) which of the applicable security patches have been approved for use in the Automation Solution, 3) the version numbers of the software to which the approved patches apply. This list shall be available to the PE/O within an agreed timeframe after the release of a patch by the manufacturer. The patch management document should include a description to the PE/O of how to electronically retrieve the patch list that describes the approved security patches that are applicable to components for which the Project is responsible. The patch list should be provided through a commonly accepted interface to allow the PE/O to know which patches it needs to download from the manufacturer or otherwise obtain. This list may be retrieved through this interface from the control system product supplier, from the Project, or from another agent identified by the Project. Approved is meant to imply that the patches have been tested and validated by the Project against a known configuration and no issues were found.

(2) If it is not permitted to install a security patch that could negatively impact the Automation Solution, it should: 1) recommend a mitigation plan when requested by the PE/O for security patches that were applicable and approved by the Project, but that were not approved by the PE/O, for example, because they could impact operations or performance (see SP 11.05 BR), 2) implement the mitigation plan after approval by the PE/O. It should develop and implement an approach to mitigate the impact of not being permitted

to install a security patch that could negatively impact the Automation Solution. This approach can include compensating mechanisms or other means to reduce the vulnerabilities addressed by the security patch. Alternative approaches should be subject to the approval of the PE/O.

4. The management of patches should provide for: 1) patches to be obtained by the PE/O directly from the manufacturer of the patch, and/or 2) redistribution of patches by the Project only if approved by the PE/O and permitted by the manufacturer of the patch. It should ensure that patches are obtained through an authorized channel (from an appropriate source) to reduce the possibility that they could be invalid/infected. The patch management document should include the patch delivery policy that supports having the PE/O obtain the patch directly from the patch manufacturer, or the Project at the request of the PE/O, and then only if the licensing agreements with the patch manufacturer permit this. If the patches are to be delivered by the project, then it should join with PE/O to decide how this will occur (e.g. DVD, secure connection).
5. The patch management documentation should include a description of how to perform patching both manually and via a patch management server and how to obtain patching status reports. 1) When using a patch management server, documentation shall be provided to show how to use the server to install patches. 2) For manual patching using portable media, documentation shall be provided that describes how to install patches from the media. It should provide instructions to the PE/O that describe how to install patches from portable media (e.g. CDs, DVDs, USB memory devices) and a patch management server.
6. The patch management process document shall include a process to obtain approval from the PE/O for installing every security patch. The patch should be installed if and only if the PE/O wants them to perform. The Configuration and Patch Management.xlsx file could be used as a checklist to validate approval of the asset owner for each patch installation.
7. The patch management process document shall include and ensure that, if the PE/O requests the Project to install security software patches (including firmware upgrades), the Project should install them at a time specified by the PE/O. The patch should be installed only when the PE/O wants it to be installed, for example, to prevent process upset if a device has to reboot after installation.
   (1) It should ensure that the security hardening level of the Automation

Solution is retained after patch installation. It should ensure that patch installation does not "undo" or otherwise degrade the hardening of the Automation Solution. The patch management process document shall include a process for restoring the hardening state of the Automation Solution if patch installation causes it to degrade (e.g. by reinstalling software or changing system configuration settings). After the patch, it should perform a vulnerability testing or hardening inspection to detect the degraded condition, and determine if this has happened, and if it has to restore the hardening.

(2) For devices that support the installation of software/firmware over the network, the update process should ensure the authenticity and integrity of the device software/firmware. The patches installed over the network should be authentic and have not been corrupted before or during the patching process. The patch management process should include a process for securely updating the software/firmware in devices. This includes allowing only authorized users to perform updates, and also ensuring that update images sent to devices are authentic (not counterfeit or corrupted) and are protected against corruption during the update process.

(3) The patch list document should include and determine the installation status of all security patches applicable to the Automation Solution for which the Project is responsible. The patch list document should be used for tracking whether patches approved for the Automation Solution have been installed to determine which patches are missing (not installed). The Configuration and Patch Management.xlsx file could be used to a templet of patch list document. This process can be provided with either manual procedures or automated tools.

7.4.1.12 Implement and document the Backup/Restore security if security control required.

If the Backup/Restore countermeasures are required in SuC, the practice of the Backup/Restore security should be implemented a centralized malware protection mechanism, if possible. An Acronis® tool could be used in the backup procedures, and the procedures of the Backup/Restore should be provided in the Security Functional Description Specifications (Annexes A.9). The user menus of these security solutions could be used as implementation guideline to provide these functionalities, and should be

integrated, set and inspected following requirements as minimum:

1. A document should be provided for recommended backup procedures for the Automation Solution. The content of the document could be in the Backup and Restore Procedure of Security Policies and Procedures and/or Security Functional Description Specification. This backup procedures document should include, but is not limited to the following:
   (1) Instructions on how to make a full backup of the Automation Solution, and partial backups, if applicable, using at least one of the following methods:
      - proprietary backup architecture on portable media,
      - single system backup architecture on portable media,
      - distributed backup architecture in which each backup system backs up a subset of the service provider's Automation Solutions at the PE/O's site, or
      - centralized backup architecture using one backup system for all of the service provider's Automation Solutions at the PE/O's site.
   (2) Provisions to back up the following types of data:
      - operation system files and cryptographic data (such as keying material),
      - applications (including middleware, such as tunneling software),
      - configuration data, database files,
      - log files, electronic logbook,
      - unconventional file types including, but not limited to, network equipment settings, control system controller settings (tuning parameters, set points, alarm levels),
      - field instrumentation parameters,
      - directory information,
      - other files identified by the Project that are required to create a complete backup of the Automation Solution.
   (3) Recommendations for offsite storage of backup media.
   (4) Provisions to ensure changes to the Automation Solution that could affect the integrity of a backup are not made while a backup is in progress.

   Examples of partial restores could include operating systems, application software, databases, and configuration files. The Acronis® tool could be used in the backup procedures.

   The backup procedures document should specify to the Automation Solution that defines how to back up the Automation Solution, which

data to backup to support full and partial backups, and how it recommends off-site storage to be handled. This documentation should recognize the following:

(1) The backup image is regarded as sensitive and can therefore be a target for security compromise.

(2) The backup can be necessary to recover from security incidents (e.g. a workstation becomes corrupted).

(3) The PE/O can have a backup strategy that is generally dependent on business requirements.

(4) The PE/O's backup strategy can include topics related to backup frequency, partial backups, when backups should be performed (e.g. before engineering changes), and recovery from infection that can influence the contents of the Project documentation.

(5) Backups should be allowed to be completed before changes are made that could interrupt the backup or that could cause inconsistencies in the backup data. Examples of such changes include engineering changes and patch installation.

2. It should provide documented instructions to the PE/O for restoring the Automation Solution or its components to normal operation. The content of the restore document could be in the Backup and Restore Procedure of Security Policies and Procedures and/or Security Functional Description Specification. The documentation should include instructions for handling abnormal scenarios, such as how to restore an Automation Solution whose architecture can have changed since the backup was made. In these cases, the restore can be incomplete and the PE/O should be made aware of conditions such as these. This requirement applies to both operational Automation Solutions and simulations.

3. It should provide documentation to the PE/O that describes how to control and securely manage portable backup media. The Backup and Restore Procedure document should include the description for handling and protection of backup data that is consistent with PE/O policies and procedures, or extensions of them. Backup data can be a target for compromise, for example, to prevent proper restoration or to gain access to confidential data.

4. It should provide documentation to the PE/O that describes how to verify successful system backup. The Backup and Restore Procedure document should include the description to verify the success of a backup.

5. It should provide documentation to the PE/O that describes how to demonstrate that: 1) it is possible to perform a complete backup of the

Automation Solution, and 2) it is possible to restore a fully functioning Automation Solution from this backup. The Backup and Restore Procedure document should include an identifiable process for demonstrating or otherwise verifying, that a backup can be performed successfully and that the Automation Solution can be restored from this backup. This process should be flexible to allow the PE/O to request only a partial backup/restore to gain confidence that the backup process can be used successfully. If the backup includes the backup of databases, then meeting this requirement also means that the Project has an identifiable process for demonstrating or otherwise verifying that automatic rollback is stopped/disabled before starting the backup. Automatic rollback can cause inconsistencies in the database should it occur while the database is being backed up.

6. It should have procedures to perform a backup of the Automation Solution in accordance with the PE/O's backup schedules and data restoration and disaster recovery objectives. The Backup and Restore Procedure document should include and adhere to the PE/O's backup/restore strategies and objectives, including backup schedules and disaster recovery plans. The intent of this requirement is to ensure that the Project is prepared to integrate its backup/restore activities with the PE/O's backup requirements.
7. It should test and demonstrate that the Automation Solution is able to continue normal operation during a backup. It should have an identifiable process or a test for demonstrating, or otherwise verifying, that the backup operations do not interfere with normal operations of the Automation Solution. For related system capability requirements, see IEC 62443-3-3.
8. It should provide documentation to the PE/O that describes how to generate and maintain audit logs of all backups and restore activities. The Backup and Restore Procedure document should include a description of how to manage audit logs for the backup and restore operations. These audit logs provide evidence of backup/restore activities such as when they occurred, who performed them, and their status. This document should also include a description of how to configure the Automation Solution to write backup and restore actions to an audit log.
9. A recommended disaster recovery plan document should be provided, and includes, but is not limited to, the following: 1) a description of various disaster scenarios and their impact on the Automation Solution, 2) step-by-step instructions for restoring, restarting failed components,

and integrating them into the Automation Solution, 3) minimum architecture requirement for restoring the entire Automation Solution. This plan should provide for recovering from a disaster that includes the details of how a disaster could occur (e.g. including cyber-security threats), and how to recover from the disaster. This plan provides an identifiable process for preparing a document specific to the Automation Solution that defines how to manage a major crisis based on a cyber-security scenario for restoring the Automation Solution and its components. The backup and the means of restoration cannot be compromised by the loss of the Automation Solution components or the entire Automation Solution. The means of restoration can include equipment, such as test benches or off-line development tools.

10. Backup and Restore Procedure: System/asset operating system, application/firmware, configuration settings, parameter settings, monitoring data, etc. backup, restore/restore procedures.

7.4.2 Review and Management of Implementation of system security countermeasures

The review process should be executed by the following steps:

1. Assign a content reviewer to check the quality, clarity, format, and completeness of the content of documents.
2. Assign a security reviewer (for example, qualified personnel in SAD) to check the validity of security content, their ability to be verified, and whether it is consistent with the requirements of Section 7.4.1. Annexes Table C.6 can be used to verify the completeness of the documents of System Security Measures, which is described in the Functional Description Specification.
3. After the documents are verified and checked, they should be submitted to PE/O for validation review, if applicable.
4. The approved documents should be managed by a version control of the CCM process (referred to Section [16]).
5. If there are any changes to the documents, the relevant information about the changes should be appropriately feedback, recorded, tracked, and managed (see Section 7.4.1). It should be reviewed and approved again, then checked into the CCM process with new version control for any modification to the software security requirements specification after use.

7.5 Perform Application Security Testing

Application security testing should be conducted in accordance with the requirements of Security Controls (Security Risk Mitigation Plan and Requirement Specifications - Functional Requirements), implementation of Security Countermeasures, and Security

Solution Integration Plan. It should base on the Security Solution Integration Plan to develop the Security Solution Integration testing Plan, and to inspect or test and record the results during SAT stage by following as a minimum:

1. Testing of the assurance security
   (1) Test and/or inspect the Vulnerability Management Procedures document (may be integrated into an IT/OT Security Functional Description Specification)
2. Testing of the network segmentation (architecture) security
   (1) It should test that wired and wireless workstations, including handhelds, used for maintenance and engineering of wired and wireless control/instrumentation devices are installed and configured to avoid security risks associated with the circumvention of:
      - The installed access controls in these devices should be tested. (e.g. Windows AD, Cisco RADIUS or Cisco TACACS+ setting and functions), if applicable.
      - The Communication security safeguards (e.g. network security devices) at the SuC boundary with Level 3 should be tested.
   (2) It should test the use of multi-factor authentication functions for SuC workstations as required by the PE/O or the Security Policies and Procedures Management Plan.
   (3) It should test the function of configuring the network device access controls scheme with the least privilege requirement. And test the functions of security measures to protect the confidentiality and integrity of data, in transit or at rest. Besides, the mutual authentication functions of communication devices should be tested to validate the identity of the user and the communication device, and results in the ability of the communication device to determine whether the user is authorized to access the device, and in the ability for the user to ensure the device is the intended device and is not being spoofed.
   (4) It should test the function of the access functions to the SuC's control actions and data flows in the SuC (e.g. between workstations and controllers), including the manual and/or automated controls and configuration changes, to ensure: 1) valid, 2) initiated or approved by an authorized user, and 3) transferred over an approved communication path in the approved direction.
   (5) It should test the security requirements (e.g. confidentiality, integrity, availability) for data storage points and data flows within the SuC, either at rest or in transit.
      - It shall test the access controls of the SuC to protect data within the SuC requiring safeguarding, from unauthorized disclosure or modification, whether at rest or in transit. Access control mechanisms used to protect data typically could include:

- It shall test or inspect the retention capabilities provided by the SuC for storing/archiving sensitive data.
- If cryptography is required, the system/device shall use cryptographic algorithms, including algorithms and key management/distribution/protection, they shall be tested with commonly accepted by both the security and industrial automation communities.

(6) It should be tested or inspected that communication architecture, including its use of network security devices or equivalent mechanisms, is implemented according to the Automation Solution design as specified and approved by the asset owner.

(7) It should be tested or inspected that the communication segments of the Automation Solution and their interfaces to other segments, including external networks, and for each interface designate whether it is trusted or untrusted.

(8) It should be tested or inspected that untrusted are protected by network communication security devices or equivalent mechanisms, and to document how these interfaces are protected, including Automation Solution specific security policies and rules.

(9) It should tested or inspect the vulnerabilities (vulnerability Scan)

(10) It should tested or inspect the implementation of communication protocols used in the Automation Solution that were known prior to Automation Solution integration or maintenance activities.

(11) It should be tested or inspected that time distribution/synchronization for the Automation Solution.

(12) It should be tested or inspected that only software and hardware features required by the Automation Solution or approved by the asset owner are enabled in the Automation Solution : 1) unnecessary software applications and services, 2) network addresses in use are authorized, 3) physical and logical access to diagnostic and configuration ports is protected from unauthorized access and use, 4) unused ports on network devices.

(13) It should tested or inspect the functions that only necessary, authorized, and documented Certificate Authority (CA) digital certificates are installed.

(14) It should be tested or inspected the functions of the Session locking functions : 1) prevents information on the logged-on user's display device from being viewed, 2) blocks input from the user’s input device (e.g. keyboard, mouse)until unlocked by the session user or an administrator.

3. Testing of the account management security

(1) Test that the account management system supports the following functions: 1)

has a single database that may be distributed or redundant, as determined by Automation Solution requirements, 2) allows accounts, including user, administrator/super user accounts, and service accounts (i.e. accounts that do not provide for interactive login), to be defined and managed for and by authorized users only, 3) allows administrators to manage accounts from a specified set of workstations/servers in the Automation Solution, not just from a single dedicated workstation, 4) distributes the enforcement of account access control lists and privileges to the location where the access or privilege is to be executed.

(2) Test or inspect that each Automation Solution user account is created and maintained unique accounts.
   - Inspect the account management document that: 1) identifies all default user and service accounts that are installed in the Automation Solution, 2) describes the tools and procedures the PE/O can use to set/reset passwords for all default user and service accounts. Inspect that the list of all user and service accounts and provide instructions to the PE/O that describe how to change their passwords should be generated.
   - Inspect that if an account/password is automatically generated for a user, other than operators and service groups, both the generated account and password should be unique.
   - Inspect that the service, auto-login, and operator accounts, and other accounts required for essential functions and/or continuous operations, or as required by the PE/O are configured permanent accounts in the Automation Solution so that they do not expire or become automatically disabled or deleted.
   - Inspect that the built-in administrator account should be disabled, and if that is not possible, that it should be renamed or otherwise made difficult to exploit.

(3) Inspect that unused system default accounts should be removed or disabled, including whether they are installed with the operating system or with the control system or related software, including unnecessary built-in accounts.

(4) Test and inspect that all user accounts should be removed once they are no longer needed, including 1) temporary accounts under the control of the Project, such as those used for integration or maintenance, 2) user accounts for the Project personnel who are no longer assigned to the Automation Solution.
   - Test or inspect that the audit log report after the completion of integration/maintenance activities that shows that accounts used to support these activities have been removed from the Automation Solution if they are no longer needed should be generated.

(5) Test the functions to configure password policies to achieve a minimum

complexity commonly accepted by both the security and industrial automation communities. The password policies should provide minimal password complexity: 1) at least eight characters in length, and 2) a combination of at least three of the following four-character sets: lowercase, uppercase, numeric digit, and special characters (e.g.% and #).

(6) Test the functions to configure passwords for local and system-wide (e.g. domain) user accounts to automatically expire after they have been in use for a period.

- Test functions to prompt users to change passwords N days before they expire, where N is specified by the PE/O. It should notify them that their passwords are expiring so they have time to change them.

(7) Test and/or inspect that the default passwords are changed as required by the PE/O, including after the process of installation, re-installation, and reset/recovery.

(8) Test and/or inspect the password policies to prevent users from reusing their last N passwords, where N is specified by the PE/O.

(9) Test and/or inspect the password policies to prevent users from changing their passwords more frequently than once every N days, where N is specified by the PE/O.

(10) Inspect and test that the secure document (could be a user account list) is created and keep this documentation current for accounts whose passwords have been approved by the PE/O to be shared with the Project, and include the given passwords for these accounts, including the subcontractors, consultants, and representatives.

- Inspect and/or test that once the passwords that were 1) shared and no longer need to be shared, 2) knowingly divulged, or 3) knowingly compromised are reported to the PE/O, and to support the PE/O in changing passwords as necessary.

4. Testing of the configuration management (CM)

(1) Test or inspect network architecture, the network architecture documentation (Network and Data Flow Diagram) should be maintained and updated to the latest. Network interfaces could be identified through a variety of techniques, including Ethernet addresses (i.e. media access control addresses), IP addresses, and network interface card identifiers. The intent is to provide enough information about them to unambiguously identify them.

(2) Test or inspect of the Inventory Asset List should be maintained and updated to the latest.

(3) The network architecture documentation (Network and Data Flow Diagram) should be inspected its documentation is up-to-date and describes the devices connected to each network segment in the Automation Solution.

5. Testing of the SuC's Asset Hardening
   (1) Test and/or inspect the security hardening document (may be integrated into an IT/OT Security Functional Description Specification) shall be created and maintained. The procedures shall be performed for the included control system/ components.
6. Testing of the wireless security if security control required
   (1) Test the following functions of the wireless systems: 1) data exchange to/from wireless instrumentation, 2) data exchange through a secure wireless link, 3) security mechanisms that prevent an intruder from gaining access to the Automation Solution using the wireless system, 4) security mechanisms that restrict access within the Automation Solution by workers with handheld wireless devices, 5) where required, security mechanisms that protect for remote management of wireless systems.
   (2) Test the protection functions of wireless access are configured to use wireless authentication and access control mechanisms that are commonly accepted.
   (3) Test the protection functions of wireless access are configured to protect wireless communications, and if cryptographic mechanisms are used for this purpose, they are commonly accepted by both the security and industrial automation communities.
   (4) Test the identifiers of the wireless network could not allow an external listener to identify the physical wireless network, its location, or the owner of the wireless network.
   (5) Test the wireless networks to be configured to prevent: 1) the use of unauthorized device addresses, and 2) interference with the assignment of device addresses, to ensure that wired and wireless devices that have IP addresses cannot have their addresses changed by dynamic address assignment mechanisms. The testing could be used by an AMS (asset management tool, e.g. OPSWAT-Neuralyzer) to verify.
7. Testing of the Safety Instrumented System (SIS) security if security control required
   (1) Test the configuration to protect safety communications and SIS safety functions from the BPCS or any other Automation Solution communications. Test the countermeasures taken to isolate functional safety communications do not impact the performance or operation of communications critical to safety.
   (2) Test the external communications (including remote access communications) to the Automation Solution cannot be able to interfere with the operation of the SIS.
   (3) Test applications (e.g. control system applications) external to the SIS shall not be able to participate in disrupting or otherwise interfere with SIS communications that are critical to safety functions. It should not have

communications critical to safety functions (e.g. data and/or commands) transferred between the SIS and applications residing external to the SIS.

(4) Test all communications between the SIS engineering workstation and Level 3 (and above) applications pass through a network security device, or an equivalent mechanism, that connects Level 2 and Level 3 (or above).

(5) Test or inspect the SIS engineering workstations within the SIS (1a) either should not have remote access installed or (1b) should be disabled (not accessible), and/or (2) have security mechanisms that block remote access communications with these workstations.

(6) Test or inspect the implementation of the gateway for all access to the Automation Solution's SIS from outside the SIS shall be mediated and authorized at the interface to the SIS.

(7) Test or inspect that SIS functions performed by the Automation Solution's SIS EWSs shall be protected from compromise by other SIS EWS software. Test or inspect that safety-related software running in SIS EWSs is protected from compromise from other software running in the SIS EWS.

(8) Test or inspect that Unauthorized wireless devices shall not be used as an integral part of SIS safety functions.

(9) Test the function to enable and disable SIS configuration mode. While disabled, this interface shall prohibit the SIS from being configured.

- Test or inspect the function process and/or procedure document to enable and disable a hardware implementation of the configuration mode interface required by SP.05.09 BR and to physically lock this hardware implementation while configuration mode is disabled.
- A verification test is performed by an independent 3rd party, to verify that it is not possible to change the configuration of the SIS when the hardware interface described in SP.05.09 RE (1) is locked in the "disable" configuration mode.

8. Testing of the remote access security if security control required

(1) Test that the remote access applications used in the Automation Solution shall be commonly accepted by both the security and industrial automation communities and provide acceptable levels of protection to the Automation Solution.

(2) Inspect the document for installation, configuration, operation, and termination of the remote access applications to be used in the Automation Solution.

(3) Test or inspect the information document about all proposed remote access connections to the PE/O that includes, for each connection: 1) its purpose, 2) the remote access application to be used, 3) how the connection will be established (e.g. via the Internet through a VPN), and 4) the location and

identity of the remote client. The inspection is to ensure that remote access to the Automation Solution is documented and managed to thwart unauthorized attempts to gain remote access to the Automation Solution.

(4) Inspect that all remote access connections to the Automation Solution are authorized by the PE/O. The requirements for remote access connections meet the countermeasure requirements of the TRA report.

(5) Test that the remote access connections are conducted over the Internet or over other publicly accessible media that are used to support remote access to the Automation Solution by the Project (e.g. from the Project facility). Test the protected links, such as VPNs.

9. Testing of the event management security if security control required

(1) Test the security incidents management from detection through disposition to allow the security risk position of the Automation Solution to be maintained. Inspect the procedure document for managing the security incidents in the Logging, Monitoring, and Reporting Procedure of Security Policies and Procedures and/or Security Functional Description Specification.

(2) Test the communications interface (agents or tools) to report security compromises that have been automatically detected shall be provided, should be accessible to the PE/O, and should be commonly accepted by both the security and industrial automation communities. Test security compromises can be automatically detected at the time of compromise or through subsequent event analysis and correlation activities.

(3) Test the audit log process configured to write and collect all security-related events, including user activities and account management activities, and shall be kept for the number of days specified by the PE/O or Security Policies and Procedures Management Plan.

- Test the security-related data and events that should be accessed through one or more interfaces that is/are commonly accepted by both the security and industrial automation communities.
- Test and verify that security-related events can be written to an audit log. Simulation tests the security-related events written to audit logs.

(4) Test the functions for logging and notifying the operator of process-related events as required by the PE/O. Test the types of events should include state changes/operating condition changes/configuration changes that can be due to manual or automated operation. Test the alarms and events to be logged and reported including both operating system events and control system alarms and events.

- Test or inspect the report alarms/alerts/events through an interface are securely that is commonly accepted by both the security and industrial

automation communities.

(5) Inspect the document provided to the PE/O that describes the Automation Solution's ability to withstand the near-simultaneous occurrence of large numbers of events, typically referred to as event storms. Robustness testing and stress testing should be performed to demonstrate this assurance.

10. Testing of the malware protection security to see if security control is required.

(1) Test and inspect the functions and instructions for the proper installation, configuration, and update of malware protection mechanisms. The malware protection mechanisms should be tested and verified for the Automation Solution.

(2) Test the implementation of that: 1) malware protection mechanisms have been correctly installed/updated and properly configured in accordance with the service provider's approved procedures, as agreed with the PE/O, 2) malware definition files are installed within the time period agreed to with the PE/O, 3) malware configurations are maintained and kept current.

- Inspect the content of the document (could be in the System Malware Protection Procedure of Security Policies and Procedures and/or Security Functional Description Specification) that describes the use of malware protection mechanisms in the Automation Solution. It shall include for each component used in the Automation Solution: 1) the installation state of malware protection mechanisms or a statement that it is not technically possible to install malware protection mechanisms on the component, 2) the current configuration settings of the installed malware protection mechanism, 3) the current status of malware definition files approved for installation on the component, 4) the use of other mitigating features and functions used to reduce the risk of infection and/or mitigate the effect of infections (e.g. isolating infections, reporting infections).

(3) It should be tested and verified, at PE/O request, that malware, other than zero-day malware, can be detected and properly handled by the installed malware protection mechanisms. Test that Malware, other than zero-day malware, should be detected and properly handled by the installed malware protection mechanisms. Possible verification methods include EICAR, IDS/IPS, and whitelisting tests.

(4) Inspect the content of the document that describes: 1) how malware definition files for the Automation Solution are evaluated and approved, 2) reporting the status of malware definition files to the PE/O within N days after release of the files by the manufacturer, where N has been agreed to by the Project and PE/O.

(5) Test that devices with detectable infections are not installed in the Automation Solution. It should verify/ensure that malware is not present in the equipment

provided by the Automation Solution. Verification can include checking the equipment for malware, installing software to the equipment at the site from malware-free media, and/or ensuring the supply chain provides malware-free equipment (e.g. the control system vendor performs malware scans before to delivery). See ISO/IEC 27036-3 for more information on supply chain security.

- Inspect for portable media that is used for system testing, commissioning, and/or maintenance, it should be used this portable media for this purpose only.
- Test and/or inspect that all portable media used in or connected to the Automation Solution by the Project should be free of known malware before use in the Automation Solution, and this portable media should not be connected to any workstation or server that is not part of the Automation Solution.

11. Testing of the Patch management security if security control required.

(1) Inspect the content of the patch management process document that describes the process of how security patches for Automation Solution software for which it is responsible are evaluated and approved. The document should include the process for verifying that new software security patches are compatible with the Automation Solution

- Inspect that the patch management process document includes a process for the PE/O to review, as a result of changes in security risks, how it evaluates and approves security patches for Automation Solution software for which it is responsible. It should include a process for evaluating and approving the security patches.
- Test and inspect that: 1) recommend a mitigation plan when requested by the PE/O for security patches that were applicable and approved by the Project, but that were not approved by the PE/O, 2) implement the mitigation plan after approval by the PE/O.

(2) Test and/or inspect the patch management process document shall include the process to inform PE/O about the description of security patches/updates. The process shall include making the description of each patch available to the PE/O within a time frame after the release of a patch by its manufacturer that is acceptable to the PE/O. The informing documentation shall include 1) security patches that apply to components of the Automation Solution for which the Project is responsible, 2) the approval status/lifecycle state (see IEC TR 62443-2-3) of each, i.e., approved, not approved, not applicable, in test, 3) a warning if the application of an approved patch requires or causes a re-start of the system, 4) the reason for those that are not approved or not applicable, 5) a plan for the remediation for those that are applicable but not approved.

- Test and/or inspect that the patch list should be made available to the PE/O, through an interface commonly accepted by the industrial and security communities, including that identifies: 1) approved security patches applicable to Automation Solution software for which the Project is responsible (e.g .control system and component software, operating system software, and 3rd party software applications), 2) which of the applicable security patches have been approved for use in the Automation Solution, 3) the version numbers of the software to which the approved patches apply.

(3) Test and/or inspect that the management of patches should provide for 1) patches to be obtained by the PE/O directly from the manufacturer of the patch, and/or 2) redistribution of patches by the Project only if approved by the PE/O and permitted by the manufacturer of the patch.

(4) Test and/or inspect the patch management documentation that describes how to perform patching both manually and via a patch management server and how to obtain patching status reports. 1) When using a patch management server, documentation shall be provided to show how to use the server to install patches. 2) For manual patching using portable media, documentation shall be provided that describes how to install patches from the media.

(5) Inspect the patch management process document shall include a process to obtain approval from the PE/O for installing every security patch.

(6) Inspect the patch management process document including that, if the PE/O requests the Project to install security software patches (including firmware upgrades), the Project should install them at a time specified by the PE/O.

- Test and/or inspect that the security hardening level of the Automation Solution is retained after patch installation. After the patch, it should perform a vulnerability testing or hardening inspection to detect the degraded condition, and determine if this has happened, and if it has to restore the hardening.
- Test and/or inspect that support installation of software/firmware over the network, the update process should ensure the authenticity and integrity of the device software/firmware.
- Test and/or inspect that the patch list document includes and determines the installation status of all security patches applicable to the Automation Solution, including tracking whether patches are approved with either manual procedures or automated tools.

12. Testing of the Backup/Restore security if security control required

(1) Inspect the content of the backup procedures including, but not limited to the following:

- Instructions on how to make a full backup of the Automation Solution, and partial backups, if applicable,
- Provisions to back up the following types of data:
- Recommendations for offsite storage of backup media.
- Provisions to ensure changes to the Automation Solution that could affect the integrity of a backup are not made while a backup is in progress.

Test the backup procedures that:

- The backup image is regarded as sensitive.
- The backup can be necessary to recover from security incidents (e.g. a workstation becomes corrupted).
- The PE/O can have a backup strategy that is generally dependent on business requirements.
- The PE/O's backup strategy can include topics related to backup frequency, partial backups, when backups should be performed (e.g. prior to engineering changes), and recovery from infection that can influence the contents of the Project documentation.
- Backups should be allowed to complete before changes are made that could interrupt the backup or that could cause inconsistencies in the backup data. Examples of such changes include engineering changes and patch installation.

(2) Test and/or inspect the instructions for restoring the Automation Solution or its components to normal operation. The test should include instructions for handling abnormal scenarios, such as how to restore an Automation Solution whose architecture can have changed since the backup was made.

(3) Test and/or inspect that describes how to control and securely manage portable backup media.

(4) Test and/or inspect that describes how to verify successful system backup.

(5) Test and/or inspect and demonstrate that: 1) it is possible to perform a complete backup of the Automation Solution, and 2) it is possible to restore a fully functioning Automation Solution from this backup.

(6) Test and/or inspect that in accordance with the PE/O's backup schedules and data restore and disaster recovery objectives.

(7) Test and demonstrate that the Automation Solution can continue normal operation during a backup.

(8) Test and/or inspect that describes how to generate and maintain audit logs of all backups and restore activities.

(9) Test and/or inspect the disaster recovery plan: 1) description of various disaster scenarios and their impact on the Automation Solution, 2) step-by-step instructions for restoring, restarting failed components, and integrating them into

the Automation Solution, 3) minimum architecture requirement for restoring the entire Automation Solution.

7.6 Practices for System security acceptance testing process

7.6.1 Perform System security acceptance testing process and Documentation

System security acceptance testing should be conducted in accordance with the requirements of OT Security Inspection and Test Protocol, and should be inspected or tested by following as minimum:

1. OT Security FAT Test
   (1) In the FAT test stage, it shall use security analysis tools to discover undocumented and/or unauthorized systems or vulnerabilities in the assets, including:
      - Use security analysis tools (e.g Neuralyzer) that can be used to discover hidden devices (IP addresses). Annexes A.12 can be used to document the Vulnerability Scanning Report.
      - Use the security analysis tools (e.g Nessus) that it can use to discover vulnerabilities for example undocumented open TCP/UDP ports.
      - Any newly found vulnerabilities should follow the vulnerability management process (7.1.1.4 2.) to mitigate security weaknesses.
   (2) The security hardening on the included control system/ components shall be verified that its security hardening guidelines and procedures are followed.
   (3) Inspection and Test Protocol (ITP) procedures related to the FAT test.
      - Threat Mitigation Test: Check and inspect the measures or countermeasures implemented to mitigate the threat and test the resilience of these implemented measures or countermeasures. It is tested and/or inspected, and the function descriptions are documented (refer to 7.6.1 2). It may include tests for security solutions for countermeasures (AD, Backup/Restore, AV, Log collector, AMS, IDS)
      - Perform or Check Weakness Detection and Vulnerability Testing (refer to 7.4.1.1 2.)
      - Verify the Threat Mitigation and Vulnerability Testing test reports or records for compliance with IEC 62443-2-4 requirements (refer to 7.6.1.1. (1).)
      - perform security function requirements test related to IEC 62443-3-3 requirements.
      - Verify the function test reports related to IEC 62443-3-3 requirements (It could be checked the certificate of asset or function

test report that is provided by the asset vendor)

2. Security Inspection

The Security Policies and Procedures and/or Security Functional Description Specification, and Security Solution Integration and function test records should be inspected and reviewed after SAT or during SIT stage for validation. The inspection should be included but not limited to,

(1) Inspection of the assurance security

[1]. Check that the Vulnerability Management Procedures have been tested and/or inspected, and the function descriptions are documented.

(2) Inspection of the network segmentation (architecture) security

[1]. Check the time distribution/synchronization setting for the SuC's assets: 1) are performed from a secure and accurate source, and 2) use a protocol that is commonly accepted by both the security and industrial automation communities and should be set to a same time server IP address, if applicable.

[2]. Check the reducing the attack surface of the SuC, including: 1) Limiting the software applications and their associated communication access points, USB devices such as mass storage devices, and wireless communications capabilities to only those necessary to perform the functions of a device used in both normal and emergency operations reduce the number of avenues into the device for an attack. 2) Identifying unnecessary and/or unauthorized access points (e.g. using network scanning tools) is one technique that can be used to discover unnecessary software programs. 3) Identifying network addresses that are unauthorized, for example using network scans as described in SP.02.02 RE (2) and removing them (e.g. by disconnecting the devices to which they are assigned) limits the source of passive and active attack. 3) Controlling access to physical configuration ports of devices, such as serial ports are intended to prevent or reduce the risk of having the network configuration (network devices) or the operation of other devices changed without proper authorization. 4) Different methods for controlling access include installing a device in a locked cabinet, being able to physically lock the configuration port, or otherwise disabling use of the port when its use is not authorized (e.g. through a software lock). 5)Locking down network device ports (switches and routers) reduces the possibility that an unauthorized device will be able to connect to the network and launch attacks or sniff the network. 6) Control system products can have capabilities unused by them

removed prior to or during installation, making it necessary for the Project to ensure that they are added/enabled only if they are required and approved by the PE/O.

[3]. Check the limitation of only necessary, authorized, and documented Certificate Authority (CA) digital certificates are installed. Check the CA certificates, including CA certificates used for self-signing, are installed, and remove those that are not used/authorized by the PE/O.

[4]. Check the session locking function and setting for SuC's workstations as required by the PE/O.

[5]. Check that the installed access controls and the configured Communication security safeguards are tested, and the function descriptions are documented.

[6]. Check that the installed multi-factor authentication functions for SuC workstations are tested, and the function descriptions are documented.

[7]. Check that the configuring the network device access controls scheme with least privilege, the functions of security measures to protect the confidentiality and integrity of data, in transit or at rest, and the mutual authentication functions of communication devices. it has been tested, and the function descriptions are documented.

[8]. Check that the function of the access functions to the SuC's control actions and data flows in the SuC are tested, and the function descriptions are documented, include: 1) valid, 2) initiated or approved by an authorized user, and 3) transferred over an approved communication path in the approved direction.

[9]. Check that the function of the security requirements (e.g. confidentiality, integrity, availability) for data storage points and data flows within the SuC, either at rest or in transit. it has been tested, and the function descriptions are documented.

[10]. Check that the function of the access controls of the SuC to protect data within the SuC requiring safeguarding are tested, and the function descriptions are documented.

[11]. Check that the function of the retention capabilities provided by the SuC for storing/archiving sensitive data are tested or inspected, and the function descriptions are documented.

[12]. If cryptographic mechanisms are used, check that the function are tested with commonly accepted by both the security and industrial automation communities, and the function descriptions are documented.

[13]. Check that communication architecture, including its use of network

security devices or equivalent mechanisms, is implemented according to the Automation Solution design as specified and approved by the asset owner, are tested or inspected, and the function descriptions are documented.

[14]. Check that the communication segments of the Automation Solution and their interfaces to other segments, including external networks, are tested or inspected, and the function descriptions are documented, and for each interface designate whether it is trusted or untrusted.

[15]. Check that untrusted are protected by network communication security devices or equivalent mechanisms, and to document how these interfaces are protected, including Automation Solution specific security policies and rules, are tested or inspected, and the function descriptions are documented.

[16]. Check the vulnerabilities (vulnerability Scan) , are tested or inspected, and the function descriptions are documented

[17]. Check the implementation of communication protocols used in the Automation Solution that were known prior to Automation Solution integration or maintenance activities, are tested or inspected, and the function descriptions are documented.

[18]. Check that time distribution/synchronization for the Automation Solution, are tested or inspected, and the function descriptions are documented.

[19]. Check that only software and hardware features required by the Automation Solution or approved by the asset owner are enabled in the Automation Solution : 1) unnecessary software applications and services, 2) network addresses in use are authorized, 3) physical and logical access to diagnostic and configuration ports is protected from unauthorized access and use, 4) unused ports on network devices, are tested or inspected, and the function descriptions are documented.

[20]. Check the functions that only necessary, authorized, and documented Certificate Authority (CA) digital certificates are installed, are tested or inspected, and the function descriptions are documented.

[21]. Check the functions of the Session locking functions : 1) prevents information on the logged-on user's display device from being viewed, 2) blocks input from the user’s input device (e.g. keyboard, mouse)until unlocked by the session user or an administrator, are tested or inspected, and the function descriptions are documented.

(3) Inspection of the account management security

[1]. Check that the account management system supports the following

functions are tested, and the function descriptions are documented: 1) has a single database that may be distributed or redundant, as determined by Automation Solution requirements, 2) allows accounts, including user, administrator/super user accounts, and service accounts (i.e. accounts that do not provide for interactive login), to be defined and managed for and by authorized users only, 3) allows administrators to manage accounts from a specified set of workstations/servers in the Automation Solution, not just from a single dedicated workstation, 4) distributes the enforcement of account access control lists and privileges to the location where the access or privilege is to be executed.

[2]. Check that each Automation Solution user account is created and maintained uniquely tested or inspected, and the function descriptions and user account information are documented.

[3]. Check that the account management document: 1) identifies all default user and service accounts that are installed in the Automation Solution, 2) describes the tools and procedures the PE/O can use to set/reset passwords for all default user and service accounts. Inspect that the list of all user and service accounts and provide instructions to the PE/O that describe how to change their passwords should be generated. It has been inspected and documented.

[4]. Check that if an account/password is automatically generated for a user, other than operators and service groups, both the generated account and password should be unique, inspected, and documented.

[5]. Check that the service, auto-login, operator accounts, and other accounts required for essential functions and/or continuous operations, or as required by the PE/O are configured permanent accounts in the Automation Solution so that they do not expire or become automatically disabled or deleted. It has been inspected and documented.

[6]. Check that the built-in administrator account should be disabled, and if that is not possible, that it should be renamed or otherwise made difficult to exploit. It has been inspected and documented.

[7]. Check that unused system default accounts should be removed or disabled, including whether they are installed with the operating system or with the control system or related software, including unnecessary built-in accounts. It has been inspected and documented.

[8]. Check that all user accounts should be removed once they are no longer needed, including 1) temporary accounts under the control of

the Project, such as those used for integration or maintenance, 2) user accounts for the Project personnel who are no longer assigned to the Automation Solution., are tested or inspected, and the function descriptions are documented. Check that the audit log report after the completion of integration/maintenance activities that shows that accounts used to support these activities have been removed from the Automation Solution if they are no longer needed should be generated, tested, or inspected, and the function descriptions are documented.

[9]. Check that the functions to configure password policies to achieve a minimum complexity are commonly accepted by both the security and industrial automation communities. The password policies should provide minimal password complexity: 1) at least eight characters in length, and 2) a combination of at least three of the following four-character sets: lowercase, uppercase, numeric digit, and special characters (e.g.% and #), are tested, and the function descriptions are documented.

[10]. Check that the functions to configure passwords for local and system-wide (e.g. domain) user accounts automatically expire after they have been in use for a period of time. it has been tested, and the function descriptions are documented. −Check that the functions prompt users to change passwords N days before they expire, where N is specified by the PE/O. It should notify them that their passwords are expiring so they have time to change them. it has been tested, and the function descriptions are documented.

[11]. Check that the default passwords are changed as required by the PE/O, are tested and/or inspected, and the function descriptions are documented.

[12]. Check that the password policies (1) prevent users from reusing their last N passwords, where N is specified by the PE/O, (2) prevent users from changing their passwords more frequently than once every N days, where N is specified by the PE/O, are tested and/or inspected, and the function descriptions are documented.

[13]. Check that the secure document (could be an user account list) is created and keep this documentation current for accounts whose passwords have been approved by the PE/O to be shared with the Project, and include the given passwords for these accounts, including the subcontractors, consultants, and representatives. it has been tested and/or inspected.

[14]. Check that once the passwords that were 1) shared and no longer need to be shared, 2) knowingly divulged, or 3) knowingly compromised are reported to the PE/O and support the PE/O in changing passwords as necessary. it has been inspected and/or tested.

(4) Inspection of the configuration management (CM)

[1]. Check that the network architecture and the network architecture documentation (Network and Data Flow Diagram) should be maintained and updated to the latest. It has been tested or inspected and kept up-to-date.

[2]. Check that the Inventory Asset List is tested or inspected and keep updating.

[3]. The network architecture documentation (Network and Data Flow Diagram) and Inventory Asset List shall be verified that wired and wireless devices used for control and instrumentation have been configured correctly with their approved values. The integrity of device configurations should be verified to detect unauthorized or erroneous configuration changes. The configuration parameter values could be confirmed by viewing them from a workstation.

(5) Inspection of the SuC's Asset Hardening

[1]. Check that the security hardening document (may be integrated into an IT/OT Security Functional Description Specification) shall be created and maintained. It has been tested and/or inspected, and the function descriptions are documented.

(6) Inspection of the wireless security if security control required

[1]. Check that the following functions of the wireless system are tested or inspected, and the function descriptions are documented: 1) data exchange to/from wireless instrumentation, 2) data exchange through a secure wireless link, 3) security mechanisms that prevent an intruder from gaining access to the Automation Solution using the wireless system, 4) security mechanisms that restrict access within the Automation Solution by workers with handheld wireless devices, 5) where required, security mechanisms that provide protection for remote management of wireless systems.

[2]. Check that the protection functions of wireless access are tested or inspected and that the function descriptions are documented. Check the correctness of the access control lists.

[3]. Check that the protection functions of wireless access are configured to protect wireless communications are tested or inspected, and the function descriptions are documented.

[4]. The wireless technology used is compliant with local regulations.

[5]. Inspecting the test record of the testing of identifiers of the wireless network could not allow an external listener to identify the physical wireless network, its location, or the owner of the wireless network. Inspect each wireless network and assign its unique identifier (e.g. SSID) both in the device and inventory asset list document.

[6]. Inspect the test record of the wireless networks to be configured to prevent: 1) the use of unauthorized device addresses, 2) interference with the assignment of device addresses, and that wired and wireless devices that have IP addresses cannot have their addresses changed by dynamic address assignment mechanisms. Inspection of the SuC's wireless device addresses is configured and corrected assignment both in the device and inventory asset list document.

(7) Inspection of the Safety Instrumented System (SIS) security if security control is required.

[1]. Check that security risk assessments of the communications of the SIS used in the SuC have been conducted and addressed. Check that the security of SIS communications, both internal and external, identified by risk assessments/security reviews have been implemented and addressed.

[2]. Check the configuration to protect safety communications and SIS safety functions from the BPCS or any other Automation Solution communications. Check the countermeasures taken to isolate functional safety communications do not impact the performance or operation of communications critical to safety are tested or inspected, and the function descriptions are documented.

[3]. Check the external communications (including remote access communications) to the Automation Solution cannot be able to interfere with the operation of the SIS are tested, and the function descriptions are documented.

[4]. Check the applications (e.g. control system applications) external to the SIS shall not be able to participate in disrupt or otherwise interfere with SIS communications that are critical to safety functions, and no communications critical to safety functions (e.g. data and/or commands) transferred between the SIS and applications residing external to the SIS are tested, and the function descriptions are documented.

[5]. Check all communications between the SIS engineering workstation and Level 3 (and above) applications pass through a network security

device, or equivalent mechanism, that connects Level 2 and Level 3 (or above) are tested, and the function descriptions are documented, to ensure that only authorized communications from Level 3 applications to SIS engineering workstations residing outside the SIS are permitted.

[6]. Check the SIS engineering workstations within the SIS (1a) either should not have remote access installed or (1b) should be disabled (not accessible), and/or (2) have security mechanisms that block remote access communications with these workstations are tested or inspected, and the function descriptions are documented.

[7]. Check the implementation of gateway for all access to the Automation Solution's SIS from outside the SIS shall be mediated and authorized at the interface to the SIS are tested or inspected, and the function descriptions are documented.

[8]. Check the protection for Safety-related software running in SIS EWSs from compromise from other software running in the SIS EWS are tested or inspected, and the function descriptions are documented.

[9]. "Unauthorized wireless devices shall not be used as an integral part of SIS safety functions" are tested or inspected, and the function descriptions are documented.

[10]. The function to enable and disable SIS configuration mode is tested, and the function descriptions are documented. To enable and disable a hardware implementation of the configuration mode interface required by SP.05.09 BR and to physically lock this hardware implementation while configuration mode is disabled are tested or inspected, and the function descriptions are documented. Check the verification test that it is not possible to change the configuration of the SIS when the hardware interface described in SP.05.09 RE (1) is locked in the "disable" configuration mode, which is performed by an independent 3rd party.

(8) Inspection of the remote access security, if applicable

[1]. The remote access applications used in the Automation Solution are tested or inspected to provide acceptable levels of protection to the Automation Solution, and the function descriptions are documented.

[2]. The installation, configuration, operation, and termination of the remote access applications to be used in the Automation Solution are tested or inspected, and the function descriptions are documented.

[3]. The information document about all proposed remote access connections to the PE/O is tested or inspected, and the function

descriptions are documented.

[4]. Check that all remote access connections to the Automation Solution are authorized by the PE/O inspected and the function descriptions are documented.

[5]. The remote access connections conducted over the Internet or over other publicly accessible media that are used to support remote access to the Automation Solution by the Project (e.g. from the Project facility), and the protected links, such as VPNs are tested or inspected, and the function descriptions are documented.

(9) Inspection of the event management security if security control required.

[1]. Check that the security incidents management from detection through disposition to allow the security risk position of the Automation Solution to be maintained are tested. Check the procedure document for managing the security incidents in the Logging, Monitoring, and Reporting Procedure of Security Policies and Procedures and/or Security Functional Description Specification are inspected.

[2]. Check that the communications interface (agents or tools) to report security compromises that have been automatically detected shall be provided and should be accessible to the PE/O and should be commonly accepted by both the security and industrial automation communities and the security compromises can be automatically detected at the time of compromise or through subsequent event analysis and correlation activities. it has been tested, and the function descriptions are documented.

[3]. Check that the audit log process is configured to write and collect all security-related events, including user activities and account management activities, and shall be kept for the number of days are tested, and the function descriptions are documented.

[4]. Check that the security-related data and events should be accessed through one or more interfaces that is/are commonly accepted by both the security and industrial automation communities are tested, and the function descriptions are documented.

[5]. Check and verify that security-related events can be written to an audit log, and the simulation tests the security-related events written to audit logs. it has been tested, and the function descriptions are documented.

[6]. Check that the functions for logging and notifying the operator of process-related events as required by the PE/O, the types of events should include state changes/operating condition

changes/configuration changes that can be due to manual or automated operation, and the alarms and events to be logged and reported include both operating system events and control system alarms and events. it has been tested, and the function descriptions are documented.

[7]. Check that the report alarms/alerts/events through an interface are securely that is commonly accepted by both the security and industrial automation communities are tested or inspected, and the function descriptions are documented.

[8]. Check that the document (the Logging, Monitoring, and Reporting Procedure of Security Policies and Procedures and/or Security Functional Description Specification) is provided to the PE/O that describes the Automation Solution's ability to withstand the near-simultaneous occurrence of large numbers of events, and the Robustness testing and stress testing are performed to demonstrate this assurance.

(10) Inspection of the malware protection security if security control required.

[1]. Check the functions and instructions for the proper installation, configuration, and update of malware protection mechanisms. It should be tested, inspected, and verified, and the function descriptions are documented.

[2]. Check the implementation of that: 1) malware protection mechanisms have been correctly installed/updated and properly configured in accordance with the service provider's approved procedures, as agreed with the PE/O, 2) malware definition files are installed within the time period agreed to with the PE/O, 3) malware configurations are maintained and kept current. It should be tested, and verified, and the function descriptions should be documented.

[3]. Check the document (could be in the System Malware Protection Procedure of Security Policies and Procedures and/or Security Functional Description Specification) describes the use of malware protection mechanisms in the Automation Solution. It shall be created and inspected, and the function descriptions will be documented.

[4]. Check that malware, other than zero-day malware, can be detected and properly handled by the installed malware protection mechanisms. It has been tested and verified, and the function descriptions are documented.

[5]. Check the document that describes: 1) how malware definition files for the Automation Solution are evaluated and approved, 2) reporting

the status of malware definition files to the PE/O within N days after release of the files by the manufacturer, where N has been agreed to by the Project and PE/O. It should be created and inspected, and the function descriptions are documented.

[6]. Check that devices with detectable infections are not installed in the Automation Solution, and that malware is not present in equipment provided by it to the Automation Solution, have been tested, verified, and the function descriptions are documented.

[7]. Portable media that it used for system testing, commissioning, and/or maintenance, it should be used this portable media for this purpose only. Check that they are configured and inspected, and the descriptions are documented.

[8]. Check that all portable media used in or connected to the Automation Solution by the Project are free of known malware prior to use in the Automation Solution, and this portable media should not be connected to any workstation or server that is not part of the Automation Solution. They have been tested and/or inspected, and the descriptions are documented.

(11) Inspection of the Patch management security if security control required.

[1]. Check the content of the patch management process document that describes the process of how security patches for Automation Solution software for which it is responsible are evaluated and approved. It has been inspected, and the process descriptions should be documented.

[2]. Check that the patch management process document includes a process for the PE/O to review, as a result of changes in security risks, how it evaluates and approves security patches for Automation Solution software for which it is responsible. It should include the process for evaluating and approving the security patches.

[3]. Check that the patch management process document includes the process to inform PE/O about the description of each patch available to the PE/O within a time frame after the release of a patch by its manufacturer that is acceptable to the PE/O, and include: 1) security patches that are applicable to components of the Automation Solution for which the Project is responsible, 2) the approval status/lifecycle state (see IEC TR 62443-2-3) of each, i.e., approved, not approved, not applicable, in test, 3) a warning if the application of an approved patch requires or causes a re-start of the system, 4) the reason for those that are not approved or not applicable, 5) a plan for the

remediation for those that are applicable but not approved. It has been tested and/or inspected, and the process descriptions are documented.

[4]. Check that the patch list is made available to the PE/O, through an interface commonly accepted by the industrial and security communities. It has been tested and/or inspected, and the process descriptions are documented.

[5]. Check that: 1) recommend a mitigation plan when requested by the PE/O for security patches that were applicable and approved by the Project, but that were not approved by the PE/O, 2) implement the mitigation plan after approval by the PE/O. It has been tested and/or inspected, and the process descriptions are documented.

[6]. Check that the management of patches should provide for 1) patches to be obtained by the PE/O directly from the manufacturer of the patch, and/or 2) redistribution of patches by the Project only if approved by the PE/O and permitted by the manufacturer of the patch. It has been tested and/or inspected, and the process descriptions are documented.

[7]. Check that the patch management documentation is included that describes how to perform patching both manually and via a patch management server and how to obtain patching status reports. 1) When using a patch management server, documentation shall be provided to show how to use the server to install patches. 2) For manual patching using portable media, documentation shall be provided that describes how to install patches from the media. It has been tested and/or inspected, and the instructions are documented.

[8]. Check that the patch management process document includes a process to obtain approval from the PE/O for installing every security patch, is inspected, and the process descriptions are documented.

[9]. Check that the patch management process document includes that if the PE/O requests the Project to install security software patches (including firmware upgrades), the Project should install them at a time specified by the PE/O. It is inspected, and the process descriptions are documented.

[10]. Check that the security hardening level of the Automation Solution is retained after patch installation. After the patch, it should perform a vulnerability testing or hardening inspection to detect the degraded condition, and determine if this has happened, and if it has to restore the hardening. It has been tested and/or inspected, and the process descriptions are documented.

[11]. Check that support installation of software/firmware over the network, the update process should ensure the authenticity and integrity of the device software/firmware. It has been tested and/or inspected, and the process descriptions are documented.

[12]. Check that the patch list document includes and determines the installation status of all security patches applicable to the Automation Solution, including tracking whether patches are approved with either manual procedures or automated tools. It has been tested and/or inspected, and the process descriptions are documented.

(12) Inspection of the Backup/Restore security if security control required.

[1]. Check that the content of the backup procedures documents is inspected, the functions of backup procedures are tested, and the use and process descriptions are documented.:

[2]. Check that the instructions for restoring the Automation Solution or its components to normal operation, are tested and/or inspected, and the process and instruction descriptions are documented.

[3]. Check that describes how to control and securely manage portable backup media are tested and/or inspected, and the process and instruction descriptions are documented.

[4]. Check that describes how to verify successful system backups are tested and/or inspected, and the process and descriptions are documented.

[5]. Check that: 1) it is possible to perform a complete backup of the Automation Solution, and 2) it is possible to restore a fully functioning Automation Solution from this backup. It has been tested and/or inspected, and the process and descriptions are documented.

[6]. Check that in accordance with the PE/O’s backup schedules and data restore and disaster recovery objectives, are tested and/or inspected, and the process and descriptions are documented.

[7]. Check that the Automation Solution is able to continue normal operation during a backup tested and/or demonstrated, and the process and descriptions are documented.

[8]. Check that describes how to generate and maintain audit logs of all backups and restore activities that are tested and/or inspected, and the process and descriptions are documented.

[9]. Check that the disaster recovery plan: 1) a description of various disaster scenarios and their impact on the Automation Solution, 2) step-by-step instructions for restoring, and restarting failed components and integrating them into the Automation Solution, 3)

minimum architecture requirement for restoring the entire Automation Solution, are tested and/or inspected.

3. OT Security SAT Test
   (1) In SAT test stage, it shall use security analysis tools to discover undocumented and/or unauthorized systems or vulnerabilities in the SuC, including:
      - Use security analysis tools (e.g Neuralyzer) that can be used to discover hidden devices (IP addresses). Annexes A.12 can be used to document the Vulnerability Scanning Report.
      - Use the security analysis tools (e.g Nessus) that it can use to discover vulnerabilities for example undocumented open TCP/UDP ports.
      - To ensure that these tools can be used only at times approved by the PE/O and in a way that is consistent with PE/O practices.
      - Any newly found vulnerabilities should follow the vulnerability management process (7.1.1.4-2.) to mitigate security weaknesses.
   (2) The security hardening on the included control system/ components shall be verified that its security hardening guidelines and procedures are followed. The verification of security hardening shall be performed for the PE/O or Employer to verify that its hardening guidelines are followed.
   (3) A verification check if approved network segmentation is implemented and verified according to the approved network and data flow diagram designed by the PE/O.
   (4) Threat Mitigation Test: Test and check the measures or countermeasures implemented to mitigate the threat and test the resilience of these implemented measures or countermeasures. It is tested and/or inspected, and the function descriptions are documented (refer to 7.4.1 and 7.6.1-2.). It may include tests for security solutions for countermeasures (AD, Backup/Restore, AV, Log collector, AMS, IDS)
   (5) Penetration Testing: Penetration testing is a cybersecurity test used to determine how intrusion testers simulate real-world attacks to circumvent a system or cybersecurity function. Penetration testing is designed to demonstrate the resilience of SuC to identify threats and risks.
   (6) Inspect and verify according to the Inspection and Test Protocol (ITP), and to inspect or test the Security Solution Integration test procedures. Verify and check the Policies and Procedures Integration and Hardening settings which comply with IEC 62443-2-4 requirements.
4. Cooperate with the owner’s request to support the OT Security SIT Test
   (1) Penetration Testing with PE/O’s assignment: Penetration testing is a cybersecurity test used to determine how intrusion testers simulate real-

world attacks to circumvent a system or cybersecurity function. Penetration testing is designed to demonstrate the resilience of SuC to identified threats and risks.

(2) Assist the PE/O in performing the test according to the Inspection and Test Protocol.

(3) IEC 62443-2-4 Compliance Verification inspection, and validate the 7.6.1 2. Security Inspection.

7.6.2 Review and Management of System security acceptance testing process.

The review process should be executed by the following steps:

1. Assign a content reviewer to check the quality, clarity, format, and completeness of the content of documents.
2. Assign a security reviewer (for example, qualified personnel in SAD) to check the validity of security content, their ability to be verified, and whether it is consistent with the requirements of Section 7.6.1. Annexes Table C.7. can be used to verify the completeness of the system security acceptance testing process.
3. The network architecture documentation (Network and Data Flow Diagram) and Inventory Asset List shall verify that wired and wireless devices used for control and instrumentation have been configured correctly with their approved values. After the documents are verified and checked, they should be submitted to PE/O for validation review, if applicable.
4. The approved documents should be managed by a version control of the CCM process (referred to Section [16]).
5. If there are any changes to the documents, the relevant information about the changes should be appropriately feedback, recorded, tracked, and managed (see Section 7.6.1). It should be reviewed and approved again, then checked into the CCM process with new version control for any modification to the software security requirements specification after use.

7.7 Practices for Operations and support/maintenance stages

7.7.1 Regular security testing and/or evaluation

- It shall use security analysis tools to discover undocumented and/or unauthorized systems or vulnerabilities in the SuC, including Use of security analysis tools (e.g Neuralyzer) that can be used to discover hidden devices (IP addresses)
- Use the security analysis tools (e.g Nessus) that can discover vulnerabilities for example undocumented open TCP/UDP ports.
- To ensure that these tools can be used only at times approved by the PE/O and

in a way that is consistent with PE/O practices.

- Any newly found vulnerabilities should follow the vulnerability management process (7.1.1.4-2.) to mitigate security weaknesses.

7.7.2 Review and Management of Operation and Support/Maintenance

The review process should be executed by the following steps:

1. Assign a content reviewer to check the quality, clarity, format, and completeness of the content of documents.
2. Assign a security reviewer (for example, qualified personnel in SAD) to check the validity of security content, their ability to be verified, and whether it is consistent with the requirements of Section 7.7.1. Annexes Table C.8. can be used to verify the completeness of the Operation and Support/Maintenance process.
3. After the documents are verified and checked, they should be submitted to PE/O for validation review, if applicable.
4. The approved documents should be managed by a version control of the CCM process (referred to Section 7.4.1.4).
5. If there are any changes to the documents, the relevant information about the changes should be appropriately feedback, recorded, tracked, and managed (see Section 7.7.1). It should be reviewed and approved again, then checked into the CCM process with new version control for any modification to the software security requirements specification after use.

7.8 Process for maintenance service

Management of cybersecurity during the operation and maintenance phase of the lifecycle includes management of automation asset integrity through a variety of measures, bypassing, patch management, and performance measurements, as well as periodic assessments and audits. In the event of cybersecurity-related changes during operation, change management procedures are used. Cybersecurity events and subsequent response are also a component of the operate and maintain phase.

Figure 6 shows the generalized integration of safety/security lifecycle operation and maintenance phase, including the Regular and Change assessments that take place during the operation and maintenance phase. Each box lists references to the section(s) that address the topic.

For more detail practice could refer to ISA-TR84.00.09-2024 Part 1 : chapter 13 Operation and maintenance.

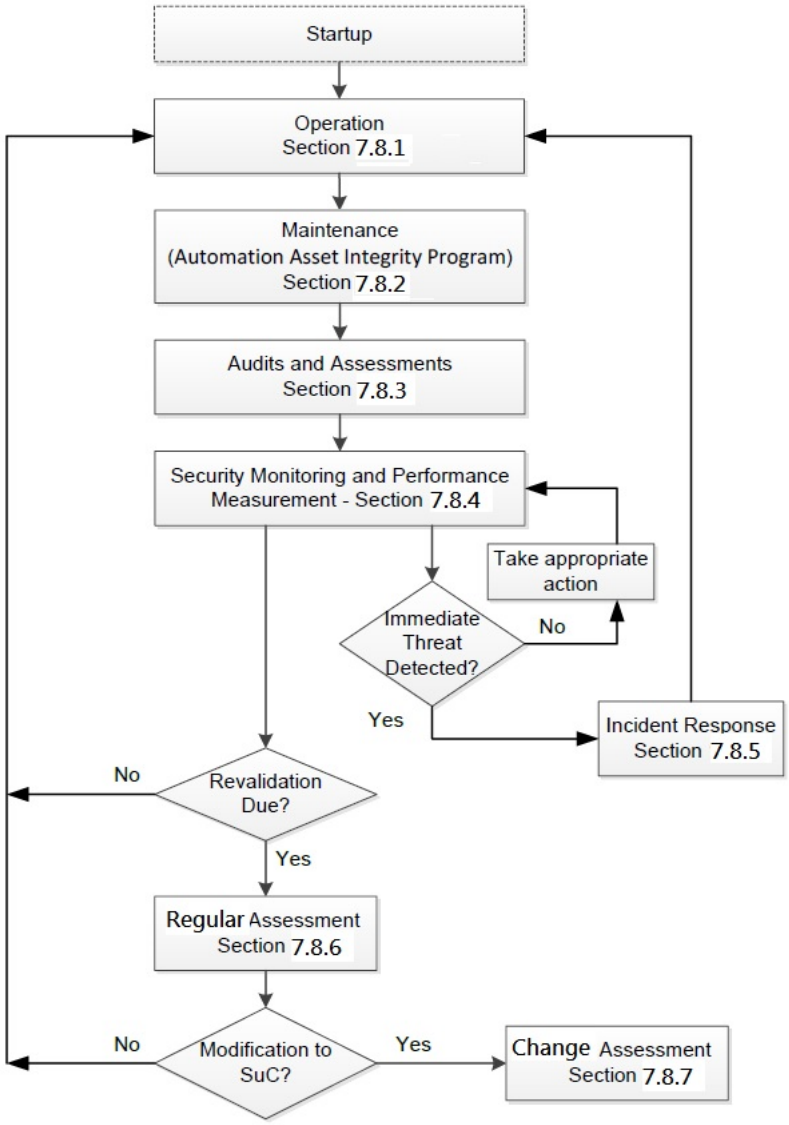

Figure 6 – Operation and maintenance lifecycle phase

7.8.1 Operation

Following startup, the plant continues with operation. Cyber -events during operation represent potential incidents involving safety, financial , and environmental hazards ; therefore it is necessary to maintain the capability, including security, built into the design and the associated organizational management measures necessary to support the ongoing operational and safety needs. The following subclauses discuss several topics that can help maintain the requisite security capability.

7.8.1.1 Access control

An access control policy should be in place to avoid unauthorized access that can lead to compromised information or misuse of the industrial automatical control systems (IACS). User access rights should be subject to review at regular intervals using a formal work process. The user access rights should be modified as applicable due to internal changes in responsibilities or job function and removed or disabled upon termination of the user relationship with the organization (employment, contract, or agreement).

The access management system should take into consideration the type of user access: physical, logical, and/or remote access. Related processes could refer to 7.4.1.3 and 7.4.1.8 for additional guidance, if applicable.

7.8.1.2 Physical access security

Managing physical access to the SuC containing (IACS) is a starting point for the security program, independent of any cybersecurity risk assessment. This is especially important to implement without waiting for a formal risk assessment for servers used for authentication and access control, as well as process/safety controllers and their engineering workstations. Authorized physical access based on the concept of least privilege is recommended. Jumpers for process transmitters should be in place to prevent remote changes to process sensor configurations.

Securing physical access helps to minimize malicious as well as nonmalicious insider (i.e., person with authorized access) cyber -intrusions. Any unauthorized physical access to a IACS system would be outside of acceptable limits.
Related processes could refer to 7.4.1.2 and 7.4.1.5 for additional guidance, if applicable.

7.8.1.3 Logical access security

Following physical access to control and/or network hardware, access should utilize a secure log - on procedure in accordance with Security program requirements (refer to 7.4 if applicable) and security function requirements (refer to OT Security Inspection and Test Protocol or Functional Description Specification and/or ISA-62443-3-3). As part of this, rules based upon clearly defined professional roles provide the basis for granting or denying logical access.

Determining which ISA-62443-3-3 requirements are applicable is a function of the

applicable target security protection rating SPR-T. All users should have authentication, authorization, and approval measures. Users should not be allowed to log in more than once at the same time. Avoiding common user ID's as much as possible is good practice.

Persons conducting activities not impacting real -time operation of the plant should have unique means of identification and authorization. Operators responsible for real-time operation typically utilize common passwords because imposing a requirement to remember a password during a response to an emergency represents poor human factors and increases the likelihood of greater harm, however, they should still log in using their own unique identification. Measures should be in place to log when specific operators log in and when they log out. Inactive sessions for those personnel conducting activities not impacting real -time operation of the plant should shut down after a defined period of inactivity. Additional security for highly sensitive applications is provided when a defined connection time is used.
Related processes could refer to 7.4.1.2 for additional guidance, if applicable.

7.8.1.4 Wireless access

Wireless applications should implement Security program requirements (refer to 7.4.1.6 if applicable) and security function requirements (refer to OT Security Inspection and Test Protocol or Functional Description Specification and/or ISA-62443-3-3) requirements for wireless access. This includes both physical and logical access control considerations as discussed in the previous sections. In some cases, remote access control considerations might also apply. The standards provide additional requirements beyond access control due to the nature of wireless designs.

When process safety risk is involved, then requirements of ISA-62443 and ANSI/ISA-61511-1 should be applied with ISA 100, and other wireless network protocols take precedence when warranted by the risk. This is also true with respect to Bluetooth applications.

Related processes could refer to 7.4.1.6 for additional guidance, if applicable.

7.8.1.5 Remote access

Remote access by its very nature does not allow the additional security that is possible with the use of physical access controls in addition to logical access controls. As such, it should be limited to a minimum. A higher risk is present for

remote access to SuC systems , as this access has the potential to create significant cybersecurity vulnerabilities, especially when bypassing security measures that may be present in higher network levels. Examples include allowing access for remote operation, diagnostics, and programming. Disabling or removing remote access capabilities is preferred whenever possible.

Prior to allowing remote access, consider the following:

- Management approval should be obtained following a risk assessment.
- The remote session should be for a limited duration and automatically end upon inactivity.
- Identification and authentication should be sufficient to ensure that only approved persons and devices are accessing the system. The higher the risk consequence, the stronger and more complex authentication technologies should be implemented, e.g., use of multifactor authentication.
- Encryption of data flows.
- Implementation of visitor personal computer /laptop cybersecurity policies. External laptop tools should have a supported anti-malware protection program running.
- Confirmation that accesses and communication of application external to the system are not able to interfere with the operation of the SuC nor the safety - critical communications.
- System design that prevents potential for split tunneling.
- Provisions to prevent unauthorized access to field devices via back doors in such devices.
- Added monitoring, such as host intrusion detection system techniques, on all remote connections to ensure that no abnormal activity or actions occur while the connection is established.
- Cybersecurity log file kept for all remote session activities and its integration to SIEM as well as its length of data retention .
- Use of host-based firewalls and operating system/application software patches have considered product supplier guidelines.
- Monitoring performance of remote activity.
- Permanent and full control of the remote access by asset owner personnel (initiation and stop) .
- The ability to manually return the plant to a safe state independent of the PSCAI system. Refer to Security program requirements (refer to 7.4.1.6 if applicable) and security function requirements (refer to OT Security Inspection and Test Protocol or Functional Description Specification and/or ISA-62443-3-3) for specific requirements.

Related processes could refer to 7.4.1.8 for additional guidance, if applicable.

7.8.1.6 Electronic use criteria

Contemporary cyber-incidents have proven that cyberattacks and malware associated with portable media can bypass boundary security measures . Portable media includes universal serial bus (USB) flash drives, external/removable hard drives, compact disks, digital video disks , zip/jazz disks, data tapes, floppy disks, handheld calibrators, cell phones, laptops, and tablets , etc. Policies and procedures making it clear what types of portable media are allowed and how they are to be managed should be developed and implemented by the asset owner. Hardening guidance provided by product suppliers is a source of information that can supply valuable information when developing electronic use criteria policies and procedures. Where technically possible, enforcement using technical means that portable media content has been check ed prior to access (e.g., BPCS, SIS, etc.) should be implemented by the asset owner. As an example, only the authorized devices should be allowed to be connected to the identified port within the selected network switch for back up. The electronic media /device should be registered in the asset inventory list with the details of device address and for which application and its relevant machines it is authorized to be used. Custodian and dependency should be identified.

Related processes could refer to 7.4.1.5 and 7.4.1.10 for additional guidance, if applicable.

7.8.1.7 Bypasses/overrides

Asset owners typically have bypass policies and procedures documented for situations when instrumented protection (safety and/or security) requires disabling during operation. These situations may involve on-line proof testing or repairs of failed equipment. Cybersecurity is protection for the entire IACS, including SuC. As such, amending bypass policies and procedures to include the management of bypassing cybersecurity measures is appropriate within the full scope as defined by this document.

Considerations for updating these policies and procedures include, but are not necessarily limited to, the following:

- Minimize duration of the bypass.
- Diagnostics should notify appropriate personnel at repeated intervals.
- Record dates and times of bypass.
- Report bypass logs to independent third -party administrators within the company.
- An alert at the time a logical bypass/override is set.
- Bypass should alarm after a defined period if not restored.
- Implement compensating security measures while the bypass is in place to ensure the SuC is not compromised as part of a temporary MOC. For example, disconnect the SuC system from the network and ensure that those engaged in interfacing to the SuC system when in the bypass mode are trusted, as well as following all the policies, procedures, and security measures that are commensurate with the applicable security level.

Additional management of change guidance is provided in 7.8.7 change assessments.

7.8.2 Maintenance

7.8.2.1 Routine maintenance

When developing a maintenance program considering cybersecurity issues, a good place to start is by reviewing manufacturer recommendations , including security manuals (Functional Description Specification). Part of this maintenance program should be the development of a patch management work process. More information about patch management is provided in 7.8.7 assessments, as patch management is most appropriately considered a part of change management.

Periodic inspections and repairs are part of routine maintenance. These may include but are not necessarily limited to:

- Ensuring equipment hardening requirements are not compromised. Related processes could refer to 7.4.1.5 for additional guidance, if applicable.
- Comparison of performance against expected performance, e.g., calibration anomalies, component configuration anomalies, etc. Related processes could refer to 7.4.1.4 for additional guidance, if applicable.
- Identification of device vulnerabilities. Related processes could refer to 7.4.1.1 for additional guidance, if applicable.
- Password requirements being met. Related processes could refer to 7.4.1.3 for additional guidance, if applicable.
- Maintenance of monitoring tools (continuous, periodic or condition based) .
- Repair due to detected failures.

The frequency of the inspections should be a function of what was determined during the risk assessment as well as whether they are manual or automated in nature. For more information regarding automated security monitoring, see 7.8.4 .

Consideration should be given to the management scheme , such as regularly checking procedures from the lifecycle point of view, and the technical scheme , such as a regular audit of the antivirus software and log. Related processes could refer to 7.4.1.10 for additional guidance, if applicable.

Updates to software (e.g., antivirus, application, embedded, etc.) should be validated by the responsible party and tested before implementation. Prior to actual installation on site, end users should consider the potential impacts of the changes. Related processes could refer to 7.4.1.11 for additional guidance, if applicable.

When workstations that have application software installed are updated, a person authorized per least privilege principles should be present at the workstation to either perform the work or monitor the work if it is being done remotely, with the ability to terminate the session if problems arise. Related processes could refer to 7.4.1.8 for additional guidance, if applicable.

Backup and restoration capabilities and procedures of all the SuC network configurations should be provided and tested on a periodic basis. Test performance should be based on the recovery time objective and maximum tolerable downtime of the recovery process to ensure that recovery is possible for the different cyberattack scenarios. The interval of time between testing should be a function of the number of changes being made (e.g., monthly notification of patch updates) and past test performance metrics , as well as the level of risk. Related processes could refer to 7.4.1.12 for additional guidance, if applicable.

7.8.2.2 Automation asset integrity program

An asset integrity program begins by identifying the safety functions, how each component that supports a function is intended to operate. Listing the known failure modes will be important input in developing the security for safety assets. Automation assets need to be monitored for the health of the security asset and the safety asset whether individual components or systems. As such, a successful automation asset integrity program should include the complete identification of compatible security devices capable of protecting their appropriate safety function

and its assets . The best program leverages a full range of secure-by-design defense in depth, with secure development lifecycle practices results with an integrity baseline . Careful attention should be paid to every interaction between the safety function and how it is secured to later assist in verification . Recording the security asset's design and test parameters used to secure a particular safety function supplements failure mode and effects analysis, FAT/SAT, and review during MOC.

7.8.2.3 Obsolescence planning

It is often the case that legacy equipment in use is no longer supported by the manufacturer. This is increasingly problematic over time due to:

- increasing loss of reliability/integrity due to wear -out,
- increasingly difficult to obtain spare parts that can be assured of the same OEM capability/security, and
- inability to patch new vulnerabilities when they are identified, increasing risk of being compromised.

As such, it is prudent for the asset owner to have a documented obsolescence plan in place to address obsolescence of cybersecurity -related equipment/mitigation/software . The start of such a plan is a complete asset inventory that documents the current versions of operating and application software as well as any information from the manufacturer about upcoming updates and/or plans for stoppage of support. Based upon the timeframes, potential risks, and availability of other means of support, a plan should be developed that considers when it is most advantageous to update the obsolete equipment and how those updates should be managed.

7.8.2.4 Tools

Several tools perform necessary activities associated with the IACS and its associated network and devices.

If a tool is not sufficiently secure relative to its SPR-T from a technical capability perspective, i.e. , failure of tool to comply with ISA-62443-4-2 for the SPR-T required by the zone where it is used, the zone SPR-I and SPR-O would be deficient as compared to the zone SPR -T. In addition, insufficient management of the tool would also cause the zone SPR-I and SPR-O to be deficient as compared to the zone SPR -T. In such situations, the tool becomes a potential threat vector to compromise the zone(s).

Proper management of tools involves development and implementation of rules embedded in procedures for the tools used by engineering, maintenance, and service providers. Failure in the proper management of these tools in a consistent and secure manner causes inefficient and inaccurate work procedures , leading to poorly managed risks.

Lack of clear rules for tools results in the following:

- difficult or impossible procedures for end users ,
- lack of interoperability,
- lack of integrity, and
- unnecessary chaos and associated costs .

From an application perspective, this document classifies tools as either manufacturing tools or shop tools. Manufacturer tools provide broad capability necessary for manufacturers to create and support devices in an engineering development or factory environment. Shop tools that provide off-net access to third parties or end users with less capability than manufacturer tools are not appropriate for on-net procedures. When there is a lack of security capability in shop tools, the recommendation is to block on-network procedures.

Many of the current portable tools intended for use in the shop do not currently support cybersecurity requirements as documented in ISA-62443-2-1 and ISA-62443-3-3 for interfaces with the network or internet, e.g., log on to networks and communicate over networks to host systems, even though they have the capability to connect. Likewise, current host systems do not currently support portable field tools. The current situation means that compensating security measures in the form of increased reliance on management procedures and rules to address the gap in technical capabilities are the only way to ensure compliance with the asset owner’s zone(s) SPR-T.

Due to the shop dealing with tools that potentially interface with multiple zones, consider making the shop a separate zone with an SPR-T equal to the highest SPR-T of the zones its tools interface with.

Host systems with the ability to communicate securely with portable field tools can convert awkward two-person procedures to more efficient one-person procedures.

The following provides guidance for the creation of rules for portable tools:

Portable field tools that provide required access to host support functions from a location proximate to a field device should:

- Be logged in to host systems and should communicate with hosts. Commissioning and maintenance procedures require field interaction with devices and process connections in the field, but device and field tool interaction should be directed through a host.
- Disallow direct communication from a tool to a device after provisioning. Field tools can facilitate provisioning and configuration; however, the recommendation is to automate these procedures as much as possible.
- Authenticate and authorize devices, field tools, and users to allow access . This means that devices be used that support authentication and authorization. It is recommended that they also support backup and restore, data protection, and when possible, continuous monitoring.
- Have their activities logged by host systems.
- Have capability to detect and reject direct commands from manufacturer and shop tools while the devices are network connected.
- Implement procedural controls to compensate when they lack the firewall function to reject unauthorized communication, i.e. , for legacy devices. Monitoring is the primary procedural control available for legacy protocols.
- Be included in the changemanagement program. Reference Figure 7 Generalized Patch Management Work Process.
- Be assessed for malware, and receive cybersecurity patches for all software components prior to first-time connection or use on a SuC system and after any software or version update following the first-time use.

Field tools can be a thin client (i.e., a simple computer that has been optimized for establishing a remote connection with a server -based computing environment) .

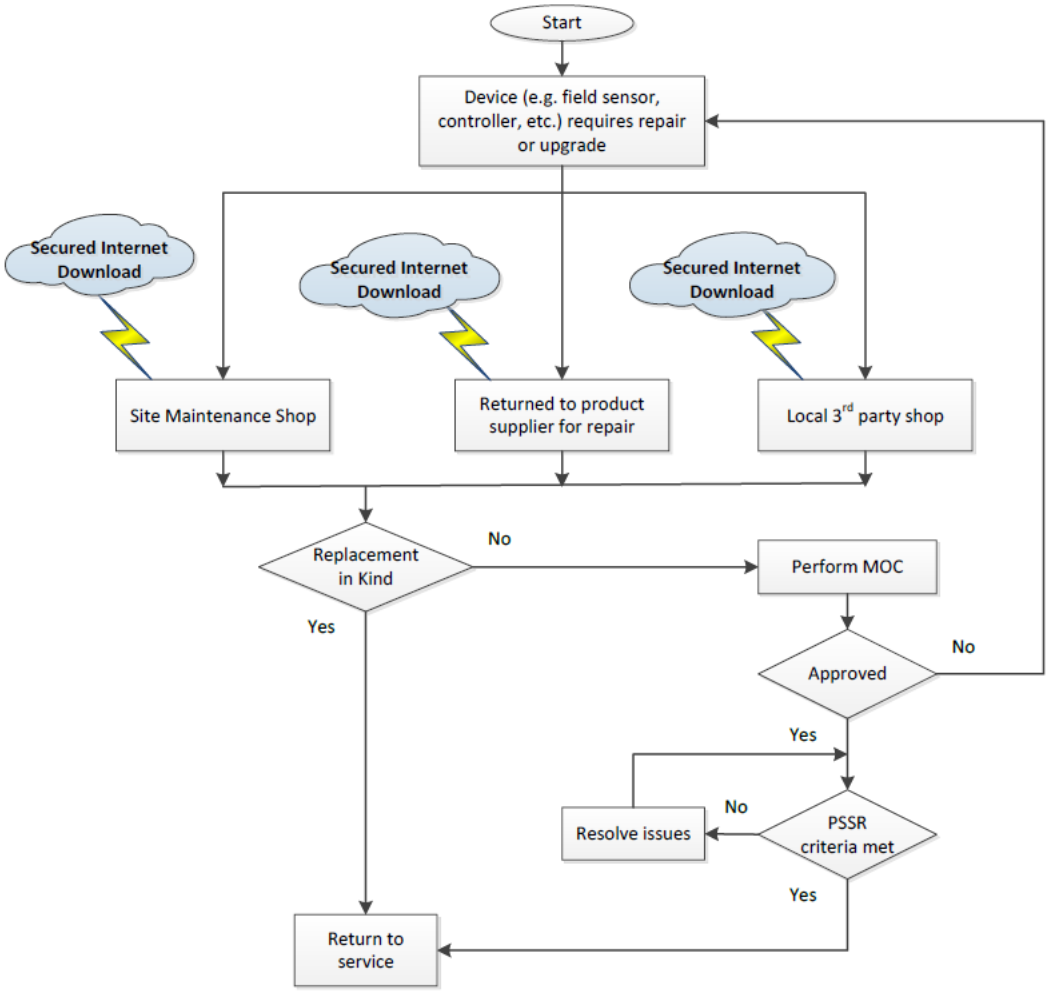

Figure 7 Device repair or upgrade flowchart (Reference : ISA-TR84.00.09-2024 Part 1)

Note : 1. Purchase order should make it clear that 3rd party shops and product suppliers acting in a service provider role should comply with 62443-2-4 as necessary (defined in PO) to comply with asset owner standards and procedures.

2. An expectation would also be that 3rd party shops and product suppliers acting in a service provider role have a cyber security management system in place that complies with 62443-2-1

Optimizing tools for ease of use by the supplier represents good design practice. This implies most jobs are capable of performance by a single technician without engineering support and automation of support for new device revisions (including MOC). This includes maintenance of full functionality after update.

Related processes could refer to 7.4.1.11 for additional guidance, if applicable.

7.8.3 Audits and assessments

7.8.3.1 Audits

ISA-62443-2-1 provides asset owner s with a framework for development of their security program that includes ongoing auditing for compliance and improvement.

Audit records should be sufficient to monitor the effectiveness and proper operation of the management system requirements in ISA-62443-2-1 and the security mechanisms utilized to meet the requirements of ISA-62443-3-3 standards. Existing work processes for performing audits should be leveraged to incorporate various cybersecurity checks. These checks may include but are not limited to the following topics:

- compliance with policies and procedures,
- asset management compliance,
- device security,
- least privilege conformance,
- use control conformance,
- physical security,
- logical access security,
- system integrity conformance,
- resource availability,
- defined data flow conformance,
- data confidentiality conformance,
- configuration changes,
- security logs,
- event monitoring results,
- alarm events,
- zone SPR compliance,
- business continuity plan drills,
- emergency response plans drills,
- incident reporting conformance, and
- training conformance.

Audit information includes all information (for example, audit records, audit settings , and audit reports) needed to successfully audit control system activity and capability. Auditing information is important for error correction, security breach recovery, investigations, and related efforts.

Audit records should be centrally managed , and audit records should be compiled from multiple components throughout the control system into a system -wide (logical or physical), time-correlated
audit trail. Audit records should be saved in a secure manner and stored in a safe location, e.g., watertight, fireproof, etc.

Ongoing audits manually performed should be performed at defined intervals.

Annexes Table C.9. provides an example of a physical inspection audit form with pass/fail criteria.

Audit results can be an important input to key performance indicators.

7.8.3.2 Job cybersecurity assessments

One method to identify cybersecurity hazards related to activities performed by employees and contractors is to perform a job cybersecurity assessment (JCA). This is like the concept of job safety assessments (JSA) used within industry. The JCA methodology is intended to be used for the assessment of site work instructions where errors can result in potential cybersecurity events. The JCA can help to identify appropriate measures to eliminate, reduce the likelihood of, or mitigate the consequences of cyberhazards that may exist prior to engaging in such work practices.

The development of a JCA is recommended for all specific procedural activities that have the potential to compromise cybersecurity of the IACS network and process controls. For more detail practice could refer to ISA-TR84.00.09-2024 Part 1 : Annex M, Job cybersecurity assessment, provides a procedure for performing a JCA.

7.8.3.3 Service provider/product supplier qualifications

With respect to product suppliers, demonstrated conformance to ISA-62443-4-1 and ISA-62443-4-2 is recommended. Conformance to ISA-62443-4-1 helps to ensure that the product supplier work processes are adequate. Any deficiencies found should be addressed and remedied. ISA-62443-4-2 provides the technical requirements as a function of SL for programmable devices. This applies to all devices within the IACS and its associated network from levels 0 through 3.5,

including those devices (e.g. , tools, remote access engineering workstations, portable media, etc.) that have intermittent connectivity.

Should the product supplier be a system integrator, ISA-62443-3-3 should be included in the specification and evaluated for conformance. ISA-62443-3-3 includes complete system requirements as a function of security level for the system being provided.

Understanding the technical security capabilities of the equipment and systems is essential to determine what level of procedural support is necessary , as well as the need for additional compensation measures. The evaluation process of the product supplier (devices and systems) is important irrespective of whether the equipment is being purchased from the original equipment manufacturer (OEM) or some other distributor (e.g., distributor, off the internet, etc.). When purchased from a supplier other than the OEM, the evaluation should ensure that counterfeit equipment is not being supplied.

7.8.4 Security monitoring and performance measurement

7.8.4.1 Alarms and alerts

The ANSI/ISA-18.2 standards define an alarm as an audible and/or visible means of indicating to the operator an equipment malfunction, process deviation, or abnormal condition requiring a response in a timely manner. They define an alert as an audible and/or visible means of indicating to the operator an equipment or process condition that requires awareness, which is indicated separately from alarm indications, and which does not meet the criteria for an alarm. One might consider the IACS network as being a utility process operated in a supervisory manner. Consequences of mismanagement or failure to respond to alarms indicating system compromise have the potential to impact process safety . To mitigate this potential, asset owners should consider the following:

- Identify all diagnostics and other indications of abnormal conditions involving the control system and associated zone(s), conduit(s), and networks. This should also include those that are related to cybersecurity.
- Perform alarm rationalization of these alarms and indications of abnormal conditions.
- As part of the alarm rationalization, define the relationship among process operators, network operators and maintenance.

- When a cyber-alarm is identified, define the required response in an appropriate procedure.
- The procedure should define the interface between IT and OT so that a coordinated response is possible. This should describe who is responsible for what as well as any required communications.
- Applicable training requirements to ensure appropriate comprehension and expected response to an alarm consistent with the cause of the alarm, e.g. , equipment failure, cyberattack, etc.

More detailed information regarding alarm management may be found in the ISA - 18 series of standards and technical reports.

7.8.4.2 Automated security monitoring

Automatic security monitoring should provide clear and meaningful information to the operations or maintenance functions , allowing for a quick and accurate response to a security breach . Additionally, the security monitoring should be able to correctly identify if the security breach impacted the availability of the safety system. The security monitoring system should display event monitoring “results” and the appropriate action response to any alarms. If the security monitoring identifies any abnormality, it cannot provide an action response and accurate information of the condition should be displayed and logged for later forensics and incident response . All changes to the security monitoring functions should follow MOC (Refer to 7.4.1.11).

Specific monitoring requirements as a function of security level can be found in ANSI/ISA-62443-3-3.

7.8.4.3 Key performance indicators

Cybersecurity involving systems with SuC is a relatively new subject but, in fact, has always been an inherent part of SIS design. For example, an SIS is by design supposed to be independent and implemented to prevent unauthorized access. Cybersecurity and SISs share many of the same design attributes. Both are concerned with physical and logical access. Both are concerned with change management authorization processes that ensure only authorized personnel and authorized systems gain access to the SIS. For this reason, it makes sense to develop cybersecurity metrics that benefit safety.

When creating metrics, both leading and lagging indicators help better understand

the current level of performance and how to prioritize future improvement activities.

It could use various metrics and key performance indicators as they seek to improve their performance. Different asset owners most likely will be at different points in their maturity with respect to cybersecurity as well as having different risk profiles, therefore different key performance indicators will be more appropriate. As an asset owner's maturity level improves, revisions to what KPIs are emphasized will most likely change as well as their associated failure criteria. For more detail practice could refer to ISA-TR84.00.09-2024 Part 1 : Annex L, Cybersecurity KPIs and metrics, includes several KPIs and metrics for use as users see fit.

7.8.5 Incident management

Threats may or may not be immediate. A documented plan should be in place that specifies how responses to intrusion (intentional or unintentional) demands are addressed and responded to considering their urgency and potential consequences. The incident response plan should include procedures for how the organization will react to incidents as a function of the incident consequence (high impact, low impact), including notification/communication, investigation , and recovery methods, as well as identifying responsible personnel and actions to be performed by designated individuals. The initial cybersecurity risk assessment should have provided a starting point for how to begin mitigation. Final development of the complete procedures should have occurred during the design phase. These procedures should be reconciled or integrated with existing work processes such as the site emergency response plan and near miss/incident reporting systems. Confirmation of implementation should occur during the pre -startup safety review (PSSR).

Refer to 7.4.1.9 and/or ISA-62443-2-1 for specific requirements related to incident management.

The resulting outputs from complying with ISA-62443-3-2 can provide a starting point to help develop response procedure (s).

Following a failed or successful attack, an analysis should determine if upgrades and corrective actions are appropriate to reduce the likelihood in the future. Quantification of incident metrics based on type, volume, consequences , and/or cost can support justification of such upgrades. Recording and communicating

unusual activities and events generates a specific cyber-knowledge base.

To prepare for potential attacks, the performance of drills to practice response procedures under simulated conditions helps to improve performance. These drills should be conducted on a periodic basis.

7.8.6 Regular assessments

7.8.6.1 Purpose

The intent of the regular assessment is to revalidate the process hazards analysis and cybersecurity hazard assumptions made versus actual experience and changes in the threat landscape, and to correct and/or update as applicable. In addition, this is an activity that also reviews changes made since the last validation or revalidation to determine if the as found satisfies the requirements stated in the safety and cybersecurity requirements specification.

7.8.6.2 Input and guidance

Performance of a regular cybersecurity risk assessment should occur following a defined period of operation providing a level of experience or sooner if conditions are found to warrant, e.g. , a substantial change in the threat landscape posing a risk known to not be tolerable by asset owner senior management. For plants regulated by process safety management standards, e.g., OSHA 1910.119 subpart H, Process safety management of highly hazardous chemicals , this is typically done every five years.

During this assessment stage, the risk review team should revalidate the prior risk assessments. The review of initial assumptions and any changes affecting the initial assumptions are key to a successful revalidation. The following activities can assist this assessment:

- review cybersecurity incidents since last revalidation,
- review changes to the threat landscape,
- review cybersecurity-related management of changes since last revalidation,
- review current vulnerability assessment,
- review detailed level cybersecurity risk assessment and update as applicable,
- review of KPI results from audit program, and
- address all recommendations resulting from revalidation.

Persons knowledgeable in the processes, operations, and design under review with at least one person knowledgeable and competent in the assessment methodologies used in the workshops should participate. The membership of the assessment team should include at least one senior competent person not involved in the operation and maintenance.

The input for the regular project reassessment is :

- safety requirements specification,
- cybersecurity requirements specification,
- prior action item closure documentation,
- current hazard and risk assessment (H&RA), e.g., HAZOP, LOPA, cybersecurity risk assessment documentation ,
- current data flow analysis report ,
- current management system,
- current vulnerability assessment(s),
- current SIL verification report,
- current security protection rating verification report,
- control system architecture drawings,
- current zone and conduit drawings,
- current configuration documentation,
- current asset inventory,
- current C&E matrix drawing(s),
- current PFDs,
- current P&IDs,
- applicable near miss, event, and incident records,
- applicable MOC records ,
- obsolescence planning documentation,
- security procedures,
- security-related maintenance procedures,
- inspection and test procedures,
- maintenance records,
- SIS/SIF work orders,
- diagnostic alarms,
- repair data,
- inspection and test records,
- applicable KPIs,
- bypass policy and procedures,
- bypass logs,
- training records, and

- competence criteria and logs.

Related processes should refer to 7.2 and 7.3 for additional guidance.

7.8.6.3 Output

The result of the regular assessment is :

- an updated set of hazard review reports, e.g. , HAZOP, LOPA, quantitative risk analysis, cybersecurity risk, etc.,
- recommendations as applicable to address identified deficiencies, and
- action items with specified dates to eliminate deficiencies determined to not satisfy corporate risk criteria.

Related processes should refer to 7.2 and 7.3 for additional guidance.

7.8.7 Change assessments: management of change

Management of change is a requirement of process safety management regulations and is associated with the change assessment. ISA-62443-2-1 requires that all changes to the current configuration baseline and infrastructure drawings/documentation, including revision and patch levels, should be authorized, validated, approved, and documented. In addition, as part of this process it requires approval by two or more people whenever the proposed actions can result in serious impact to the industrial process.

Figure 8 is an expansion of the change assessment block within the generalized integrated safety/security lifecycle documented in Figure 6. The change flowchart shown in Figure 8 starts with a proposed change and through a series of questions determines the type and extent of recommendations to address the proposed change. For the purposes of this document, decommissioning is a subset of the MOC work process even though decommissioning is shown separately in Figure 6, Generalized integrated safety/security lifecycle.

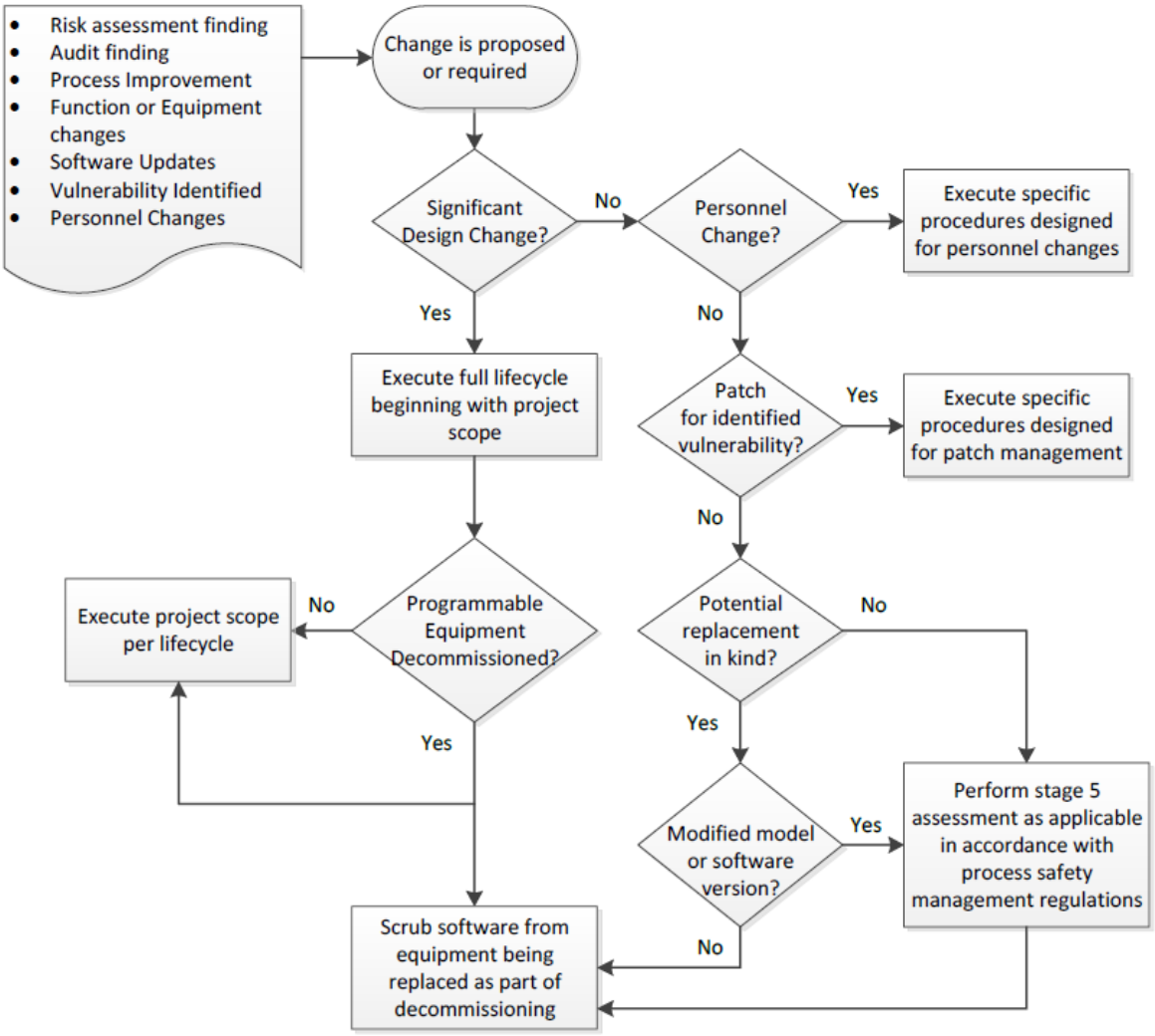

Figure 8 – MOC/decommissioning work process (Reference : ISA-TR84.00.09-2024 Part 1)

7.8.7.1 Management of change

Changes to the overall IACS and safety system may occur due to many reasons. Although MOC is generally a well-established practice in the process industry, cybersecurity raises new issues that should be considered. Any modification (see Figure 8) should trigger an analysis for impact. The change should be evaluated against the process safety information, the SRS , and the CRS as developed and implemented. To support MOC, baseline information should be available. ISA-62443-2-1 requires the following:

- a current baseline configuration of all devices and their software components ;
- documentation of configuration settings of all IACS devices and software applications ;
- organization responsibilities, manufacturer, model, version numbers, serial

numbers, revision/patch levels and history ;

- a current baseline of the logical and physical infrastructure drawings/documentation of all devices and their software components, including their network connectivity.

1. General change management considerations

In general, changes should be in accordance with the conventions set forth in the design basis documents and suggested adherence to:

- product supplier's safety manual,
- product supplier's cybersecurity manual, and
- all business network integration agreements/policies/work process documents that support the cybersecurity countermeasure implementation.

Examples of items that should be part of change management include, but are not necessarily limited to:

- Changes to access restriction to the maintenance/engineering interface. Restriction of access can be procedural, designed and controlled via network, and/or additionally controlled via local plant key locks with active monitoring metrics.
- Changes to administrative policies/procedures that define the conditions under which the maintenance interface may be connected to the system during normal operation. This may involve procedures and design and be controlled via closed network access ports that require MOC to open, creating online metrics and make available for use.
- Changes to written approval with reasons for access.
- Changes to documentation of persons allowed access and what work individuals are permitted to perform via written approval process.
- Changes to documentation of required training and/or familiarity with the system before access is permitted.
- Changes to documentation of the circumstances that allow access to be permitted; this includes the procedures that control the use of maintenance bypasses.
- Changes to the use of virus checking software and appropriate program and file handling procedures in the engineering workstation or other components inside the safety zone (See section on competence and system integration (buy/build/configure) competence) .
- Changes to the use of metrics used in the PSCAI system utility software that tracks revisions in the application logic and allows the determination (after the fact) of when a change was made, who made the change, and what the change consisted of.

- Changes to methods dealing with unauthorized and authorized access (remote or local) to the process control or safety system logic solvers and I/O.
- Changes to any logic that can affect the proper operation of the PSCAI (time delays, set point changes, maintenance bypasses, and PSCAI device configuration changes).
- Software and firmware patch updates.

Based on the evaluated impact of the proposed modification, the tasks performed by personnel with lifecycle responsibilities may change. Training should be performed when modifications are made to personnel responsibilities, work processes, procedures, or tools prior to implementation of the change.

2. Replacement in kind

   The seemingly simplest type of MOC to consider is whether a change can be considered replacement in kind. From a cybersecurity viewpoint, this means no changes to a device model number or changes to its firmware or software. With the advent of smart devices, this is seldom the case. Manufacturers are frequently updating the software due to software patches or the modification of software to change or add features. New or modified features may result in new vulnerabilities and should be evaluated against the CRS as well as from a risk perspective and tested prior to implementation. Consequently, from a cybersecurity perspective, any changes should not be considered “replacement -in-kind” and should have a cybersecurity review performed and documented as part of the MOC. Any unneeded features should be disabled.

3. Emergency changes

   When there is no choice as to a change, such as following a failure, review of the new device specification should look for new features as compared to the current device specification. New or unneeded features should be turned off until it has been determined that they will not have a negative impact on the original design basis. New features that cannot be disabled should be tested to ensure they do not affect the current design basis or operations. ISA-62443-2-1 requires documentation of explicit manual elevation of privileges, including supervisor overrides for all operations that require elevated privileges.

4. Routine maintenance

   Some changes are routine to maintain security within a well-documented procedure. Updating table definitions is an example where a general MOC is not required.

5. Patch management

Patching may be part of normal maintenance, or it may be required due to the identification of a critical vulnerability. In both cases, patching is part of change management. In the case of patching, it generally makes sense to have specific procedures rat her than to use the more generalized MOC work process. In general, patching should be performed as applicable. End users should ensure that all authorized firmware upgrades have been implemented securely and that no unauthorized firmware changes have been made. Additional guidance is available in ANSI/ ISA-TR62443-2-3-2015.

Related processes should refer to 7.4.1.11 for additional guidance.

6. Functionality changes

Many changes involve new or revised functionality. Oftentimes the functionality provided exceeds that requested due to being part of a standard product. For more detail practice could refer to ISA-TR84.00.09-2024 Part 1 : Table 10 – Typical types of functionality changes and associated recommended practices when performing MOC.

7. Access changes

Access management is important to enforce least privilege, thus helping to minimize the attack surface. Only persons who have a need to access specific systems and who are competent should be allowed access. For example, not every control engineer should be allowed access to the SIS engineering workstation, although more control engineers would typically be granted permission to access the BPCS workstation. Access management should have its own procedure , as attempting to manage this activity using the generalized MOC work process would be very inefficient. Within the procedure, the responsibilities of those organizations that should work together should be defined. Those organizations that are typically involved includes operations, maintenance, electrical engineering support, controls engineering support , and human resources. From the least privileged perspective, the specific job function represents a foundation for what access and to what level of access rights one would have. Human resources should be in volved, as they should help manage job function transfers as well as people leaving the company or business area.

7.8.7.2 Decommissioning

In this document, decommissioning represents a subset of management of change. For smaller changes such as perceived replacement in kind, the MOC work process

should ensure that data be purged from the components being replaced. ISA-62443-2-1 requires that all data requiring safeguarding is purged when the device is decommissioned or otherwise removed from the IACS. With respect to control systems, ISA-62443-3-3 requires they have the capability to purge all information for which explicit read authorization is supported from components that are to be released from active service and/or decommissioned. Similarly, ISA-62443-4-2 requires that components provided by product suppliers have the capability to erase all information, for which explicit read authorization is supported, from components to be released from active service and/or decommissioned. This should be confirmed during the technical evaluation process before placing the purchase order. It is recommended that data purging be addressed with a procedure that details required actions and who is accountable and responsible for execution of the procedure.

ISA-62443-2-1 includes a requirement that procedures be established and audited with respect to the addition, removal, and disposal of all assets. The decommissioning procedures should include (but will not necessarily be limited to):

- Device evaluation to determine if the device should be sanitized or if the data on the device needs to be retained and transferred elsewhere within the company.
- Procedures to transfer historian information (safety performance key indicators, incident events, etc.).
- Method of data destruction should be selected based on the data sensitivity, e.g. , erasing/overwriting, degaussing (demagnetizing), physical destruction, cryptographic erase, etc. Transfer or reuse of the device is not recommended unless sanitization can be fully validated.
- Availability of decommissioning documentation, including device information, data destruction/disposal method used, and validation test availability for audit purposes.

When the changes impact the design of the controls network, then decommissioning should undergo a full safety lifecycle analysis.

If decommissioning is intended to shut down or remove all the facilities at a site, then cybersecurity analysis is necessary once the exact method and timing for each decommissioning step is defined. The resulting cybersecurity analysis may require revisiting and modification of previously established method and timing for each decommissioning step.

Since decommissioning is an infrequent event, lack of experience in this process is

common. Thus, an effort should be made to include all plant personnel familiar with the facility (for example, operating, maintenance, management, engineering, controls, IT , safety) in the decommissioning planning.

Before proceeding with decommissioning projects, all parties involved with this activity should fully understand the scope and consider the potential cybersecurity issues addressed throughout the lifecycle. The following will only list typical cybersecurity issues resulting from decommissioning to help the reader to develop a proper decommissioning cybersecurity plan .

As-built information should be available before proceeding with any aspects of decommissioning, so that existing security protection ratings and other cybersecurity -related security measures, conduits, and zones are not compromised, and decommissioning steps can be planned properly.

While it is possible not all the safety lifecycle phases apply for any given decommissioning, each phase should be considered. Listed below are the safety lifecycle phases and simple decommissioning issues often encountered that are related to that phase.

- Hazard and risk assessment: The hazard and risk assessment should identify risks related to cybersecurity created through:
  - improper decommissioning sequencing resulting in loss of, or reduction of, cybersecurity;
  - loss of protection in zones, conduits, process control systems, or PSCAI systems;
  - impact of decommissioning on utilities (for example, electrical, steam, instrument air) that could impact the operability of programmable electronic devices used as cybersecurity security measures (for example, overvoltage, under voltage, instrument air pressure abnormality);
  - the impact of new plant personnel and impact on existing plant personnel noted in the introduction above.

- Allocation of security levels to security measures : The need for security measures will be based on the results of the cybersecurity risk analysis. This may include the addition of new security measures or the modification of existing security measures.
- CRS for the cybersecurity security measures: Assuming either of the above two bullets results in modifications to existing specifications documented in the

existing CRS, the CRS should be updated.

- Design and engineering of cybersecurity security measures: While the previous three bullets can result in the need for design and engineering, an additional consideration includes the temporary construction design and engineering requirements that may be needed to maintain production of existing facilities safely and securely while decommissioning is underway. This temporary construction may induce new cybersecurity issues that should be addressed in the cybersecurity risk assessment and subsequent steps as needed.
- Design and development of other means of risk reduction : Loss of existing security measures or need for additional security measures may require the design and development of other means of cybersecurity risk reduction.
- Installation, commissioning, and validation: Any additional or modified cybersecurity risk reduction implementation should consider the need for installation, commissioning, and validation.
- Revalidation of access privileges given the changes to the system.
- Data sanitization of equipment removed.
- Operation and maintenance: Maintenance and operating procedures and training should be put into effect if the implementations of earlier bullets noted above are determined to be necessary.
- The competence of the people involved in decommissioning work is necessary to confirm all participants have the necessary training and knowledge of the cybersecurity impact of the decommissioning prior to performing these tasks. The membership of the assessment team should include at least one senior competent person not involved in the project, e.g. , design, operation, and maintenance.

Based on the evaluated impact of the decommissioning, the tasks performed by personnel with PSCAI lifecycle responsibilities may change . Training should be performed when modifications are made to personnel responsibilities, work processes, procedures, or tools prior to the decommissioning.

7.8.7.3 Assessing the change work process

1. Purpose

The intent of the stage 5 assessment is to ensure a robust management of change program with respect to cybersecurity and to validate that the assumptions made in the risk assessment are still applicable. Once operations assume the responsibility for operation of the plant, execution of individual MOC should occur for proposed changes. This is a requirement of process safety management regulations, e.g. , OSHA 1910.119 subpart H, Process safety management of highly hazardous

chemicals.

2. Input and guidance

The change assessment of the overall work process is recommended to occur before or in conjunction with the regular assessment. Competent personnel should complete the performance of this assessment via an independent check. These people should have both the knowledge and experience to judge both the completion of expected work and, when applicable, the quality of such work.

The input for the stage 5 project assessment is :

- MOC documentation,
- MOC approval documentation ,
- risk assessments for approved change ,
- other applicable baseline risk assessment reports ,
- MOC KPI records,
- current safety and risk assessment reports ,
- current SPR verification report (i.e., SPR-I or SPR-O, whichever is most recent) ,
- cybersecurity requirements specification (CRS) ,
- PHA/risk assessment reports ,
- vulnerability assessments,
- zone and conduit drawings,
- configuration documentation,
- security procedures,
- operating procedures,
- maintenance procedures,
- other applicable design and/or procedural documents,
- training records, and
- competence criteria and logs.

3. Output

The result of change assessment is :

- the relative maturity level of the current MOC work process as implemented and operated and
- recommendations for improvement as applicable.

7.9 Process for System Acceptance Testing

7.9.1 Overview of system testing

7.9.1.1 General

The SuC system is to be tested at various stages in its development and implementation. Each new SuC system should be subjected to three tests to demonstrate proper operation in accordance with project-specific requirements: factory acceptance test (FAT), site acceptance test (SAT) and site integration test (SIT). Loop tests should be performed in accordance with IEC 62382, which typically occur after SIT. All these tests should be completed, with any open items documented and agreed upon by all parties involved in the tests, prior to the system being placed in operation. An optional fourth test, factory integration test (FIT) can also be performed on all or part of the system while at the vendor's factory.
For more detail practice could refer to IEC 62381:2024 Automation systems in the process industry – Factory acceptance test (FAT), site acceptance test (SAT), and site integration test (SIT).

The typical order of execution of these tests is:

- The factory acceptance test (FAT) is performed on the SuC system, subsystem or component before it leaves the vendor's factory to demonstrate that it functions in accordance with the project-specific requirements.
- The factory integration test (FIT) is a fourth, optional testing point to demonstrate that the merging of some or all the various subsystems and components function as specified. This test is performed after or in conjunction with the FAT, before the SuC system, subsystem or component leaves the vendor's factory.
- The site acceptance test (SAT) is performed after installation on site to demonstrate the SuC system, subsystem, or component is in accordance with the applicable standards, codes, specifications, and installation instructions. This test is performed after each subsystem is installed.
- The site integration test (SIT) is performed after the SAT to demonstrate that the merging of the various subsystems and components into one overall SuC system is complete and that all subsystems and components work together as specified in the test plan. This test can be performed on two or more subsystems or components after each has been installed and successfully completed a SAT or after all subsystems and components have been installed and successfully completed a SAT.

7.9.1.2 Methods of test performance

This guideline provides checklists for developing test plans for the SuC system. Traditionally, these tests are performed using manual methods. With modern systems, these tests can also be performed using automated methods, depending on the system's capability. If automated methods are used, it is the vendor's responsibility to demonstrate that the automated tests completely cover all aspects of the test plan and are validated.

7.9.1.3 Project design changes

Changes made to the project design during or at any time after FAT, whether to the detailed design scope or as a correction/adjustment made during testing, should be formally documented and their full impact on the SuC system should be determined, including the impact of the changes on test plans and already completed tests. Involved parties (e.g. owner, buyer, vendor) should be informed of all changes impacting project scope/cost/schedule, safety, or system performance and should approve changes as required by the project. Project design and test plan documentation should be revised and completed tests re-performed, where necessary, to reflect all design changes.

7.9.1.4 Adapted procedures in the event of modifications to existing systems

This guideline generally describes testing of new systems. If a modification or upgrade to a system that is currently in operation is being tested, additional precautions should be considered. During design of the modification/upgrade, changes should not be made in the field (on the owner's operational system) until testing is complete. If any changes are made to the operational system during this time, those changes should be tracked and be implemented in the new system being tested before FAT. For example, all changes (logic, I/O, graphics, etc.) made in the field after the software freeze date should be implemented in the SuC system before the FAT. This ensures changes made by operations for example, are captured in and tested with the new system.

7.9.2 Factory acceptance test (FAT)

7.9.2.1 General

This Clause provides the activities that are precursors to, conducted during, and provided after the FAT. The purpose of the FAT is to demonstrate that the automation system, subsystem, or component is in accordance with the URS and

FRS and to verify the functionality, performance, and stability of the hardware and software delivered by the vendor.

For security related FAT processes could refer to 7.6.1 1. OT Security FAT Test for additional guidance.

7.9.2.2 Performance

The FAT should be performed after manufacture of the SuC system and prior to installation in the field.

NOTE The FAT typically is performed by the vendor. The buyer typically witnesses the test activities. There can be buyers who want to carry out some parts of the FAT themselves. This is established on a project-related basis.

7.9.2.3 Pre-FAT activities

1. General

   Prior to commencing the FAT, the following activities should be completed:

   a) vendor tests;

   b) documentation;

   c) test plan; and

   d) test schedule.

2. Vendor tests

   The vendor should conduct all vendor standard and any necessary custom tests of the system. Reports documenting the tests should be available for buyer inspection.

3. Documentation

   Reference documentation should be assembled prior to the FAT. This document primarily consists of the purchase order to the vendor and all requirements and information included with that order describing the requirements for the system, its installation, and its performance. This document serves as the basis for development of the FAT functionality test requirement document. These documents can include, but are not limited to, the following categories:

   - User requirements specification: document(s) defining the project scope and design conventions and guidelines;
   - Functional requirements specification: document(s) defining the detailed design requirements, including system functional requirements;
   - Information to vendor: scope requirements changes, changes to SuC system hardware or software, or other additions or clarifications provided to the vendor

during execution of the project;

- Vendor documentation: documentation developed by the vendor during the execution of the work, including complete documentation of all system I/O and interlocks;
- Process control narratives, updated to reflect any changes made during testing; and
- Master alarm list, updated to reflect any changes made during testing.

4. Test plan

A written test plan and specification documenting the tests to be conducted, the applicable acceptance criteria to be used for each test, safety instructions, facilities/tools/hardware/software, and staffing should be developed and agreed to by buyer and the vendor in advance of the tests. This plan should clarify who, the buyer or the vendor, is to perform each test and the criteria for acceptance of test results. The test plan should address all of the following areas applicable to the specific project per the URS and FRS:

- Overall scope of the tests, including hardware, software, configuration/programming, documentation, etc.;
- Hardware, including construction, spare space, access for maintenance, agreement with drawings, wiring/cabling, terminations, labeling in accordance with project documentation/drawings, requirements, and acceptance criteria;
- Performance of required application-related functions and operator interface and controls, including simulation of system inputs and outputs and acceptance criteria;
- Performance of system-related functions and acceptance criteria;
- Provision of adequate infrastructure by the vendor to demonstrate the required functionality;
- Review of software revisions, updates or modifications to date from the time the software was downloaded to the system and any vendor's recommended updates which are considered as a fix;
- Interoperability testing of intelligent field devices with the system (i.e., highway addressable remote transducer (HART), fieldbus, etc.);
- Review of vendor's report of tests and checks performed on the system and readiness of the system for FAT;
- Review of application programming, operator graphics, and database completeness;
- Development of an action plan of how to handle all tests that were not completed during the FAT, excluded from the FAT, or require re-performance after the FAT;
- Testing of the system grounding before energization;
- Testing of interfaces to other systems or subsystems;

- Review of hardware and/or software (e.g. third party) specifically excluded from the FAT
- and how and when it will be tested; and
- System in operation mode with all network and system security functioning (field settings in place).

NOTE 1 Refer to IEC TR 63082-1 for intelligent device management.

NOTE 2 Refer to Annex A for an example of a testing checklist.

For security related FAT processes could refer to 6.5.1.4.1 to develop OT Security Inspection and Test Protocol (Test plan) for additional guidance.

5. Test schedule

   A test schedule (activities and time schedule) should be mutually agreed upon between the buyer and the vendor. Staffing requirements should be agreed upon between the buyer and all other parties to satisfy schedule requirements. The FAT schedule should be reviewed to confirm that it supports the project schedule for when the SuC system is required to be delivered on site.

7.9.2.4 FAT punch list

1. General

   With respect to the test specification, any incomplete work or non-conformances detected during the FAT should be recorded on a punch list for correction of same by the party agreed upon by the vendor and the buyer. Each punchlist item should be assigned one of the following categories:

- Immediate – FAT to be paused for rectification, FAT to continue after rectification;
- On-going – Rectification during FAT, will be completely rectified by end of FAT (typically for multiple instances of the same issue, each of which will be rectified as encountered and by the end of the FAT, all will be rectified. Rectification is performed before test. If later re-test is required, the item is classified as "Repeat");
- Repeat – FAT to be repeated for this item after rectification and before completion of FAT;
- Before shipment – To be rectified after FAT but before the system is shipped to the site, re-test, if any, to be documented and conducted during SAT;
- At site – Remaining work to be rectified after shipment, i.e., at site, and re-test, if any, to be documented and conducted during SAT or SIT; or
- Future – To capture issues not in the project or FAT scope but something to be addressed in the future.

A FAT punch list, at a minimum, should include:

- reference to the applicable specification/FAT test plan requirement;
- description of the issue;
- description of the resolution and date completed; and
- sign-off area for buyer and the vendor for acceptance, if not recorded otherwise.

2. Correction

As items on the punch list are rectified, verification should be documented. For any changes or corrections made during the FAT that can in any way affect previously completed tests, those tests should be re-performed and documented.

3. Corrections after FAT

All problem corrections and subsequent re-checks should be executed during the FAT. If this is not possible, problem rectification can be undertaken after the FAT if mutually agreed to by buyer and the vendor. Problem correction to be completed after the FAT should include the following steps:

- Identification of re-work needed;
- Action plan/time schedule, including responsible person(s);
- Execution of re-work;
- Re-test (of re-work and anything possibly affected by the re-work);

NOTE Whether the buyer is to witness the re-test is to be agreed upon with the vendor.

- Notification of completion; and
- Acceptance of re-check.

7.9.2.5 Documentation of FAT

1. General

The results of the FAT should be completely documented, including:

a) FAT report;

b) FAT final documentation; and

c) FAT completion.

2. FAT report

Minutes or a report of the FAT should be developed and issued to all parties reflecting:

- Attendees;
- Tests performed;
- Open issues and agreements for their resolution; and

- Buyer approval to ship or other disposition of the system.

3. FAT final documentation

   Final documentation of the FAT should include:

   - Signed copies of the test function plans;
   - Dated and signed copies of all other documents generated during the FAT;
   - FAT punch list, updated with the latest status of each item;
   - Documentation of the actual hardware and software (including versions) tested;
   - Documentation of all software and hardware configurable parameters used;
   - Backup copy(ies) of the final complete system and application software;
   - Documentation of system loading observed during the test and spare capacity;
   - An index and color copies of all applicable graphic displays; and
   - Update of all system-related documentation to reflect the FAT-complete status of the system.

7.9.2.6 FAT completion

The FAT should be considered complete when all the required functions have been demonstrated and verified to be in accordance with the FAT plan and specifications, with the exception of the mutually agreed remaining punch list items. Upon successful completion of the FAT, authorized representatives of the buyer and the vendor should sign the FAT test results/report. If a formal certificate is required, the form can be provided by the buyer or the vendor. The vendor should ensure the preservation of the final state of the FAT to guarantee that there are no modifications or subsequent interventions in the equipment.

7.9.3 Factory integration test (FIT)

7.9.3.1 General

This Clause provides the activities that are precursors to, conducted during, and provided after the FIT. The FIT is an optional test that can be conducted after or in conjunction with the FAT at the factory before shipment of the system. The purpose of the FIT is to conduct some, or all the SIT integration tests at the factory to identify and resolve problems earlier and at lower cost than in the field. Like the SIT, the FIT demonstrates that interconnected systems function together in order to achieve results based on the control philosophy and project-specific requirements. Performing a FIT can present financial or schedular advantages for the project. All interested parties (e.g., buyer, vendor(s)) should agree on whether a FIT will be

performed for the specific project and, if so, the scope and schedule for that test.

Tests conducted in the FIT are a partial or complete set of system interoperability tests to be conducted in the field during the SIT. Whether or not these tests were performed during the FIT, all the SIT tests should be performed during the SIT in the field, after installation of all systems, subsystems and components.

7.9.3.2 Performance

The FIT, if to be performed, should be performed after completion of or in conjunction with the FAT and prior to shipment of the system to the owner.

NOTE The FIT typically is performed by the vendor. The buyer typically witnesses the test activities. There can be buyers who want to carry out some parts of the FIT themselves. This is established on a project-related basis.

7.9.3.3 Pre-FIT activities

1. General

   Prior to commencing the FIT, the following activities should be completed:

   a) FAT, including updated FAT punch list;
   b) FIT test plan; and
   c) FIT test schedule.

2. Test plan

   A written test plan and specification documenting the tests to be conducted, the applicable acceptance criteria to be used for each test, safety instructions, facilities/tools/hardware/software, and staffing should be developed and agreed to by buyer and the vendor(s) in advance of the tests. This plan should clarify who, buyer or the vendor, is to perform each test and the criteria for acceptance of test results. The test plan should address all the following areas applicable to the specific project:

   - Overall scope of the tests, including systems, hardware, software, configuration/programming, documentation, etc.;
   - Tests to confirm interoperability of systems involved; and
   - FAT functional tests of individual systems to be re-performed after interface to other system(s).

   NOTE Refer to Annex C for an example of a testing checklist.

3. Test schedule

   A test schedule (activities and time schedule) should be mutually agreed upon between buyer and the vendor(s). Staffing requirements should be agreed upon between the buyer and all other parties to satisfy schedule requirements.

7.9.3.4 FIT punch list

1. General

   With respect to the test specification, any incomplete work or non-conformances detected during the FIT should be recorded on a punch list for correction of same by the appropriate party. Punch list items should be categorized as follows:

   - Immediate – FIT to be paused for rectification, FIT to continue after rectification;
   - On-going – Rectification during FIT, will be completely rectified by end of FIT (typically for multiple instances of the same issue, each of which will be rectified as encountered and by the end of the FIT, all will be rectified. Rectification is performed before test. If later re-test is required, the item is classified as "Repeat");
   - Repeat – FIT to be repeated for this item after rectification and before completion of FIT;
   - Before shipment – To be rectified after FIT but before the system is shipped to the site, re-test, if any, to be documented and conducted during SIT;
   - At site – Remaining work to be rectified after shipment, i.e., at site, and re-test, if any, to be documented and conducted during SAT or SIT; or
   - Future – To capture issues not in the project or FIT scope but something to be addressed in the future.

   A FIT punch list, at a minimum, should include:

   - reference to specification/FIT test plan requirement;
   - description of the issue;
   - person(s) responsible for resolution;
   - description of the resolution and date completed; and
   - sign-off area for buyer and the vendor for acceptance, if not handled otherwise.

2. Correction

   As items on the punch list are rectified, verification should be documented. Any changes or corrections made during the FIT that can in any way affect previously completed tests require that those tests be re-performed and documented.

3. Correction after FIT

All problem corrections and subsequent re-checks should be executed during the FIT. If this is not possible, problem rectification can be undertaken after the FIT if mutually agreed to by buyer and the vendor. Problem correction to be completed after the FIT should include the following steps:

- Identification of re-work needed;
- Action plan/time schedule, including responsible person(s);
- Execution of re-work;
- Re-test, of re-work and anything possibly affected by the re-work, including agreement with the vendor on the possible need for the buyer to witness re-test;
- Notification of completion; and
- Acceptance of re-check.

7.9.3.5 Documentation of FIT

1. General

   The results of the FIT should be completely documented, including:

   a) FIT report;

   b) FIT final documentation; and

   c) FIT completion.

2. FIT report

   Minutes or a report of the FIT should be developed and issued to all parties reflecting:

   - Attendees;
   - Tests performed;
   - Open issues and agreements for their resolution; and
   - Buyer acceptance of the system, with or without issues.

3. FIT final documentation

   Final documentation of the FIT should include:

   - Signed copies of the test function plans;
   - Dated and signed copies of all other documents generated during the FIT;
   - FIT punch list, updated with the latest status of each item;
   - Documentation of the actual hardware and software (including versions) tested;
   - Documentation of all software and hardware configurable parameters used;
   - Backup copy(ies) of the final complete system and application software;
   - Documentation of system loading observed during the test and spare capacity;
   - An index and color copies of any graphic displays modified or added since the

FAT; and

- Update of all system-related documentation to reflect the FIT-complete status of the system.

7.9.3.6 FIT completion

The FIT should be considered complete when all the required functions have been demonstrated and verified to be in accordance with the FIT plan and specifications, with the exception of the mutually agreed remaining punch list items. Upon successful completion of the FIT, authorized representatives of the buyer and the vendor(s) should sign the FIT test results/report. If a formal certificate is required, the form can be provided by the buyer or the vendor. The vendor should ensure the preservation of the final state of the FIT to guarantee that there are no modifications or subsequent interventions in the equipment.

7.9.4 Site acceptance test (SAT)

7.9.4.1 Performance

The SAT should be performed after the delivery and installation of the system at the site. The SAT is performed to demonstrate the proper functionality of the system after delivery and installation.

NOTE The SAT typically is performed by the vendor. The buyer typically witnesses the test activities. There can be buyers who want to carry out some parts of the SAT themselves. This is established on a project-related basis.

For security related SAT processes could refer to 7.6.1 3. OT Security SAT Test for additional guidance.

7.9.4.2 Pre-SAT activities

1. General

Prior to conducting the SAT, the relevant hardware/software components should be delivered to the site and properly installed. The following items should be completed during the installation of the SuC system/subsystem/components before the SAT can be carried out:

- Hardware installation (all system components including controllers, I/O cards, marshalling racks, power supplies, operating/engineering stations);

- Grounding system installed for the relevant hardware being tested;
- Network communications installed (for example, hubs, switches);
- Review of software revisions, updates or modifications from FAT to date;
- SuC system power up and download of correct software;
- A full backup of any software/code that has been installed at the start of the SAT test; and
- I/O check of any I/O that will be tested during the SAT.

2. Test plan

A written test plan and specification documenting the tests to be conducted, the applicable acceptance criteria to be used for each test, safety instructions, facilities/tools/hardware/software, and staffing should be developed and agreed to by buyer and the vendor in advance of the tests. This plan should clarify who, buyer or the vendor, is to perform each test and the criteria for acceptance of test results. The test plan should address all the following areas applicable to the specific project:

- Overall scope of the tests, including hardware, software, configuration/programming, documentation, etc.;
- Hardware, including installation, agreement with installation drawings, wiring/cabling, terminations, labeling as per project documentation/drawings, requirements, and acceptance criteria;
- Software, including the loaded SuC system software and the loaded custom configuration, programs and graphics are the correct version and are functioning properly;
- FAT functional tests to be re-performed after installation;
- FAT tests that were not performed/completed during the FAT and completion of any other open FAT punch list items;
- FIT functional tests to be re-performed after installation;
- FIT tests that were not performed/completed during the FIT and completion of any other open FIT punch list items;
- Network and system security (e.g. proper firewall rules and network segmentation); and
- Tests such as interlock checks, complex functionality checks and sequence or batch checks, which are to be performed after loop checks.

Hardware and software configurations should comply with FAT results.

NOTE Refer to Annex B for an example of a testing checklist.

For security related SAT processes could refer to 6.5.1.4.1 to develop OT Security

Inspection and Test Protocol and 7.5 Perform Application Security Testing to develop the Security Solution Integration testing Plan for additional guidance.

3. Test schedule

A test schedule (activities and time schedule) should be mutually agreed upon between the buyer and the vendor. Staffing requirements should be agreed upon between the buyer and all other parties to satisfy schedule requirements. The SAT contains checks that are to be performed before loop checks and can contain checks that are to be performed after loop checks.

NOTE For guidance for loop checks refer to IEC 62382.

7.9.4.3 SAT punch list

1. General

With respect to the test specification, any incomplete work or non-conformances detected during the SAT should be recorded on a punch list for correction of same by the appropriate party. Each punchlist item should be assigned one of the following categories:

- Immediate – SAT to be paused for rectification, SAT to continue after rectification;
- On-going – Rectification during SAT will be completely rectified by end of SAT (typically for multiple instances of the same issue, each of which will be rectified as encountered and by the end of the SAT, all will be rectified. Rectification is performed before test. If later re-test is required, the item is classified as "Repeat".);
- Repeat – SAT to be repeated for this item after rectification and before completion of SAT; or
- Future – Something that is not required to be resolved prior to the start of commissioning or that is captured as an issue not in the project or SAT scope but something to be addressed in the future.

A SAT punch list, at a minimum, should include:

- reference to specification/SAT test plan requirement;
- description of the issue;
- person(s) responsible for resolution;
- description of the resolution and date completed; and
- sign-off area for buyer and the vendor for acceptance, if not recorded otherwise.

2. Correction

As items on the punch list are rectified, verification should be documented. Any changes or corrections made during the SAT that can in any way affect previously completed tests require that those tests be re-performed and documented.

3. Correction after SAT

All problem corrections and subsequent re-checks should be executed during the SAT. If this is not possible, problem rectification can be undertaken after the SAT if mutually agreed to by the buyer and the vendor. Problem correction to be completed after the SAT should include the following steps:

- Identification of re-work needed;
- Action plan/time schedule, including responsible person(s);
- Execution of re-work;
- Re-test, of re-work and anything possibly affected by the re-work, including agreement with the vendor on the possible need for the buyer to witness the re-test;
- Notification of completion; and
- Acceptance of re-check.

7.9.4.4 Documentation of SAT

1. General

The results of the SAT should be completely documented, including:

a) SAT report;

b) SAT final documentation; and

c) SAT completion.

2. SAT report

Minutes or a report of the SAT should be developed and issued to all parties reflecting:

- Attendees;
- Tests performed;
- Open issues and agreements for their resolution; and
- Buyer acceptance of the system, with or without open issues.

3. SAT final documentation

Final documentation of the SAT should include:

- Signed copies of the test function plans;
- Dated and signed copies of all other documents generated during the SAT;

- SAT punch list, updated with the latest status of each item;
- Documentation of the actual hardware and software (including versions) tested;
- Documentation of all software and hardware configurable parameters used;
- Backup copy(ies) of the final complete system and application software;
- Documentation of system loading observed during the test and spare capacity;
- An index and color copies of any graphic displays modified or added since the FAT; and
- Update of all system-related documentation to reflect the SAT-complete status of the system.

7.9.4.5 SAT completion

The SAT should be considered complete when all the required functions have been demonstrated and verified to be in accordance with the SAT plan and specifications, with the exception of the mutually agreed remaining punch list items. Upon successful completion of the SAT, authorized representatives of the buyer and the vendor should sign the SAT test results/report. If a formal certificate is required, the form can be provided by the buyer or the vendor. The vendor should ensure the preservation of the final state of the SAT to guarantee that there are no modifications or subsequent interventions in the equipment.

7.9.5 Site integration test (SIT)

7.9.5.1 Performance

The SIT should ensure that interconnected systems function together in order to achieve results based on the control philosophy and project-specific requirements. The SIT consists of testing the communication and interaction between the automation subsystems or with other systems to ensure desired functional performance. The SIT can be one overall test with multiple sections, one for each subsystem, or it can be multiple tests, one for each subsystem.

The SIT should be performed after the SAT for each system/subsystem involved has been successfully completed. The SIT is performed to test the combination of two or more independent systems that have been connected in order to obtain the functionality desired by the control philosophy for the complete SuC system. For example, a SIT should be conducted when integrating the following types of systems that communicate in any way with other parts of the SuC system using other than traditional I/O (e.g. analog inputs/outputs, discrete inputs/outputs), the

functionality of which is verified in the loop tests:

- SuC systems that are part of an equipment package unit and have their own DCS/PLC or controller;
- Analyzer systems;
- Safety instrumented systems;
- Combining DCS/PLCs from more than one vendor or manufacturer;
- Higher level systems such as MES, ERP; and
- Any other communications between automation subsystems or between the SuC system and any other systems.

NOTE The SIT typically is performed by the vendor. The buyer typically witnesses the test activities. There can be buyers who want to carry out some parts of the SIT themselves. This is established on a project-related basis.

For security related SIT processes could refer to 7.6.1 4. OT Security SIT Test for additional guidance.

7.9.5.2 Pre-SIT activities

1. General

   Prior to conducting the SIT, the relevant hardware/software components of all systems and subsystems to be involved in the SIT should have satisfactorily completed their respective SAT. Installation of all communications and interconnections (e.g., direct connected signals or network physical interface layer) between systems and subsystems should be complete. A full backup of any software/code that has been installed at the start of the SIT test should be made.

2. Test plan

   A written test plan and specification documenting the tests to be conducted, the applicable acceptance criteria to be used for each test, safety instructions, facilities/tools/hardware/software, and staffing should be developed and agreed to by the buyer and the vendor(s) in advance of the tests. This plan should clarify who, the buyer or the vendor, is to perform each test and the criteria for acceptance of test results. The test plan should address all of the following areas applicable to the specific project:

   - Overall scope of the tests, including systems, hardware, software, configuration/programming, documentation, etc.;
   - Tests to confirm interoperability of systems involved; and
   - FAT or SAT functional tests of systems to be re-performed after interface to other

system(s).

NOTE Refer to Annex C for an example of a testing checklist.

For security related SIT processes could refer to 6.5.1.4.1 to develop OT Security Inspection and Test Protocol and 7.6.1 2. Security Inspection for additional guidance.

3. Test schedule

A test schedule (activities and time schedule) should be mutually agreed upon between buyer and the vendor(s). Staffing requirements should be agreed upon between the buyer and all other parties to satisfy schedule requirements.

7.9.5.3 SIT punch list

1. General

With respect to the test specification, any incomplete work or non-conformances detected during the SIT should be recorded on a punch list for correction of same by the appropriate party. Punch list items should be categorized as follows:

- Immediate – SIT to be paused for rectification, SIT to continue after rectification;
- On-going – Rectification during SIT, will be completely rectified by end of SIT (typically for multiple instances of the same issue, each of which will be rectified as encountered and by the end of the SIT, all will be rectified. Rectification is performed before test. If later re-test is required, the item is classified as "Repeat");
- Repeat – SIT to be repeated for this item after rectification and before completion of SIT; and
- Future – Something that is not required to be resolved prior to the start of commissioning or that is captured as an issue not in the project or SIT scope but something to be addressed in the future.

A SIT punch list, at a minimum, should include:

- reference to specification/SIT test plan requirement;
- description of the issue;
- person(s) responsible for resolution;
- description of the resolution and date completed; and
- sign-off area for owner and the vendor for acceptance, if not handled otherwise.

2. Correction

As items on the punch list are rectified, verification should be documented. Any changes or corrections made during the SIT that can in any way affect previously completed tests require that those tests be re-performed and documented.

3. Correction after SIT

   All problem corrections and subsequent re-checks should be executed during the SIT. If this is not possible, problem rectification can be undertaken after the SIT if mutually agreed to by the buyer and the vendor. Problem correction to be completed after the SIT should include the following steps:

   - Identification of re-work needed;
   - Action plan/time schedule, including responsible person(s);
   - Execution of re-work;
   - Re-test, of re-work and anything possibly affected by the re-work, including agreement with the vendor on the possible need for the buyer to witness the re-test;
   - Notification of completion; and
   - Acceptance of re-check.

7.9.5.4 Documentation of SIT

1. General

   The results of the SIT should be completely documented, including:

   a) SIT report;

   b) SIT final documentation; and

   c) SIT completion.

2. SIT report

   Minutes or a report of the SIT should be developed and issued to all parties reflecting:

   - Attendees;
   - Tests performed;
   - Open issues and agreements for their resolution; and
   - Buyer acceptance of the system, with or without open issues.

3. SIT final documentation

   Final documentation of the SIT should include:

- Signed copies of the test function plans;
- Dated and signed copies of all other documents generated during the SIT;
- SIT punch list, updated with the latest status of each item;
- Documentation of the actual hardware and software (including versions) tested;
- Documentation of all software and hardware configurable parameters used;
- Backup copy(ies) of the final complete system and application software;
- Documentation of system loading observed during the test and spare capacity;
- An index and color copies of any graphic displays modified or added since the FAT; and
- Update of all system-related documentation to reflect the SIT-complete status of the system.

7.9.5.5 SIT completion

The SIT should be considered complete when all the required functions have been demonstrated and verified to be in accordance with the SIT plan and specifications, with the exception of the mutually agreed remaining punch list items. Upon successful completion of the SIT, authorized representatives of the buyer and the vendor(s) should sign the SIT test results/report. If a formal certificate is required, the form can be provided by the buyer or the vendor. The vendor should ensure the preservation of the final state of the SIT to guarantee that there are no modifications or subsequent interventions in the equipment.

.

8.0 Tables 表格

8.1 The SI,SM Project and System Security Management Guideline – Annexes (整合/維護服務專案和系統安全 - 附件)

The templates and tables cited in the article of the SI,SM Project and System Security Management Guideline

Template Caption/Table Caption	Page No. in the Annexes	Section in the Article of the Guide
Annexes A: Practice Examples for Security Implementation		
Annexes A.1: Security Management Plan (Example)	4	7.1.1.1
Annexes A.2: Security Vendor Management Plan (Example)	4	7.1.1.2
Annexes A.3: SI/SM Project Security Management Plan (Example)	5	7.1.1.3
Annexes A.4: Security Policies and Procedures Plan (Example)	6	7.1.1.4
Annexes A.5: Data Flow Diagram (Example)	9	7.2.1 1. 7.2.1 3. 7.3.1 2.
Annexes A.6: Inventory Asset List (Example)	11	7.2.1 2. 7.3.1 1.
Annexes A.7: Simple Network Diagram (Example)	12	7.2.1 3.
Annexes A.8: Threat and Risk Assessment Report (Example)	14	7.2.1 9. 7.3.1
Annexes A.9: Security Functional Description Specifications (Example)	16	7.4.1 7.4.1.12
Annexes A.10: IACS Automation Solutions/Asset Hardening Recommended Practices (Example)	20	7.4.1.5
Annexes A.11: OT Security Inspection and Test Protocol (FAT/SAT Test Case) (Example)	21	6.5.1.4.1
Annexes B: Annexes Related to the Security Policy and Procedure		
Annexes B.1: Key Competencies of Roles for the Project/System or the Project	22	6.2.1.1 1.
Annexes B.2: Organizational Independence for the Project Security Assurance Organization	28	6.2.2 1.
Annexes B.3: The Proforma Form for Verifying File Integrity	34	7.4.1.4 1.(2)
Annexes B.4: The corresponding Security program process and guidelines	35	6.5.1 7.0
Annexes C: security Verification Checklist for Security Implementation		

Template Caption/Table Caption	Page No. in the Annexes	Section in the Article of the Guide
Table C.1: The Security Plan Checklist	48	7.1.2
Table C.2: Threat and Preliminary Risk Assessment (TRA) Verification Checklist	53	7.2.2 2.
Table C.3: Network Architecture Documentation Verification Checklist	55	7.2.2 3.
Table C.4: Inventory Asset List Verification Checklist	57	7.2.2 3.
Table C.5: Critical Security Design Verification Checklist	58	7.3.2 3.(5)
Table C.6: Documents of System Security Countermeasures Verification Checklist	62	7.4.2 2.
Table C.7: System Security Acceptance Testing Verification Checklist	111	7.6.2 2.
Table C.8: Operation and Support/Maintenance Verification Checklist	115	7.7.2 2.

8.2 The tasks of Secure Project/System development lifecycle and the reference sections for implementation with mapping to IEC 62443-2-4 SP requirements

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
Concept/ Specification - Tendering/ Acquisition (R0)	Tender Security Requirements	Tender Security Requirements	SSA-PRO-001	Tender Security Requirements	0.01	(ID01) 6.5.1.1.1		
	Tender Security Evaluation	Tender Security Evaluation	SSA-PRO-002	Security Compliance Report	0.02	(ID01) 6.5.1.1.2		
	C0 Control Gate	R0 Gate Review	SSA-PRO-003	Security Requirements	0.03			
Concept/ Specification - Project Initiation (R1)	Security Planning & Risk Assessment	Security Planning	SSA-PLN-001	Security Management Plan	1.01	(ID01) 6.5.1.2.1	(ID01) 7.1.1.1 1. (ID01) 7.1.1.1 2. (ID01) 7.1.1.1 5.~6. (ID01) 7.1.1.1 6. (ID01) 7.1.1.1 4.~7. (ID01) 7.1.1.4 (ID01) 7.1.3 1. (ID01) 7.1.3 2. (ID01) 7.1.3	SP.01.02 BR SP.01.02 RE(1) SP.01.01 BR SP.01.01 RE(1) SP.01.03 BR SP.01.02 BR SP.01.01 BR SP.01.01 RE(1)

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
							(ID01) 7.1.3 3. (ID01) 7.1.3 1. & 4. (ID02) Annexes A.1 12.	SP.01.02 BR SP.01.02 RE(1) SP.01.03 BR SP.01.02 RE(1)
				Vendor (and/or Subcontractors) Security Management Plan	1.02	(ID01) 6.5.1.2.1	(ID01) 7.1.1.2 1. (ID01) 7.1.1.2 2. (ID01) 7.1.1.2 3.~7. (ID01) 7.1.3 (ID01) 7.1.3 1. & 4. (ID02) Annexes A.2 (ID05) 5.2 (ID05) 8.0	SP.01.02 BR SP.01.02 RE(1) SP.01.01 RE(1) SP.01.01 RE(1) SP.01.03 RE(1) SP.01.03 RE(1) SP.01.04 RE(1)
				SI/SM Project Security Management Plan	PSMP	(ID01) 6.5.1.2.1	(ID01) 7.1.1.3 (ID01) 7.1.1.3 1. (ID01) 7.1.1.3 2. (ID01) 7.1.1.3 2. (ID01) 7.1.1.3 3. (ID01) 7.1.1.3 4. (ID01) 7.1.1.3 5. (ID01) 7.1.3 1. (ID01) 7.1.3 4. (ID01) 7.4.1.1. (ID02) Annexes A.3 (ID03) 5.3.2 (ID03) 5.2.1 (ID03) 5.3.4 1. (ID03) 5.3.2	SP.01.03 BR SP.01.02 RE(1) SP.01.04 BR SP.01.04 RE(1) SP.01.05 BR SP.01.06 BR SP.01.07 BR SP.01.03 BR SP.01.03 RE(1) SP.02.01 BR SP.01.01 BR SP.01.03 BR

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
							(ID03) 5.3.3 (ID03) 5.3.4 1. (ID03) 5.6.3 (ID04) 7.0 (ID04) 7.0	SP.01.05 BR SP.01.06 BR SP.01.06 BR SP.01.07 BR SP.02.01 BR SP.01.03 BR SP.01.03 RE(1)
				Security Policies and Procedures - Preliminary	1.03	(ID01) 6.5.1.2.1	(ID01) 7.1.1.4 2. (ID01) 7.1.1.4 2. (ID01) 7.1.1.4 2. (ID01) 7.1.1.4 2. (ID01) 7.1.1.4 2. (ID01) 7.1.2 (ID02) Annexes A.4 5.	SP.02.01 BR SP.02.02 RE(1) SP.02.02 RE(3) SP.03.03 BR SP.03.03 RE(1) SP.02.02 RE(1) SP.02.01 BR
		Systems Security Classification	SSA-REQ-001	Systems security classification		(ID01) 6.5.1.2.2		
		Threat & Risk Assessment (Preliminary)	SSA-REQ-002	Preliminary (or High-level) Security Requirements	1.04	(ID01) 6.5.1.2.3	(ID01) 7.2 (ID01) 7.2.1 4.~7.	SP.02.01 BR SP.03.01 BR
				Simple Network Diagram	1.05	(ID01) 6.5.1.2.3	(ID01) 7.2.1 1. (ID01) 7.2.1 3. Annexes A.7 Annexes A.5	SP.06.01 BR SP.06.01 BR
				Asset Inventory List - Preliminary	1.06	(ID01) 6.5.1.2.3	(ID01) 7.2.1 2. Annexes A.6	SP.06.02 BR

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
				Threat and Risk Assessment Report - Preliminary	1.07	(ID01) 6.5.1.2.3	(ID01) 7.2 (ID01) 7.2.1 9. Annexes A.8	SP.02.01 BR SP.03.01 RE(1)
	C1 Control Gate	R1 Gate Review	SSA-REQ-003	R1 Gate Review		(ID01) 6.5.1.2.4	(ID01) 7.2.2 3. (ID01) 7.2.2 3. (ID01) 6.5.1.2.4 2. (ID01) 6.5.1.2.4 3. (ID01) 6.5.1.2.4 3. (ID01) 6.5.1.2.4 5. (ID01) 6.5.1.2.4 6. (ID01) 6.5.1.2.4 6.	SP.06.03 BR SP.06.02 BR SP.02.02 RE(1) SP.06.01 BR SP.06.02 BR SP.03.01 RE(2) SP.03.03 BR SP.03.03 RE(1)
Development/Design and Development (R2)	Detailed Risk Assessment, if applicable	Detailed risk assessment	SSA-DES-001	Asset Inventory List	2.01	(ID01) 6.5.1.3.1	(ID01) 7.3.1 1. Annexes A.6	SP.06.01 RE(1)
				Network and Data Flow Diagram	2.02	(ID01) 6.5.1.3.1	(ID01) 7.3.1 2. Annexes A.5	SP.06.01 RE(1)
				Detailed Threat and Risk Assessment Report	2.03	(ID01) 6.5.1.3.1	(ID01) 7.2 (ID01) 7.3.1 3. (ID01) 7.3.1 4. (1) (ID01) 7.3.1 4. (2)~(3) (ID01) 7.3.1 4. (4) (ID01) 7.3.1 4. (4) (ID01) 7.3.1 5. (ID01) 7.3.1 6. (ID01) 7.3.1 6. (ID01) 7.3.1 6. (ID01) 7.3.1 7. (ID01) 7.3.1 8.	SP.02.01 BR SP.03.01 BR SP.03.02 RE(1) SP.03.02 RE(2) SP.03.10 BR SP.03.10 RE(1) SP.04.01 BR SP.04.03 BR SP.04.03 RE(1) SP.04.03

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
							Annexes A.8	RE(2) SP.03.01 RE(1) SP.05.01 BR
				Security Risk Mitigation Plan and Requirement Specifications	2.04	(ID01) 6.5.1.3.1		
	Critical Security Design Review	Security Architecture Review	SSA-DES-002	Review Security Architecture		(ID01) 6.5.1.3.2-1.	(ID01) 7.2.1 8. (ID01) 7.3.2 1.	SP.03.01 RE(2) SP.05.01 BR
		Security Controls Review	SSA-DES-003	Review Security Controls		(ID01) 6.5.1.3.2-2.	(ID01) 6.5.1.3.2-2. (ID01) 7.3.2 2.	SP.03.01 RE(1) SP.05.01 BR
	C2 Control Gate	R2 Gate Review	SSA-DES-004	R2 Gate Review			(ID01) 7.3.1 7. (ID01) 7.3.1 9.	SP.03.01 RE(1) SP.03.01 RE(2)
Production/ Implementation and Verification and Validation (R3)	Implementation of the System security countermeasures	Implementation of the System security countermeasures	SSA-ENG-001	IACS Automation Solutions/Asset Hardening Recommended Practices	3.01	(ID01) 6.5.1.4.1	(ID01) 7.4.1.5 Annexes A.10	SP.02.03 BR
				Security Policies and Procedures (Security Functional Description Specification)	3.02	(ID01) 6.5.1.4.1	(ID01) 7.4.1.1 1. (ID01) 7.4.1.1 2. (ID01) 7.4.1.2 1. (ID01) 7.4.1.2 2. (ID01) 7.4.1.2 3. (ID01) 7.4.1.2 4. (ID01) 7.4.1.2 5. (ID01) 7.4.1.2 6. (ID01) 7.4.1.2 7. (ID01) 7.4.1.2 8. (ID01) 7.4.1.2	SP.02.01 BR SP.02.02 BR SP.03.02 BR SP.03.04 BR SP.03.05 BR SP.03.05 RE(1) SP.03.06 BR SP.03.07 BR SP.03.07 RE(1)

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
							8.(1)	SP.03.08 BR
							(ID01) 7.4.1.2	SP.03.08
							8.(2)	RE(1)
							(ID01) 7.4.1.2	SP.03.08
							8.(3)	RE(2)
							(ID01) 7.4.1.2 9.	SP.03.08
							(ID01) 7.4.1.2 10.	RE(3)
							(ID01) 7.4.1.2	SP.03.09 BR
							10.(1)	SP.03.10 BR
							(ID01) 7.4.1.2	SP.03.10
							10.(2)	RE(1)
							(ID01) 7.4.1.2	SP.03.10
							10.(3)	RE(2)
								SP.03.10
							(ID01) 7.4.1.3 1.	RE(3)
							(ID01) 7.4.1.3 2.	
							(ID01) 7.4.1.3	SP.09.01 BR
							2.(1)	SP.09.02 BR
							(ID01) 7.4.1.3	SP.09.02
							2.(2)	RE(1)
							(ID01) 7.4.1.3	SP.09.02
							2.(3)	RE(2)
							(ID01) 7.4.1.3	SP.09.02
							2.(4)	RE(3)
							(ID01) 7.4.1.3 3.	SP.09.02
							(ID01) 7.4.1.3 4.	RE(4)
							(ID01) 7.4.1.3	SP.09.03 BR
							4.(1)	SP.09.04 BR
							(ID01) 7.4.1.3 5.	SP.09.04
							(ID01) 7.4.1.3 6.	RE(1)
							(ID01) 7.4.1.3	SP.09.05 BR
							6.(1)	SP.09.06 BR
							(ID01) 7.4.1.3 7.	SP.09.06
							(ID01) 7.4.1.3 8.	RE(1)
							(ID01) 7.4.1.3	SP.09.07 BR
							8.(1)	SP.09.08 BR
							(ID01) 7.4.1.3 9.	SP.09.08

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
							(ID01) 7.4.1.3	RE(1)
							9.(1)	SP.09.09 BR
								SP.09.09
							(ID01) 7.4.1.4	RE(1)
							2.(1)	
							(ID01) 7.4.1.4	SP.06.01 BR
							2.(2)	SP.06.01 BR
							(ID01) 7.4.1.4	SP.06.01
							2.(3)	RE(1)
							(ID01) 7.4.1.4	SP.06.03 BR
							2.(4)	
								SP.04.01 BR
							(ID01) 7.4.1.6 1.	SP.04.02 BR
							(ID01) 7.4.1.6 2.	SP.04.02
							(ID01) 7.4.1.6 3.	RE(1)
							(ID01) 7.4.1.6 4.	SP.04.03 BR
							(ID01) 7.4.1.6 5.	SP.04.03
							(ID01) 7.4.1.6 6.	RE(1)
								SP.04.03
							(ID01) 7.4.1.7 1.	RE(2)
							(ID01) 7.4.1.7 2.	
							(ID01) 7.4.1.7 3.	SP.05.02 BR
							(ID01) 7.4.1.7 4.	SP.05.03 BR
							(ID01) 7.4.1.7 5.	SP.05.04 BR
							(ID01) 7.4.1.7 6.	SP.05.05 BR
							(ID01) 7.4.1.7 7.	SP.05.05
							(ID01) 7.4.1.7 8.	RE(1)
							(ID01) 7.4.1.7 9.	SP.05.06 BR
							(ID01) 7.4.1.7	SP.05.07 BR
							9.(1)	SP.05.08 BR
							(ID01) 7.4.1.7	SP.05.09 BR
							9.(2)	SP.05.09
								RE(1)
							(ID01) 7.4.1.8 1.	SP.05.09
							(ID01) 7.4.1.8 2.	RE(2)
							(ID01) 7.4.1.8 3.	
							(ID01) 7.4.1.8 4.	SP.07.01 BR

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
							(ID01) 7.4.1.8 5.	SP.07.02 BR
								SP.07.03 BR
							(ID01) 7.4.1.9 1.	SP.07.04 BR
							(ID01) 7.4.1.9 2.	SP.07.04
							(ID01) 7.4.1.9 3.	RE(1)
							(ID01) 7.4.1.9	
							3.(1)	SP.08.01 BR
							(ID01) 7.4.1.9	SP.08.01
							3.(2)	RE(1)
							(ID01) 7.4.1.9 4.	SP.08.02 BR
							(ID01) 7.4.1.9	SP.08.02
							4.(1)	RE(1)
							(ID01) 7.4.1.9 5.	SP.08.02
								RE(2)
							(ID01) 7.4.1.10 1.	SP.08.03 BR
							(ID01) 7.4.1.10 2.	SP.08.03
							(ID01) 7.4.1.10	RE(1)
							2.(1)	SP.08.04 BR
							(ID01) 7.4.1.10 3.	
							(ID01) 7.4.1.10 4.	SP.10.01 BR
							(ID01) 7.4.1.10 5.	SP.10.02 BR
							(ID01) 7.4.1.10	SP.10.02
							5.(1)	RE(1)
							(ID01) 7.4.1.10	SP.10.03 BR
							5.(2)	SP.10.04 BR
								SP.10.05 BR
							(ID01) 7.4.1.11 2.	SP.10.05
							(ID01) 7.4.1.11	RE(1)
							2.(1)	SP.10.05
							(ID01) 7.4.1.11 3.	RE(2)
							(ID01) 7.4.1.11	
							3.(1)	SP.11.01 BR
							(ID01) 7.4.1.11	SP.11.01
							3.(2)	RE(1)
							(ID01) 7.4.1.11 4.	SP.11.02 BR
							(ID01) 7.4.1.11 5.	SP.11.02
							(ID01) 7.4.1.11 6.	RE(1)

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
							(ID01) 7.4.1.11 7. (ID01) 7.4.1.11 7.(1) (ID01) 7.4.1.11 7.(2) (ID01) 7.4.1.11 7.(3) (ID01) 7.4.1.12 1. (ID01) 7.4.1.12 2. (ID01) 7.4.1.12 3. (ID01) 7.4.1.12 4. (ID01) 7.4.1.12 5. (ID01) 7.4.1.12 6. (ID01) 7.4.1.12 7. (ID01) 7.4.1.12 8. (ID01) 7.4.1.12 9. (ID01) 7.4.2 Annexes A.9	SP.11.02 RE(2) SP.11.03 BR SP.11.04 BR SP.11.05 BR SP.11.06 BR SP.11.06 RE(1) SP.11.06 RE(2) SP.11.06 RE(3) SP.12.01 BR SP.12.02 BR SP.12.03 BR SP.12.04 BR SP.12.05 BR SP.12.06 BR SP.12.07 BR SP.12.08 BR SP.12.09 BR
				Security Solution Integration Plan for Security Policy and Procedure Design Best Practices	3.03	(ID01) 6.5.1.4.1		
				Security Inspection and Test Protocol	3.04	(ID01) 6.5.1.4.1	(ID01) 7.5 1.(1) (ID01) 7.5 2.(1) (ID01) 7.5 2.(2) (ID01) 7.5 2.(3) (ID01) 7.5 2.(3)	SP.02.02 BR SP.03.07 BR SP.03.07 RE(1) SP.03.08 BR

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
							(ID01) 7.5 2.(3)	SP.03.08
							(ID01) 7.5 2.(3)	RE(1)
							(ID01) 7.5 2.(4)	SP.03.08
							(ID01) 7.5 2.(5)	RE(2)
							(ID01) 7.5 2.(5)	SP.03.08
							(ID01) 7.5 2.(5)	RE(3)
							(ID01) 7.5 2.(5)	SP.03.09 BR
							(ID01) 7.5 3.(1)	SP.03.10 BR
							(ID01) 7.5 3.(2)	SP.03.10
							(ID01) 7.5 3.(2)	RE(1)
							(ID01) 7.5 3.(2)	SP.03.10
							(ID01) 7.5 3.(2)	RE(2)
							(ID01) 7.5 3.(2)	SP.03.10
							(ID01) 7.5 3.(3)	RE(3)
							(ID01) 7.5 3.(4)	SP.09.01 BR
							(ID01) 7.5 3.(4)	SP.09.02 BR
							(ID01) 7.5 3.(5)	SP.09.02
							(ID01) 7.5 3.(6)	RE(1)
							(ID01) 7.5 3.(6)	SP.09.02
							(ID01) 7.5 3.(7)	RE(2)
							(ID01) 7.5 3.(8)	SP.09.02
							(ID01) 7.5 3.(9)	RE(3)
							(ID01) 7.5 3.(10)	SP.09.02
							(ID01) 7.5 3.(10)	RE(4)
								SP.09.03 BR
							(ID01) 7.5 4.(1)	SP.09.04 BR
							(ID01) 7.5 4.(2)	SP.09.04
							(ID01) 7.5 4.(3)	RE(1)
							(ID01) 7.5 5.(1)	SP.09.05 BR
							(ID01) 7.5 6.(1)	SP.09.06 BR
							(ID01) 7.5 6.(2)	SP.09.06
							(ID01) 7.5 6.(3)	RE(1)
							(ID01) 7.5 6.(4)	SP.09.07 BR
							(ID01) 7.5 6.(5)	SP.09.08 BR
								SP.09.08
							(ID01) 7.5 7.(1)	RE(1)
							(ID01) 7.5 7.(2)	SP.09.09 BR

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
							(ID01) 7.5 7.(3)	SP.09.09
							(ID01) 7.5 7.(4)	RE(1)
							(ID01) 7.5 7.(5)	
							(ID01) 7.5 7.(6)	SP.06.01 BR
							(ID01) 7.5 7.(7)	SP.06.01 BR
							(ID01) 7.5 7.(8)	SP.06.01
							(ID01) 7.5 7.(9)	RE(1)
							(ID01) 7.5 7.(9)	SP.02.03 BR
							(ID01) 7.5 7.(9)	SP.04.01 BR
							(ID01) 7.5 8.(1)	SP.04.02 BR
							(ID01) 7.5 8.(2)	SP.04.02
							(ID01) 7.5 8.(3)	RE(1)
							(ID01) 7.5 8.(4)	SP.04.03
							(ID01) 7.5 8.(5)	RE(1)
							(ID01) 7.5 9.(1)	SP.04.03
							(ID01) 7.5 9.(2)	RE(2)
							(ID01) 7.5 9.(3)	
							(ID01) 7.5 9.(3)	SP.05.02 BR
							(ID01) 7.5 9.(3)	SP.05.03 BR
							(ID01) 7.5 9.(4)	SP.05.04 BR
							(ID01) 7.5 9.(4)	SP.05.05 BR
							(ID01) 7.5 9.(5)	SP.05.05
								RE(1)
							(ID01) 7.5 10.(1)	SP.05.06 BR
							(ID01) 7.5 10.(2)	SP.05.07 BR
							(ID01) 7.5 10.(2)	SP.05.08 BR
							(ID01) 7.5 10.(3)	SP.05.09 BR
							(ID01) 7.5 10.(4)	SP.05.09
							(ID01) 7.5 10.(5)	RE(1)
							(ID01) 7.5 10.(5)	SP.05.09
							(ID01) 7.5 10.(5)	RE(2)
							(ID01) 7.5 11.(1)	SP.07.01 BR
							(ID01) 7.5 11.(1)	SP.07.02 BR
							(ID01) 7.5 11.(1)	SP.07.03 BR
							(ID01) 7.5 11.(2)	SP.07.04 BR
							(ID01) 7.5 11.(2)	SP.07.04
							(ID01) 7.5 11.(3)	RE(1)

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
							(ID01) 7.5 11.(4)	SP.08.01 BR
							(ID01) 7.5 11.(5)	SP.08.01
							(ID01) 7.5 11.(6)	RE(1)
							(ID01) 7.5 11.(6)	SP.08.02 BR
							(ID01) 7.5 11.(6)	SP.08.02
							(ID01) 7.5 11.(6)	RE(1)
							(ID01) 7.5 12.(1)	SP.08.02
							(ID01) 7.5 12.(2)	RE(2)
							(ID01) 7.5 12.(3)	SP.08.03 BR
							(ID01) 7.5 12.(4)	SP.08.03
							(ID01) 7.5 12.(5)	RE(1)
							(ID01) 7.5 12.(6)	SP.08.04 BR
							(ID01) 7.5 12.(7)	
							(ID01) 7.5 12.(8)	SP.10.01 BR
							(ID01) 7.5 12.(9)	SP.10.02 BR
								SP.10.02
								RE(1)
								SP.10.03 BR
								SP.10.04 BR
								SP.10.05 BR
								SP.10.05
								RE(1)
								SP.10.05
								RE(2)
								SP.11.01 BR
								SP.11.01
								RE(1)
								SP.11.02
								RE(2)
								SP.11.02 BR
								SP.11.02
								RE(1)
								SP.11.03 BR
								SP.11.04 BR
								SP.11.05 BR
								SP.11.06 BR

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
								SP.11.06 RE(1) SP.11.06 RE(2) SP.11.06 RE(3) SP.12.01 BR SP.12.02 BR SP.12.03 BR SP.12.04 BR SP.12.05 BR SP.12.06 BR SP.12.07 BR SP.12.08 BR SP.12.09 BR
				Security Verification and Validation Testing Plan (SVVP)	3.05	(ID01) 6.5.1.4.1		
				Incident response and recovery plan	3.06	(ID01) 6.5.1.4.1		
	Application Security Testing	Perform Function / Source Code Review	SSA-ENG-002	Functions/Source Codes Review Report	3.09	(ID01) 6.5.1.4.2-1.		
		Perform Application Security Testing	SSA-ENG-003	SBOM	3.10	(ID01) 6.5.1.4.2-2.	(ID01) 7.5	
	System Security Acceptance Testing	System Security Acceptance Testing	SSA-ENG-004	FAT Test Cases – Related to security	3.07	(ID01) 6.5.1.4.3	(ID01) 7.6.1 1.(1) (ID01) 7.6.1 1.(1) (ID01) 7.6.1 1.(1) (ID01) 7.6.1 1.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 1.(3)	SP.02.02 RE(2) SP.03.03 BR SP.03.03 RE(1) SP.02.03 RE(1)

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
							(ID01) 7.6.1 1.(3)	
							(ID01) 7.6.1 1.(3)	SP.02.02 BR
							(ID01) 7.6.1 1.(3)	SP.03.07 BR
							(ID01) 7.6.1 1.(3)	SP.03.07
							(ID01) 7.6.1 1.(3)	RE(1)
							(ID01) 7.6.1 1.(3)	SP.03.08 BR
							(ID01) 7.6.1 1.(3)	SP.03.08
							(ID01) 7.6.1 1.(3)	RE(1)
							(ID01) 7.6.1 1.(3)	SP.03.08
							(ID01) 7.6.1 1.(3)	RE(2)
							(ID01) 7.6.1 1.(3)	SP.03.08
							(ID01) 7.6.1 1.(3)	RE(3)
							(ID01) 7.6.1 1.(3)	SP.03.09 BR
							(ID01) 7.6.1 1.(3)	SP.03.10 BR
							(ID01) 7.6.1 1.(3)	SP.03.10
							(ID01) 7.6.1 1.(3)	RE(1)
							(ID01) 7.6.1 1.(3)	SP.03.10
							(ID01) 7.6.1 1.(3)	RE(2)
							(ID01) 7.6.1 1.(3)	SP.03.10
							(ID01) 7.6.1 1.(3)	RE(3)
							(ID01) 7.6.1 1.(3)	SP.09.01 BR
							(ID01) 7.6.1 1.(3)	SP.09.02 BR
							(ID01) 7.6.1 1.(3)	SP.09.02
							(ID01) 7.6.1 1.(3)	RE(1)
							(ID01) 7.6.1 1.(3)	SP.09.02
							(ID01) 7.6.1 1.(3)	RE(2)
							(ID01) 7.6.1 1.(3)	SP.09.02
								RE(3)
							(ID01) 7.6.1 1.(3)	SP.09.02
							(ID01) 7.6.1 1.(3)	RE(4)
							(ID01) 7.6.1 1.(3)	SP.09.03 BR
							(ID01) 7.6.1 1.(3)	SP.09.04 BR
							(ID01) 7.6.1 1.(3)	SP.09.04
							(ID01) 7.6.1 1.(3)	RE(1)
							(ID01) 7.6.1 1.(3)	SP.09.05 BR
							(ID01) 7.6.1 1.(3)	SP.09.06 BR
							(ID01) 7.6.1 1.(3)	

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
								SP.09.06
							(ID01) 7.6.1 1.(3)	RE(1)
							(ID01) 7.6.1 1.(3)	SP.09.07 BR
							(ID01) 7.6.1 1.(3)	SP.09.08 BR
							(ID01) 7.6.1 1.(3)	SP.09.08
							(ID01) 7.6.1 1.(3)	RE(1)
							(ID01) 7.6.1 1.(3)	SP.09.09 BR
							(ID01) 7.6.1 1.(3)	SP.09.09
							(ID01) 7.6.1 1.(3)	RE(1)
							(ID01) 7.6.1 1.(3)	
							(ID01) 7.6.1 1.(3)	SP.06.01 BR
							(ID01) 7.6.1 1.(3)	SP.06.01 BR
							(ID01) 7.6.1 1.(3)	SP.06.01
							(ID01) 7.6.1 1.(3)	RE(1)
							(ID01) 7.6.1 1.(3)	SP.02.03 BR
							(ID01) 7.6.1 1.(3)	SP.04.01 BR
							(ID01) 7.6.1 1.(3)	SP.04.02 BR
							(ID01) 7.6.1 1.(3)	SP.04.02
							(ID01) 7.6.1 1.(3)	RE(1)
							(ID01) 7.6.1 1.(3)	SP.04.03
							(ID01) 7.6.1 1.(3)	RE(1)
							(ID01) 7.6.1 1.(3)	SP.04.03
							(ID01) 7.6.1 1.(3)	RE(2)
							(ID01) 7.6.1 1.(3)	
							(ID01) 7.6.1 1.(3)	SP.05.02 BR
								SP.05.03 BR
							(ID01) 7.6.1 1.(3)	SP.05.04 BR
							(ID01) 7.6.1 1.(3)	SP.05.05 BR
							(ID01) 7.6.1 1.(3)	SP.05.05
							(ID01) 7.6.1 1.(3)	RE(1)
							(ID01) 7.6.1 1.(3)	SP.05.06 BR
							(ID01) 7.6.1 1.(3)	SP.05.07 BR
							(ID01) 7.6.1 1.(3)	SP.05.08 BR
							(ID01) 7.6.1 1.(3)	SP.05.09 BR
							(ID01) 7.6.1 1.(3)	SP.05.09
							(ID01) 7.6.1 1.(3)	RE(1)
							(ID01) 7.6.1 1.(3)	

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
							(ID01) 7.6.1 1.(3)	SP.05.09
							(ID01) 7.6.1 1.(3)	RE(2)
							(ID01) 7.6.1 1.(3)	SP.07.01 BR
							(ID01) 7.6.1 1.(3)	SP.07.02 BR
							(ID01) 7.6.1 1.(3)	SP.07.03 BR
							(ID01) 7.6.1 1.(3)	SP.07.04 BR
							(ID01) 7.6.1 1.(3)	SP.07.04
							(ID01) 7.6.1 1.(3)	RE(1)
							(ID01) 7.6.1 1.(3)	SP.08.01 BR
							(ID01) 7.6.1 1.(3)	SP.08.01
							(ID01) 7.6.1 1.(3)	RE(1)
							(ID01) 7.6.1 1.(3)	SP.08.02 BR
							(ID01) 7.6.1 1.(3)	SP.08.02
							(ID01) 7.6.1 1.(3)	RE(1)
							(ID01) 7.6.1 1.(3)	SP.08.02
							(ID01) 7.6.1 1.(3)	RE(2)
							(ID01) 7.6.1 1.(3)	SP.08.03 BR
							(ID01) 7.6.1 1.(3)	SP.08.03
								RE(1)
								SP.08.04 BR
								SP.10.01 BR
								SP.10.02 BR
								SP.10.02
								RE(1)
								SP.10.03 BR
								SP.10.04 BR
								SP.10.05 BR
								SP.10.05
								RE(1)
								SP.10.05
								RE(2)
								SP.11.01 BR
								SP.11.01
								RE(1)
								SP.11.02
								RE(2)

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
								SP.11.02 BR SP.11.02 RE(1) SP.11.03 BR SP.11.04 BR SP.11.05 BR SP.11.06 BR SP.11.06 RE(1) SP.11.06 RE(2) SP.11.06 RE(3) SP.12.01 BR SP.12.02 BR SP.12.03 BR SP.12.04 BR SP.12.05 BR SP.12.06 BR SP.12.07 BR SP.12.08 BR SP.12.09 BR
				FAT Report – Related to security	3.08	(ID01) 6.5.1.4.3		
				Application and Vulnerability Assessment Testing Report	3.11	(ID01) 6.5.1.4.3		
				SAT Test Cases – Related to security	3.12	(ID01) 6.5.1.4.3	(ID01) 7.6.1 3.(1) (ID01) 7.6.1 3.(1) (ID01) 7.6.1 3.(1) (ID01) 7.6.1 3.(2) (ID01) 7.6.1 3.(3)	SP.02.02 RE(2) SP.03.03 BR SP.03.03 RE(1) SP.02.03 RE(1)

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
							(ID01) 7.6.1	SP.03.02 BR
							2.(1)[1]	
							(ID01) 7.6.1	SP.02.02 BR
							2.(2)[1]	SP.03.04 BR
							(ID01) 7.6.1	SP.03.05 BR
							2.(2)[2]	SP.03.05
							(ID01) 7.6.1	RE(1)
							2.(2)[3]	SP.03.06 BR
							(ID01) 7.6.1	SP.03.07 BR
							2.(2)[4]	SP.03.07
							(ID01) 7.6.1	RE(1)
							2.(2)[5]	SP.03.08 BR
							(ID01) 7.6.1	SP.03.08
							2.(2)[6]	RE(1)
							(ID01) 7.6.1	SP.03.08
							2.(2)[7]	RE(2)
							(ID01) 7.6.1	SP.03.08
							2.(2)[7]	RE(3)
							(ID01) 7.6.1	SP.03.09 BR
							2.(2)[7]	SP.03.10 BR
							(ID01) 7.6.1	SP.03.10
							2.(2)[7]	RE(1)
							(ID01) 7.6.1	SP.03.10
							2.(2)[8]	RE(2)
							(ID01) 7.6.1	SP.03.10
							2.(2)[9]	RE(3)
							(ID01) 7.6.1	
							2.(2)[10]	SP.09.01 BR
							(ID01) 7.6.1	SP.09.02 BR
							2.(2)[11]	SP.09.02
							(ID01) 7.6.1	RE(1)
							2.(2)[12]	SP.09.02
								RE(2)
							(ID01) 7.6.1	SP.09.02
							2.(3)[1]	RE(3)
							(ID01) 7.6.1	SP.09.02
							2.(3)[2]	RE(4)

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
							(ID01) 7.6.1	SP.09.03 BR
							2.(3)[3]	SP.09.04 BR
							(ID01) 7.6.1	SP.09.04
							2.(3)[4]	RE(1)
							(ID01) 7.6.1	SP.09.05 BR
							2.(3)[5]	SP.09.06 BR
							(ID01) 7.6.1	SP.09.06
							2.(3)[6]	RE(1)
							(ID01) 7.6.1	SP.09.07 BR
							2.(3)[7]	SP.09.08 BR
							(ID01) 7.6.1	SP.09.08
							2.(3)[8]	RE(1)
							(ID01) 7.6.1	SP.09.09 BR
							2.(3)[8]	SP.09.09
							(ID01) 7.6.1	RE(1)
							2.(3)[9]	
							(ID01) 7.6.1	SP.06.01 BR
							2.(3)[10]	SP.06.01
							(ID01) 7.6.1	RE(1)
							2.(3)[10]	SP.06.01 BR
							(ID01) 7.6.1	SP.06.03 BR
							2.(3)[11]	SP.02.03 BR
							(ID01) 7.6.1	
							2.(3)[12]	SP.04.01 BR
							(ID01) 7.6.1	SP.04.02 BR
							2.(3)[12]	SP.04.02
							(ID01) 7.6.1	RE(1)
							2.(3)[13]	SP.04.03 BR
							(ID01) 7.6.1	SP.04.03
							2.(3)[14]	RE(1)
								SP.04.03
							(ID01) 7.6.1	RE(2)
							2.(4)[1]	
							(ID01) 7.6.1	SP.05.01 BR
							2.(4)[1]	SP.05.02 BR
							(ID01) 7.6.1	SP.05.03 BR
							2.(4)[2]	SP.05.04 BR

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
							(ID01) 7.6.1	SP.05.05 BR
							2.(4)[3]	SP.05.05
							(ID01) 7.6.1	RE(1)
							2.(5)[1]	SP.05.06 BR
								SP.05.07 BR
							(ID01) 7.6.1	SP.05.08 BR
							2.(6)[1]	SP.05.09 BR
							(ID01) 7.6.1	SP.05.09
							2.(6)[2]	RE(1)
							(ID01) 7.6.1	SP.05.09
							2.(6)[3]	RE(2)
							(ID01) 7.6.1	
							2.(6)[4]	SP.07.01 BR
							(ID01) 7.6.1	SP.07.02 BR
							2.(6)[5]	SP.07.03 BR
							(ID01) 7.6.1	SP.07.04 BR
							2.(6)[6]	SP.07.04
								RE(1)
							(ID01) 7.6.1	SP.08.01 BR
							2.(7)[1]	SP.08.01
							(ID01) 7.6.1	RE(1)
							2.(7)[2]	SP.08.02 BR
							(ID01) 7.6.1	SP.08.02
							2.(7)[3]	RE(1)
							(ID01) 7.6.1	SP.08.02
							2.(7)[4]	RE(2)
							(ID01) 7.6.1	SP.08.03 BR
							2.(7)[5]	SP.08.03
							(ID01) 7.6.1	RE(1)
							2.(7)[6]	SP.08.04 BR
							(ID01) 7.6.1	
							2.(7)[7]	SP.10.01 BR
							(ID01) 7.6.1	SP.10.02 BR
							2.(7)[8]	SP.10.02
							(ID01) 7.6.1	RE(1)
							2.(7)[9]	SP.10.03 BR
								SP.10.04 BR

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
							(ID01) 7.6.1	SP.10.05 BR
							2.(7)[10]	SP.10.05
							(ID01) 7.6.1	RE(1)
							2.(7)[10]	SP.10.05
							(ID01) 7.6.1	RE(2)
							2.(7)[10]	
								SP.11.01 BR
							(ID01) 7.6.1	SP.11.01
							2.(8)[1]	RE(1)
							(ID01) 7.6.1	SP.11.02 BR
							2.(8)[2]	SP.11.02
							(ID01) 7.6.1	RE(1)
							2.(8)[3]	SP.11.02
							(ID01) 7.6.1	RE(2)
							2.(8)[4]	SP.11.03 BR
							(ID01) 7.6.1	SP.11.04 BR
							2.(8)[5]	SP.11.05 BR
							(ID01) 7.6.1	SP.11.06 BR
							2.(9)[1]	SP.11.06
							(ID01) 7.6.1	RE(1)
							2.(9)[2]	SP.11.06
							(ID01) 7.6.1	RE(2)
							2.(9)[3]	SP.11.06
							(ID01) 7.6.1	RE(3)
							2.(9)[4]	
							(ID01) 7.6.1	SP.12.01 BR
							2.(9)[5]	SP.12.02 BR
							(ID01) 7.6.1	SP.12.03 BR
							2.(9)[6]	SP.12.04 BR
							(ID01) 7.6.1	SP.12.05 BR
							2.(9)[7]	SP.12.06 BR
							(ID01) 7.6.1	SP.12.07 BR
							2.(9)[8]	SP.12.08 BR
								SP.12.09 BR
							(ID01) 7.6.1	
							2.(10)[1]	

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
							(ID01) 7.6.1 2.(10)[2] (ID01) 7.6.1 2.(10)[3] (ID01) 7.6.1 2.(10)[4] (ID01) 7.6.1 2.(10)[5] (ID01) 7.6.1 2.(10)[6] (ID01) 7.6.1 2.(10)[7] (ID01) 7.6.1 2.(10)[8]	
							(ID01) 7.6.1 2.(11)[1] (ID01) 7.6.1 2.(11)[2] (ID01) 7.6.1 2.(11)[3] (ID01) 7.6.1 2.(11)[4] (ID01) 7.6.1 2.(11)[5] (ID01) 7.6.1 2.(11)[6] (ID01) 7.6.1 2.(11)[7] (ID01) 7.6.1 2.(11)[8] (ID01) 7.6.1 2.(11)[9] (ID01) 7.6.1 2.(11)[10] (ID01) 7.6.1 2.(11)[11]	

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
							(ID01) 7.6.1 2.(11)[12] (ID01) 7.6.1 2.(12)[1] (ID01) 7.6.1 2.(12)[2] (ID01) 7.6.1 2.(12)[3] (ID01) 7.6.1 2.(12)[4] (ID01) 7.6.1 2.(12)[5] (ID01) 7.6.1 2.(12)[6] (ID01) 7.6.1 2.(12)[7] (ID01) 7.6.1 2.(12)[8] (ID01) 7.6.1 2.(12)[9]	
				SAT Report – Related to security	3.13	(ID01) 6.5.1.4.3		
				SIT Report – Related to security	3.15	(ID01) 6.5.1.4.3		
	Penetration Testing	Penetration Testing	SSA-ENG-005	Penetration Testing Report – Related to security	3.17	(ID01) 6.5.1.4.4		
	C3 Control Gate	R3 Gate Review	SSA-ENG-006	SLA Protocol	3.18			
				Security Case – R3 stage	3.19			
				ICSA Report – R3 stage	3.20			

Stage	Sub-Stage	Task Name	Task_ID	Output Delivery	Output_ID	Guideline Section		IEC 62443-2-4 SP Mapping
Operation and Support/ Maintenance (R4) – if applicable	Audit & Continuous Monitoring, if applicable	Perform security review	SSA-O&M-001			(ID01) 6.5.2.1		
		Perform type/setting/configuration management.	SSA-O&M-002			(ID01) 6.5.2.2 (ID01) 7.4.1.4		
		Perform Management of Change (MOC)	SSA-O&M-003			(ID01) 6.5.2.3 (ID01) 7.4.1.11		
		Regular security testing and/or evaluation	SSA-O&M-004			(ID01) 6.5.2.4 (ID01) 7.7.1		
		SuC's cybersecurity incident response and recovery	SSA-O&M-005			(ID01) 6.5.2.5 (ID01) 7.4.1.9		
		Perform continuous monitoring	SSA-O&M-006			(ID01) 6.5.2.6		
	C4 Control Gate, if applicable	R4 Gate Review	SSA-O&M-007			(ID01) 6.5.2.7		
Decommissioning/ Disposal (R5 – if applicable	Secure Decommissioning/Disposal, if applicable	Preserve Information	SSA-EOS-001			(ID01) 6.5.3.1		
		Sanitize Media	SSA-EOS-002			(ID01) 6.5.3.2		
		Dispose Hardware & Software	SSA-EOS-003			(ID01) 6.5.3.3		
	C5 Control Gate, if applicable	R5 Gate Review	SSA-EOS-004			(ID01) 6.5.3.4		

8.3 The tasks, delivery outputs, and implement procedures in accordance with IEC 62443-2-4 SP requirements

SP	Task_ID	Output_ID	Guideline Section
SP.01.01BR	SSA-PLN-001	1.01 PSMP	(ID01) 7.1.1.1 5.~6. (ID01) 7.1.3 1. (ID02) A.1 (ID03) 5.3.2 (ID01) 7.1.3 3. (ID02) A.3 (ID01) 6.3. (ID01) 7.1.2 1.
SP.01.01RE(1)	SSA-PLN-001	1.01 1.02	(ID01) 7.1.1.1 5. (ID02) A.1 (ID01) 7.1.1.2 3.~7. (ID02) A.2 (ID01) 7.1.3 (ID01) 6.3. (ID01) 7.1.2 1.
SP.01.02BR	SSA-PLN-001	1.01 1.02	(ID01) 7.1.1.1 1. (ID02) A.1 (ID01) 7.1.1.2 1. (ID02) A.2 (ID01) 7.1.1.4 (ID01) 7.1.3
SP.01.02RE(1)	SSA-PLN-001	1.01 1.02 PSMP	(ID01) 7.1.1.1 2. (ID02) A.1 (ID01) 7.1.1.2 2. (ID02) A.2 (ID01) 7.1.1.3 1. (ID01) 7.1.3 3. (ID02) Annexes A.1 12.
SP.01.03BR	SSA-PLN-001	1.01 PSMP	(ID01) 7.1.1.1 4.~7. (ID01) 7.1.1.3 (ID01) 7.1.3 1. (ID01) 7.1.3 1. & 4. (ID03) 5.2.1 (ID04) 7.0

SP	Task_ID	Output_ID	Guideline Section
SP.01.03RE(1)	SSA-PLN-001	1.02 PSMP	(ID01) 7.1.3 1. & 4. (ID01) 7.1.3 4. (ID04) 7.0 (ID05) 5.2
SP.01.04BR	SSA-PLN-001	PSMP	(ID01) 7.1.1.3 2. (ID01) 7.1.2 3.
SP.01.04RE(1)	SSA-PLN-001	PSMP 1.02	(ID01) 7.1.1.3 2. (ID01) 7.1.2 3. (ID05) 8.0
SP.01.05BR	SSA-PLN-001	PSMP	(ID01) 7.1.1.3 3. (ID01) 6.2.2. (ID03) 5.3.4 1.
SP.01.06BR	SSA-PLN-001	PSMP	(ID01) 7.1.1.3 4. (ID03) 5.3.2 (ID03) 5.3.3
SP.01.07BR	SSA-PLN-001	PSMP	(ID01) 7.1.1.3 5. (ID03) 5.3.4 1.
SP.02.01BR	SSA-PLN-001 SSA-REQ-002 SSA-DES-001 SSA-ENG-001	1.03 1.04 1.07 2.03 3.02 PSMP	(ID01) 7.2 (ID01) 7.2.1 (ID01) 7.2.1 9. (ID01) 7.3.1 9. (ID02) A.8 (ID01) 7.5 (ID01) 7.4.1.1 1. (ID01) 6.5.1.4.1 (ID01) 7.6.1 1(3) (ID03) 5.6
SP.02.02BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.1 2. (ID01) 7.5 1.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(1)[1]
SP.02.02RE(1)	SSA-PLN-001 SSA-REQ-003	1.03 R1_Review	(ID01) 6.5.1.2.4 2. (ID01) 7.1.1.4 2. (ID01) 7.1.2
SP.02.02RE(2)	SSA-ENG-004	3.07 3.12	(ID01) 7.5 1.(1) (ID01) 7.6.1 1.(1) (ID01) 7.6.1 3.(1)

SP	Task_ID	Output_ID	Guideline Section
			(ID01) 6.5.2.1 (ID01) 7.7.1
SP.02.02RE(3)	SSA-PLN-001	1.03	(ID01) 7.1.1.4 2. (ID01) 7.5 1.(1) (ID01) 7.6.1 1.(1) (ID01) 7.6.1 3.(1)
SP.02.03BR	SSA-ENG-001 SSA-ENG-004	3.01 3.04 3.07 3.12	(ID01) 7.4.1.5 (ID01) 7.5 5.(1) (ID01) 7.6.1 1.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(5)[1]
SP.02.03RE(1)	SSA-ENG-004	3.07 3.12	(ID01) 7.4.1.5 (ID01) 7.5 5.(1) (ID01) 7.6.1 1.(2) (ID01) 7.6.1 3.(2) (ID01) 7.6.1 2.(5)[1] (ID01) 6.5.1.2
SP.03.01BR	SSA-REQ-002 SSA-DES-001	1.04 2.03	(ID01) 7.2.1 4.~7. (ID01) 7.3.1 3.
SP.03.01RE(1)	SSA-REQ-002 SSA-DES-001 SSA-DES-003	1.07 2.03 SC_Review	(ID01) 7.2.1 9. (ID01) 7.3.1 7. (ID01) 6.5.1.3.2-2.
SP.03.01RE(2)	SSA-REQ-003 SSA-DES-002	R1_Review SA_Review	(ID01) 6.5.1.2.4 5. (ID01) 7.2.1 8.
SP.03.02BR	SSA-ENG-001 SSA-ENG-004	3.02 3.12	(ID01) 7.4.1.2 1. (ID01) 7.5 2.(6) (ID01) 7.6.1 2.(2)[13] (ID01) 7.6.1 3.(3)
SP.03.02RE(1)	SSA-DES-001	2.03	(ID01) 7.3.1.1 4. (1) (ID01) 7.5 2.(7) (ID01) 7.6.1 2.(2)[14]
SP.03.02RE(2)	SSA-DES-001	2.03	(ID01) 7.3.1.1 4.(2)~(3) (ID01) 7.5 2.(8) (ID01) 7.6.1 2.(2)[15]
SP.03.03BR	SSA-REQ-003 SSA-PLN-001 SSA-ENG-004	R1_Review 1.03 3.07	(ID01) 6.5.1.2.4 6. (ID01) 7.1.1.4 2. (ID01) 7.5 2.(9)(ID01) 7.6.1 1.(1)

SP	Task_ID	Output_ID	Guideline Section
		3.12	(ID01) 7.6.1 2.(2)[16] (ID01) 7.6.1 3.(1)
SP.03.03RE(1)	SSA-REQ-003 SSA-PLN-001 SSA-ENG-004	R1_Review 1.03 3.07 3.12	(ID01) 6.5.1.2.4 6. (ID01) 7.1.1.4 2. (ID01) 7.5 2.(10) (ID01) 7.6.1 2.(2)[17] (ID01) 7.6.1 1.(1) (ID01) 7.6.1 3.(1)
SP.03.04BR	SSA-ENG-001 SSA-ENG-004	3.02 3.12	(ID01) 7.4.1.2 2. (ID01) 7.5 2.(11) (ID01) 7.6.1 2.(2)[18] (ID01) 7.6.1 2.(2)[1]
SP.03.05BR	SSA-ENG-001 SSA-ENG-004	3.02 3.12	(ID01) 7.4.1.2 3. (ID01) 7.5 2.(12) (ID01) 7.6.1 2.(2)[19] (ID01) 7.6.1 2.(2)[2]
SP.03.05RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.12	(ID01) 7.4.1.2 4. (ID01) 7.5 2.(13) (ID01) 7.6.1 2.(2)[20] (ID01) 7.6.1 2.(2)[3]
SP.03.06BR	SSA-ENG-001 SSA-ENG-004	3.02 3.12	(ID01) 7.4.1.2 5. (ID01) 7.5 2.(14)(ID01) 7.6.1 2.(2)[21] (ID01) 7.6.1 2.(2)[4]
SP.03.07BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.2 6. (ID01) 7.5 2.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[5]
SP.03.07RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.2 7. (ID01) 7.5 2.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[6]
SP.03.08BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.2 8. (ID01) 7.5 2.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[7]
SP.03.08RE(1)	SSA-ENG-001	3.02	(ID01) 7.4.1.2 8.(1)

SP	Task_ID	Output_ID	Guideline Section
	SSA-ENG-004	3.04 3.07 3.12	(ID01) 7.5 2.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[7]
SP.03.08RE(2)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.2 8.(2) (ID01) 7.5 2.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[7]
SP.03.08RE(3)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.2 8.(3) (ID01) 7.5 2.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[7]
SP.03.09BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.2 9. (ID01) 7.5 2.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[8]
SP.03.10BR	SSA-DES-001 SSA-ENG-001 SSA-ENG-004	2.03 3.02 3.04 3.07 3.12	(ID01) 7.3.1 4. (4) (ID01) 7.4.1.2 10. (ID01) 7.5 2.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[9]
SP.03.10RE(1)	SSA-DES-001 SSA-ENG-001 SSA-ENG-004	2.03 3.02 3.04 3.07 3.12	(ID01) 7.3.1 4. (4) (ID01) 7.4.1.2 10.(1) (ID01) 7.5 2.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[10]
SP.03.10RE(2)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.2 10.(2) (ID01) 7.5 2.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[11]
SP.03.10RE(3)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.2 10.(3) (ID01) 7.5 2.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[12]
SP.03.10RE(4)	Decommissioning/ Disposal	Sanitize Media	(ID01) 6.5.3.2 (ID01) 6.5.3.4 1.
SP.04.01BR	SSA-DES-001 SSA-ENG-001	2.03 3.02	(ID01) 7.3.1 5. (ID01) 7.4.1.6 1.

SP	Task_ID	Output_ID	Guideline Section
	SSA-ENG-004	3.04 3.07 3.12	(ID01) 7.5 6.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(6)[1]
SP.04.02BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.6 2. (ID01) 7.5 6.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(6)[2]
SP.04.02RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.6 3. (ID01) 7.5 6.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(6)[3]
SP.04.03BR	SSA-DES-001 SSA-ENG-001 SSA-ENG-004	2.03 3.02 3.12	(ID01) 7.3.1 6. (ID01) 7.4.1.6 4. (ID01) 7.6.1 2.(6)[4]
SP.04.03RE(1)	SSA-DES-001 SSA-ENG-001 SSA-ENG-004	2.03 3.02 3.04 3.07 3.12	(ID01) 7.3.1 6. (ID01) 7.4.1.6 5. (ID01) 7.5 6.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(6)[5]
SP.04.03RE(2)	SSA-DES-001 SSA-ENG-001 SSA-ENG-004	2.03 3.02 3.04 3.07 3.12	(ID01) 7.3.1 6. (ID01) 7.4.1.6 6. (ID01) 7.5 6.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(6)[6]
SP.05.01BR	SSA-DES-001 SSA-DES-002 SSA-DES-003 SSA-ENG-004	2.03 SA_Review SC_Review 3.12	(ID01) 7.3.1 8. (ID01) 7.3.2 1. (ID01) 7.3.2 2. (ID01) 7.6.1 2.(7)[1]
SP.05.02BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.7 1. (ID01) 7.5 7.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[2]
SP.05.03BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.7 2. (ID01) 7.5 7.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[3]
SP.05.04BR	SSA-ENG-001	3.02	(ID01) 7.4.1.7 3.

SP	Task_ID	Output_ID	Guideline Section
	SSA-ENG-004	3.04 3.07 3.12	(ID01) 7.5 7.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[4]
SP.05.05BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.7 4. (ID01) 7.5 7.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[5]
SP.05.05RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.7 5. (ID01) 7.5 7.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[6]
SP.05.06BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.7 6. (ID01) 7.5 7.(6) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[7]
SP.05.07BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.7 7. (ID01) 7.5 7.(7) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[8]
SP.05.08BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.7 8. (ID01) 7.5 7.(8) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[9]
SP.05.09BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.7 9. (ID01) 7.5 7.(9) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[10]
SP.05.09RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.7 9.(1) (ID01) 7.5 7.(9) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[10]
SP.05.09RE(2)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.7 9.(2) (ID01) 7.5 7.(9) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[10]
SP.06.01BR	SSA-REQ-002 SSA-REQ-003	1.05 R1_Review	(ID01) 7.2.1 1. (ID01) 7.2.1 3.

SP	Task_ID	Output_ID	Guideline Section
	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 6.5.1.2.4 3. (ID01) 7.4.1.4 2.(1) (ID01) 7.4.1.4 2.(2) (ID01) 7.5 4.(1) (ID01) 7.5 4.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(4)[1] (ID01) 7.6.1 2.(4)[2]
SP.06.01RE(1)	SSA-DES-001 SSA-ENG-001 SSA-ENG-004	2.01 2.02 3.02 3.04 3.07 3.12	(ID01) 7.3.1 1. (ID01) 7.3.1 2. (ID01) 7.4.1.4 2.(3) (ID01) 7.5 4.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(4)[1]
SP.06.02BR	SSA-REQ-002 SSA-REQ-003	1.06 R1_Review	(ID01) 7.2.1 2. (ID01) 6.5.1.2.4 3. (ID01) 7.2.2 3.
SP.06.03BR	SSA-REQ-003 SSA-ENG-001 SSA-ENG-004	R1_Review 3.02 3.12	(ID01) 7.2.2 3. (ID01) 7.4.1.4 2.(4) (ID01) 7.6.1 2.(4)[3]
SP.07.01BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.8 1. (ID01) 7.5 8.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(8)[1]
SP.07.02BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.8 2. (ID01) 7.5 8.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(8)[2]
SP.07.03BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.8 3. (ID01) 7.5 8.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(8)[3]
SP.07.04BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.8 4. (ID01) 7.5 8.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(8)[4]

SP	Task_ID	Output_ID	Guideline Section
SP.07.04RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.8 5. (ID01) 7.5 8.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(8)[5]
SP.08.01BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.9 1. (ID01) 7.5 9.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(9)[1]
SP.08.01RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.9 2. (ID01) 7.5 9.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(9)[2]
SP.08.02BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.9 3. (ID01) 7.5 9.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(9)[3]
SP.08.02RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.9 3.(1) (ID01) 7.5 9.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(9)[4]
SP.08.02RE(2)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.9 3.(2) (ID01) 7.5 9.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(9)[5]
SP.08.03BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.9 4. (ID01) 7.5 9.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(9)[6]
SP.08.03RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.9 4.(1) (ID01) 7.5 9.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(9)[7]
SP.08.04BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.9 5. (ID01) 7.5 9.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(9)[8]
SP.09.01BR	SSA-ENG-001	3.02	(ID01) 7.4.1.3 1.

SP	Task_ID	Output_ID	Guideline Section
	SSA-ENG-004	3.04 3.07 3.12	(ID01) 7.5 3.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[1]
SP.09.02BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.3 2. (ID01) 7.5 3.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[2]
SP.09.02RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.3 2.(1) (ID01) 7.5 3.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[3]
SP.09.02RE(2)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.3 2.(2) (ID01) 7.5 3.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[4]
SP.09.02RE(3)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.3 2.(3) (ID01) 7.5 3.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[5]
SP.09.02RE(4)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.3 2.(4) (ID01) 7.5 3.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[6]
SP.09.03BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.3 3. (ID01) 7.5 3.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[7]
SP.09.04BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.3 4. (ID01) 7.5 3.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[8]
SP.09.04RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.3 4.(1) (ID01) 7.5 3.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[8]
SP.09.05BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04	(ID01) 7.4.1.3 5. (ID01) 7.5 3.(5)

SP	Task_ID	Output_ID	Guideline Section
		3.07 3.12	(ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[9]
SP.09.06BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.3 6. (ID01) 7.5 3.(6) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[10]
SP.09.06RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.3 6.(1) (ID01) 7.5 3.(6) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[10]
SP.09.07BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.3 7. (ID01) 7.5 3.(7) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[11]
SP.09.08BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.3 8. (ID01) 7.5 3.(8) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[12]
SP.09.08RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.3 8.(1) (ID01) 7.5 3.(9) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[12]
SP.09.09BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.3 9. (ID01) 7.5 3.(10) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[13]
SP.09.09RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.3 9.(1) (ID01) 7.5 3.(10) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[14]
SP.10.01BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.10 1. (ID01) 7.5 10.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(10)[1]
SP.10.02BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07	(ID01) 7.4.1.10 2. (ID01) 7.5 10.(2) (ID01) 7.6.1 1.(3)

SP	Task_ID	Output_ID	Guideline Section
		3.12	(ID01) 7.6.1 2.(10)[2]
SP.10.02RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.10 2.(1) (ID01) 7.5 10.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(10)[3]
SP.10.03BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.10 3. (ID01) 7.5 10.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(10)[4]
SP.10.04BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.10 4. (ID01) 7.5 10.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(10)[5]
SP.10.05BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.10 5. (ID01) 7.5 10.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(10)[6]
SP.10.05RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.10 5.(1) (ID01) 7.5 10.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(10)[7]
SP.10.05RE(2)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.10 5.(2) (ID01) 7.5 10.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(10)[8]
SP.11.01BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.11 2. (ID01) 7.5 11.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[1]
SP.11.01RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.11 2.(1) (ID01) 7.5 11.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[2]
SP.11.02BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.11 3. (ID01) 7.5 11.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[3]

SP	Task_ID	Output_ID	Guideline Section
SP.11.02RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.11 3.(1) (ID01) 7.5 11.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[4]
SP.11.02RE(2)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.11 3.(2) (ID01) 7.5 11.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[5]
SP.11.03BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.11 4. (ID01) 7.5 11.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[6]
SP.11.04BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.11 5. (ID01) 7.5 11.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[7]
SP.11.05BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.11 6. (ID01) 7.5 11.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[8]
SP.11.06BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.11 7. (ID01) 7.5 11.(6) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[9]
SP.11.06RE(1)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.11 7.(1) (ID01) 7.5 11.(6) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[10]
SP.11.06RE(2)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.11 7.(2) (ID01) 7.5 11.(6) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[11]
SP.11.06RE(3)	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.11 7.(3) (ID01) 7.5 11.(6) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[12]
SP.12.01BR	SSA-ENG-001	3.02	(ID01) 7.4.1.12 1.

SP	Task_ID	Output_ID	Guideline Section
	SSA-ENG-004	3.04 3.07 3.12	(ID01) 7.5 12.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(12)[1]
SP.12.02BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.12 2. (ID01) 7.5 12.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(12)[2]
SP.12.03BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.12 3. (ID01) 7.5 12.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(12)[3]
SP.12.04BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.12 4. (ID01) 7.5 12.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(12)[4]
SP.12.05BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.12 5. (ID01) 7.5 12.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(12)[5]
SP.12.06BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.12 6. (ID01) 7.5 12.(6) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(12)[6]
SP.12.07BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.12 7. (ID01) 7.5 12.(7) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(12)[7]
SP.12.08BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.12 8. (ID01) 7.5 12.(8) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(12)[8]
SP.12.09BR	SSA-ENG-001 SSA-ENG-004	3.02 3.04 3.07 3.12	(ID01) 7.4.1.12 9. (ID01) 7.5 12.(9) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(12)[9]

--- End of Document ---